

Daily Vulnerability Report - 2026-09-12

Window (UTC): 2026-09-11T10:16 to 2026-09-12T10:16 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-12 10:17:02 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
1391	6	115	402	354	32	488	784

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85706	10.0	CRIT	Yes		gitlab:community edition and enterprise edition	GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-84869	9.9	CRIT	Yes	0.004	connectwise:screenconnect	A condition in the ScreenConnect client may allow files to be transferred and executed through an active remote session without authorization or Host confirmation in certain circumstances. ScreenConnect servers are not impacted.
CVE-2026-86060	9.2	CRIT	Yes	0.007	mikrotik:routeros	RouterOS contains an argument-handling flaw in the SSH login path involving usernames that begin with a prohibited character, allowing for the trusted RouterOS policy mask to be changed, leading to privilege escalation. Exploitation requires an unauthenticated SSH session to reach the RouterOS login helper.This issue was fixed in versions: 6.49.21 (Long-term), 7.23.4 (Long-term) and 7.24.2 (Stable)
CVE-2026-42016	8.8	HIGH	Yes	0.003	jfrog:artifactory	JFrog Artifactory (Self Hosted) versions before 7.133.11 are vulnerable to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
CVE-2026-67277	8.8	HIGH	Yes	0.007	mikrotik:routeros	RouterOS accepts a "related" btest connection before the corresponding primary session has completed authentication. An unauthenticated client can use this state to start an IPv4 UDP test. With "random-data=false", the sender transmits an uninitialized tail from a kernel packet buffer. A separate unchecked, inverted packet-size interval causes unsigned integer underflow, anomalously large fragmented output, and ca...
CVE-2026-42018	7.5	HIGH	Yes	0.003	jfrog:artifactory	JFrog Artifactory could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-14560	10.0	CRIT		0.002		The teddy-bear-customize-addon WordPress plugin through 1.0.5 does not properly validate uploaded files, relying on a client-supplied content type and preserving the original filename, allowing unauthenticated attackers to upload arbitrary PHP files and execute code on the server.
CVE-2026-46595	10.0	CRIT		0.005	golang:crypto	Previously, CVE-2024-45337 fixed an authorization bypass for misused ssh server configurations; if any other type of callback is passed other than public key, then the source-address validation would be skipped.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80462	10.0	CRIT				A vulnerability in the Chef Automate API gateway and identity validation path may allow an unauthenticated actor to gain elevated access to protected Chef Automate functionality under specific conditions.
CVE-2026-82004	10.0	CRIT		0.014	adobe:campaign	Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82617	10.0	CRIT				The two built-in name-finder patterns exposed by <code>opennlp.tools.namefind.RegexNameFinderFactory - DEFAULT_REGEX_NAME_FINDER.EMAIL</code> and <code>DEFAULT_REGEX_NAME_FINDER.URL</code> - contain ambiguous nested quantifiers. An application that obtains these finders through <code>RegexNameFinderFactory.getDefaultRegexNameFinders(...)</code> and then applies them to untrusted text through <code>RegexNameFinder.find(String[])</code> or <code>RegexNameFinder.find(String...</code>
CVE-2026-87985	10.0	CRIT				An arbitrary code execution vulnerability in Mistral Vibe allows an attacker to bypass command permission checks using ANSI-C quoted arguments. These arguments are not properly inspected, enabling a crafted allowlisted command to execute arbitrary code on the user's system without approval.
CVE-2026-87986	10.0	CRIT				An arbitrary code execution vulnerability in Mistral Vibe allows an attacker to bypass command permission checks using shell constructs it's parser cannot interpret. Unparsed portions are omitted from inspection, enabling embedded commands to execute on the user's system without approval.
CVE-2026-87987	10.0	CRIT				An arbitrary code execution vulnerability in Mistral Vibe allows an attacker to bypass command permission checks using environment variable assignments preceding allowlisted commands. These assignments are excluded from inspection, enabling attacker-controlled environment variables to cause arbitrary code execution without user approval.
CVE-2026-87988	10.0	CRIT				An arbitrary file access vulnerability in Mistral Vibe allows an attacker to bypass workspace restrictions through commands classified as unconditionally allowed. Missing path validation for these commands enables access to files outside the active workspace without user approval.
CVE-2026-15630	9.9	CRIT		0.003		A non-global organization admin in one tenant can bypass tenant boundaries to delete, create, or modify resources in any other tenant by exploiting a mismatch between authorization (based on <code>?id=</code>) and action (based on request body).
CVE-2026-19232	9.9	CRIT		0.006	adobe:experience_manager	Adobe Experience Manager is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user, potentially gaining elevated access or control over the victim's account or session. A low-privileged attacker could exploit this vulnerability to gain elevated access or control over the victim's account or session. Exploitation of this issue does not r...
CVE-2026-62420	9.9	CRIT		0.003	canonical:lxd	An authorization bypass vulnerability in LXD allows an authenticated attacker to bypass target project security restrictions during cross-project instance migrations. When moving an instance cross-project to a different cluster member via <code>POST /1.0/instances/{name}</code> with <code>migration: true</code> , <code>project: <target></code> , and <code>target: <member></code> , the destination node skips all project restriction checks because the request arrives as...
CVE-2026-63294	9.9	CRIT		0.01	canonical:lxd	A link following vulnerability in LXD allows an attacker to achieve root command execution on the host system. During the import or unpacking of crafted image or backup archives, LXD fails to properly validate and confine the <code>backup.yaml</code> file when it exists as a symbolic link. An attacker can exploit this flaw by providing a malicious archive with a symlinked <code>backup.yaml</code> file, causing LXD to process unconfined con...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-63296	9.9	CRIT		0.002	canonical:lxd	An authorization bypass vulnerability in LXD allows an authenticated attacker to bypass target project restrictions during instance migration. When migrating an instance to a target project, LXD accepts configuration overrides without validating the new configuration against the target project's enforced restrictions. An attacker can exploit this flaw to move instances with disallowed high-privilege configurations...
CVE-2026-63297	9.9	CRIT		0.002	canonical:lxd	An authorization bypass vulnerability in LXD due to a timing flaw during configuration merging allows an authenticated attacker to bypass target project restrictions during cross-project instance copies. When copying an instance to a target project, LXD performs restriction checks before configuration merging is complete, creating a time-of-check to time-of-use (TOCTOU) condition. An attacker can exploit this flaw...
CVE-2026-63298	9.9	CRIT		0.004	canonical:lxd	An improper neutralization of special elements vulnerability in LXD's NVIDIA instance configuration handling allows an authenticated attacker to inject arbitrary configuration directives. By supplying newline characters within the 'nvidia.driver.capabilities' or 'nvidia.require.*' configuration values, an attacker can manipulate the generated lxc.conf file. This flaw enables the attacker to execute arbitrary code ...
CVE-2026-63299	9.9	CRIT		0.003	canonical:lxd	An authorization bypass vulnerability in LXD allows an authenticated user to bypass project-level disk and volume limits. Two related code paths fail to verify resource limits during volume operations: the storagePoolVolumeTypePostMove function omits the limits.AllowVolumeCreation check before moving a volume across projects, and volume snapshot restore operations skip the AllowVolumeUpdate check when the configur...
CVE-2026-63300	9.9	CRIT		0.003	canonical:lxd	An improper validation vulnerability in the instancePostMigration function in lxd/instance_post.go of LXD allows an authenticated attacker with can_create_instances permissions on a restricted project to bypass project-level security restrictions. When migrating an instance between projects, LXD fails to validate the instance's configuration against the target project's enforced restrictions (such as restricted.co...
CVE-2026-65646	9.9	CRIT		0.003		Improper neutralization of special elements in in Plesk's DNS zone management functionality allows remote authenticated users to disclose arbitrary local files and escalate privileges.
CVE-2026-66897	9.9	CRIT		0.006	canonical:lxd	A path traversal vulnerability in LXD's instance template processing allows an attacker with container edit permissions, or any user launching a crafted image, to overwrite arbitrary files on the host system as root. When processing target template paths specified in metadata.yaml, LXD validates the path against a confined os.Root directory handle but subsequently opens and creates the file using os.Create with an...
CVE-2026-66898	9.9	CRIT		0.003	canonical:lxd	A path traversal vulnerability in LXD allows an attacker to manipulate file system paths during backup import and restore operations. When importing or restoring a backup archive, LXD fails to validate instance and storage volume names contained within the archive metadata. An attacker can exploit this flaw by supplying a crafted backup archive with malicious instance or volume names containing path traversal sequ...
CVE-2026-87719	9.9	CRIT				GitLab has remediated an issue in GitLab EE affecting all versions from 18.3 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could allow an authenticated user with Duo Chat access to obtain Advanced Search instance configurations and sensitive credentials using a specially crafted GraphQL subscription argument to bypass serialization and perform server object lookup.
CVE-2026-14559	9.8	CRIT		0.001		The teddy-bear-customize-addon WordPress plugin through 1.0.5 does not verify a user's password before authenticating them, allowing unauthenticated attackers to log in as any registered user, including administrators, by supplying only that user's email address.
CVE-2026-14563	9.8	CRIT		0.001		The advanced-customized-prompts WordPress plugin through 1.0.1 does not verify the password before issuing an authenticated session for a supplied email address in an unauthenticated action, allowing unauthenticated attackers to log in as any registered user, including administrators, or to create arbitrary new accounts.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19931	9.8	CRIT		0.008	haxx:curl	A flaw in libcurl makes it wrongly reuse an HTTP connection setup for a given hostname using Negotiate authentication, when the initial request is done using empty credentials. This can make user B's request get sent over user A's previously authenticated connection.
CVE-2026-28606	9.8	CRIT		0.003		In handleBondStateChanged of AdapterService.java, there is a possible way to skip pairing due to a logic error in the code. This could lead to remote escalation of privilege without user consent with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-42581	9.8	CRIT		0.006	netty:netty	Netty is an asynchronous, event-driven network application framework. Prior to 4.2.13.Final and 4.1.133.Final, HttpObjectDecoder strips a conflicting Content-Length header when a request carries both Transfer-Encoding: chunked and Content-Length, but only for HTTP/1.1 messages. The guard is absent for HTTP/1.0. An attacker that sends an HTTP/1.0 request with both headers causes Netty to decode the body as chunked ...
CVE-2026-43830	9.8	CRIT		0.003		Full details and mitigation steps are currently restricted and will be published at a later date.
CVE-2026-53952	9.8	CRIT				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. A logic flaw in GetSimple CMS (v3.4.0a and below) and GetSimpleCMS-CE (v3.3.22 and below) allows unauthenticated attackers to create a new administrator account. The application features an automated security control designed to delete the sensitive `admin/setup.php` file post-installation. However, this ...
CVE-2026-62103	9.8	CRIT				Unauthenticated PHP Object Injection in Everest Forms <= 3.6.0 versions.
CVE-2026-62105	9.8	CRIT				Unauthenticated PHP Object Injection in ThemeREX Addons < 2.45.0 versions.
CVE-2026-63073	9.8	CRIT		0.009	openssl:openssl	Issue summary: OpenSSL CMP response validation passed an unexpected response sender distinguished name directly as the format string to `ERR_raise_data()`. Impact summary: A malicious or intercepted CMP endpoint can crash a CMP client that enforces an expected sender or uses a pinned server certificate whose subject becomes the default expected sender. CWE: CWE-134 (Use of Externally-Controlled Format String) D...
CVE-2026-69431	9.8	CRIT		0.009		Heap-based buffer overflow in Telnet Client allows an unauthorized attacker to execute code over a network.
CVE-2026-71644	9.8	CRIT				An issue in Robotics-STAR-Lab (SYSU STAR Group) RACER Tested affected version: commit abcdef1234567890 allows an attacker to cause unsafe trajectory planning and potential UAV collisions via a missing default case in the FSM that stops publishing swarm trajectories when the drone enters IDLE
CVE-2026-78006	9.8	CRIT				The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.4 via the is_safe_widget_instance function. This is due to insufficient protection in is_safe_widget_instance, which can be bypassed because PHP fires magic methods during its pre-parse, combined with enable_rendering_widget_copied() forging a valid wp_hash integrity attribute before unser...
CVE-2026-78159	9.8	CRIT				The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.3 via the parse_array function. This is due to insufficient validation of the widget 'classes' map, allowing a plain-array payload to bypass the is_safe_widget_instance() object check and reach the callable-invocation sink in Element_Classes::parse_array(). This makes it possible for unaut...
CVE-2026-78445	9.8	CRIT		0.009	microsoft:windows_server_2012, microsoft:windows_server_2016, microsoft:windows_server_2019, microsoft:windows_server_20	Use after free in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-78573	9.8	CRIT		0.004		IBM ContextForge MCP Gateway 1.0.0 through 1.0.7 could allow a remote attacker to gain administrative access due to the use of default credentials.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-79395	9.8	CRIT				An improper authentication vulnerability in the WS-Security (wsse:UsernameToken) verification routine within the Sofia IPC daemon in Xiongmai IP Camera XM530 firmware HMT.CM2005-v220608.1837 and earlier allows remote attackers to bypass authentication and execute privileged ONVIF actions (including PTZ control, stream URL retrieval, and system reboot) via a crafted SOAP request supplying the admin username with an...
CVE-2026-79689	9.8	CRIT		0.019	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.
CVE-2026-79724	9.8	CRIT		0.005		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary OS commands due to improper neutralization of special elements used in an OS command.
CVE-2026-79941	9.8	CRIT		0.019	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.
CVE-2026-81204	9.8	CRIT		0.006		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary code due to code injection during graph construction.
CVE-2026-81467	9.8	CRIT		0.038		Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Command execution.
CVE-2026-84390	9.8	CRIT				A inclusion of sensitive information in source code vulnerability in Fortinet FortiMonitorOnSight 7.2.4 through 7.2.7, FortiMonitorOnSight 7.2.0 through 7.2.2 may allow attacker to improper access control via <insert attack vector here>
CVE-2026-85025	9.8	CRIT		0.004		IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an unauthenticated attacker to execute arbitrary code and access or modify chat sessions through publicly shared MCP project endpoints due to improper enforcement of public-flow security restrictions and session isolation controls.
CVE-2026-8778	9.8	CRIT		0.006		The MIPL Grouped Checkout Fields for WooCommerce – Customize & Organize Checkout Fields. plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the `mipl_wc_upload_file` function in all versions up to, and including, 1.2.1. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution po...
CVE-2026-39821	9.6	CRIT		0.007	golang:net	The ToASCII and ToUnicode functions incorrectly accept Punycode-encoded labels that decode to an ASCII-only label. For example, ToUnicode("xn--example-.com") incorrectly returns the name "example.com" rather than an error. This behavior can lead to privilege escalation in programs using the idna package. For example, a program which performs privilege checks on the ASCII hostname may reject "example.com" but permi...
CVE-2026-70846	9.6	CRIT		0.003	oracle:demand_planning	Vulnerability in the Oracle Demand Planning product of Oracle Supply Chain (component: Internal Operations). Supported versions that are affected are 12.1 and 12.2. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Demand Planning. While the vulnerability is in Oracle Demand Planning, attacks may significantly impact additional products (scope chan...
CVE-2026-81376	9.6	CRIT		0.007	microsoft:visual_studio_code	Incomplete comparison with missing factors in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82100	9.6	CRIT		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to a path traversal vulnerability.
CVE-2026-82107	9.6	CRIT		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information and bypass security restrictions due to improper authentication.
CVE-2026-19001	9.5	CRIT		0.004	mongodb:bi_connector_odbc_driver	The MongoDB BI Connector ODBC Driver may write outside the bounds of a fixed-size buffer when an application supplies an unusually long catalog, schema, or object name to a metadata retrieval function. This may result in memory corruption within the calling application's process, leading to abnormal termination and, under certain conditions, the potential for arbitrary code execution.
CVE-2026-70477	9.5	CRIT		0.004	flowiseai:flowise	Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, a prompt injection sent to a chatflow using a CSV Agent node can cause the LLM to respond with a malicious Python script that bypasses the blocklist validator and executes in an unsandboxed Pyodide environment. The specific flaw exists within the run method of the CSV_Agents class, where untrusted data is used ...
CVE-2026-88062	9.5	CRIT		0.004		OmniRoute is an open-source AI gateway providing a single endpoint for multiple model providers. In 3.8.49 and earlier, the OmniRoute POST /api/acp/agents custom ACP agent endpoint accepted attacker-controlled binary and versionCommand values and used only a self-consistency check before execFileSync executed the selected interpreter and arguments. The same request called refreshAgentCache, and resolveVersionProbe...
CVE-2026-28384	9.4	CRIT		0.005	canonical:lxd	An improper sanitization of the compression_algorithm parameter in Canonical LXD allows an authenticated, unprivileged user to execute commands as the LXD daemon on the LXD server via API calls to the image and backup endpoints. This issue affected LXD from 4.12 through 6.6 and was fixed in the snap versions 5.0.6-e49d9f4 (channel 5.0/stable), 5.21.4-1374f39 (channel 5.21/stable), and 6.7-1f11451 (channel 6.0 stab...
CVE-2026-38056	9.4	CRIT				A local privilege escalation vulnerability exists in the iDirect iQ200 VSAT terminal running firmware 23.0.1.0. The iQ200 is a rackmount satellite modem deployed across oil and gas, maritime, defense, and remote infrastructure as the primary, and often sole communications link for offshore rigs, vessels, and remote sites. Important context: the device ships from the factory with a pre-configured low-privilege loca...
CVE-2026-61410	9.4	CRIT		0.013	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains a Missing Authorization vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution. This vulnerability is considered critical because it allows an attacker to execute commands remotely on a target system by sending a spe...
CVE-2026-81046	9.4	CRIT		0.004		Dell ThinOS 10, versions prior to 2605_10.2616, contain a Protection Mechanism Failure vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Arbitrary Code Execution within the application context.
CVE-2026-82466	9.4	CRIT		0.003		Rodauth before 2.46.0 contains an authentication bypass vulnerability in the webauthn_login route that allows logged-in users to authenticate as any other account. Attackers can exploit improper account resolution logic that falls back to session account identifiers instead of validating the credential binding to complete authentication as arbitrary users.
CVE-2026-86151	9.4	CRIT		0.02		A vulnerability was detected in Tenda CP3 27.5.57.101. The affected element is the function sub_2F77E8 of the file Apis/system.c of the component Network Configuration Management. Performing a manipulation results in os command injection. The attack may be initiated remotely.
CVE-2025-14813	9.3	CRIT		0.003		: Use of a Broken or Risky Cryptographic Algorithm vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcpv on all (core modules). This vulnerability is associated with program files G3413CTRBlockCipher. This issue affects BC-JAVA: from 1.59 before 1.80.2, from 1.81 before 1.81.1, from 1.82 before 1.84.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54072	9.3	CRIT				Authorizer is an open-source, self-hostable authentication and authorization server. Prior to version 2.2.1, the `authorize` endpoint accepts any `redirect_uri` without validating it against `AllowedOrigins`. When `response_type=token` or `response_type=id_token`, the server appends `access_token`, `id_token`, and `refresh_token` as query parameters and issues a 302 redirect to the attacker-supplied URL. An unaut...
CVE-2026-67292	9.3	CRIT		0.003	freerdp:freerdp	FreeRDP before 3.29.0 contains a buffer over-disclosure vulnerability in the gateway WebSocket transport (libfreerdp/core/gateway/websocket.c). The client's Pong reply reuses a fixed 1024-byte response stream whose length is not sealed to the actual received Ping payload, so a malicious gateway/WebSocket peer sending a non-empty Ping control frame causes the client to reply with an overlong Pong that discloses byt...
CVE-2026-67294	9.3	CRIT		0.003	freerdp:freerdp	FreeRDP before 3.29.0 improperly validates the Extended Key Usage (EKU) purpose of the peer certificate during client-side server TLS authentication. In x509_utils_verify(), when server-purpose (X509_PURPOSE_SSL_SERVER) verification fails, the code falls back to client-purpose and any-purpose verification, so a trusted, hostname-matching certificate valid only for clientAuth can be accepted as the RDP server certi...
CVE-2026-72709	9.3	CRIT				SPIP before 4.4.18 contains a missing authorization vulnerability in the administrative action endpoints under ecrire/action/ that allows unauthenticated attackers to perform privileged actions by supplying a valid HMAC-SHA256 nonce without any server-side permission check via autoriser(). Attackers can obtain a valid nonce, compute it for any action as the anonymous user, and invoke the editor_auteur action direc...
CVE-2026-72710	9.3	CRIT				SPIP before 4.4.18 contains a remote code execution vulnerability in the editor_objet action where the arg parameter resolves SQL table names without enforcing an editable columns allowlist, allowing attackers with a valid nonce to inject attacker-controlled rows into the spip_jobs table. Attackers can supply arg=job/0 with crafted fonction and args values, which are later unserialized and executed when the cron j...
CVE-2026-75940	9.3	CRIT		0.003		A vulnerability was reported in Lenovo Health Android Application, distributed exclusively in the Chinese market, that could allow an attacker to access sensitive health-related information.
CVE-2026-77089	9.3	CRIT		0.003	commvault:commvault	Command Center API contained an authentication bypass issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update Command Center.
CVE-2026-80238	9.3	CRIT		0.001	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Execution with Unnecessary Privileges vulnerability. An unauthenticated attacker with local access could potentially exploit this vulnerability, leading to Protection mechanism bypass. This vulnerability is considered critical because a low-privileged operator with SSH access to the SCG host c...
CVE-2026-81800	9.3	CRIT		0.002		Unauthenticated SQL Injection in Verified Reviews (Avis Vérifiés) <= 2.4.6 versions.
CVE-2026-87984	9.3	CRIT				An arbitrary file write vulnerability in Mistral Vibe, introduced in version 1.3.4, allows an attacker to create or overwrite files outside the active workspace without user approval. Shell redirection destinations are omitted from permission checks, enabling otherwise allowlisted commands to write to arbitrary paths accessible to the Vibe process.
CVE-2026-88899	9.3	CRIT		0.004		knowns versions before 0.31.0 fail to properly validate the x-opencode-directory request header in the /api/opencode proxy endpoint. Remote attackers can supply arbitrary directory paths to execute file operations outside the project root on the host system.
CVE-2026-89010	9.3	CRIT				WAVLINK WN535M1 and WN535M3 routers running firmware prior to M35M1_V250922 contain an unauthenticated OS command injection vulnerability that allows remote attackers to execute arbitrary commands as root by sending crafted filenames to the sync_server daemon on TCP port 13136. The daemon interpolates attacker-controlled filename input containing shell metacharacters into a shell command string via sprintf() and p...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89042	9.3	CRIT		0.003		passport-saml-encrypted through 0.1.13 makes SAML signature verification conditional on an optional cert option, allowing attackers to bypass authentication by submitting unsigned SAML responses. Attackers can post forged SAML responses with arbitrary NameID and attributes to the assertion consumer service endpoint to receive authenticated profiles without valid signatures.
CVE-2026-89249	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the YPTWallet plugin where user-supplied CryptoWallet values are base64-encoded but not HTML-escaped before storage in wallet_log.information. Administrators viewing pending withdrawal requests in pendingRequests.php execute the stored markup in their session, allowing attackers to perform adminis...
CVE-2026-89253	9.3	CRIT				WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the user 'donationLink' profile field. User::setDonationLink() (objects/user.php) stores the value and save() validates it only with filter_var(..., FILTER_VALIDATE_URL), which accepts strings such as http://evil.example/"onmouseover=alert(document.domain)//, while getDonationLink() applies o...
CVE-2026-89254	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the CustomizeUser plugin where the field_name parameter is stored raw without sanitization. Administrators can inject malicious scripts via the add.json.php endpoint that execute when viewing extra info pages or profile forms that render the typeToHTML function.
CVE-2026-89255	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to HTML-encode PGP public keys echoed into a textarea element. An authenticated attacker can inject malicious JavaScript by submitting a crafted public key, which executes in an administrator's session when viewing the user's profile tab.
CVE-2026-89256	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the Bookmark plugin where chapter names are not encoded before being concatenated into public watch-page HTML. A video owner can inject malicious scripts via the bookmark name parameter, and every visitor of that video executes the payload in the AVideo origin.
CVE-2026-89258	9.3	CRIT				Hugo is a static site generator. In versions after v0.123.0 and before v0.165.0, symlinks in parent directories were not dropped during direct resource lookups, allowing path confinement to be bypassed. An attacker who can place — or who convinces a site author to place — a symlink inside a mounted directory (for example, in a locally vendored theme under themes/) can cause functions that perform direct lookups, s...
CVE-2026-89259	9.3	CRIT				Hugo is a static site generator. From v0.161.0, Hugo executes Node tools under Node's permission model, but TailwindCSS — included in the default security.exec.allow list — requires a highly permissive configuration (--allow-addons, --allow-child-process, --allow-worker). As a result, the restrictions intended by the fix for GHSA-x597-9fr4-5857 could still be bypassed, allowing a Node tool invoked during a build t...
CVE-2026-13738	9.2	CRIT		0.005	commvault:commvault	CommServe contained an authorization bypass vulnerability affecting a limited set of command execution operations. Software customers upgrade to resolved maintenance release. Update all Commvault installations, including Commserve, Webserver, Command Center, Media Agents, Clients and HyperScale X.
CVE-2026-21095	9.2	CRIT		0.004	samsung:android	Heap-based buffer overflow in DNG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.
CVE-2026-21096	9.2	CRIT		0.004	samsung:android	Heap-based buffer overflow in JPEG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.
CVE-2026-3869	9.2	CRIT				CWE-303 : Incorrect Implementation of Authentication Algorithm vulnerability exists that could cause loss of confidentiality, integrity and availability of the PLC provided an application project with a lower application level is running on the PLC.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-47839	9.2	CRIT		0.003		A vulnerability allows users authenticating through a federated OIDC provider to obtain the uaa.admin scope despite operators restricting that provider through externalGroupsWhitelist configuration. The issue occurs specifically when an OIDC identity provider uses groupMappingMode: AS_SCOPES with a wildcard externalGroupsWhitelist entry.
CVE-2026-54047	9.2	CRIT				Laci Synchroni is a decentralized mod and appearance sync server and plugin for Dalamud. Versions of the backend prior to 1.2.3 have an improper authentication vulnerability in the application's OAuth2 login flow. The application relies on client-side state by trusting the `UID` field inside the `Authentications` object of a user's local `config.json` file. By manually editing this local file on their PC prior to ...
CVE-2026-70478	9.2	CRIT		0.004	flowiseai:flowise	Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, the POST /api/v1/oauth2-credential/refresh/:credentialId endpoint is included in WHITELIST_URLS and requires no authentication. The endpoint decrypts the stored credential, sends a refresh request to the configured OAuth provider with the client secret and refresh token, and returns the refreshed access_token i...
CVE-2026-87983	9.2	CRIT				An arbitrary file read vulnerability in Mistral Vibe, introduced in version 2.6.0, allows an attacker to bypass workspace restrictions using quoted absolute paths in allowlisted shell commands. Improper handling of quotation marks during path validation enables files outside the active workspace to be read without user approval.
CVE-2026-89212	9.2	CRIT				A flaw resulting in XML external entity (XXE) was found in Akana API Platform in which references were improperly restricted during XML-to-JSON processing. The issue affects Akana versions 2026.1, 2025.1.1, and all versions before 2024.1.6 (including older unsupported versions of Akana) and has been fixed as a security patch in the latest release of supported versions.
CVE-2026-89243	9.2	CRIT				WWBN AVideo through commit c3edcc274c389816d434acada07ee78eaf330c1 contains a stored cross-site scripting vulnerability in UserGroups::setGroup_name() that fails to sanitize group_name input. Administrators with canAdminUserGroups permission can inject malicious HTML and JavaScript that executes in the browser when other administrators access the user manager interface.
CVE-2026-90456	9.2	CRIT				An example environment-configuration file for a bundled inventory-management component ships with a fixed, publicly-known administrative password. A deployment that copies this example file into active configuration without running the setup routine that regenerates credentials will expose that component's administrative interface to anyone aware of the default value.
CVE-2026-18924	9.1	CRIT		0.006	haxx:curl	A flaw in libcurl's handling of HTTP/2 Server Push streams, when the parent handle is set to share connections with other handles, can lead to use-after-free in the cleanup process.
CVE-2026-19646	9.1	CRIT		0.005		IBM Common Licensing Agent 9.0, Agent 9.0.0.1, Agent 9.0.0.2, ART 9.0, ART 9.0.0.1, and ART 9.0.0.2 could allow a remote attacker to redirect users to an arbitrary domain due to improper validation of the HTTP Host header.
CVE-2026-33186	9.1	CRIT		0.016	grpc:grpc	gRPC-Go is the Go language implementation of gRPC. Versions prior to 1.79.3 have an authorization bypass resulting from improper input validation of the HTTP/2 `:path` pseudo-header. The gRPC-Go server was too lenient in its routing logic, accepting requests where the `:path` omitted the mandatory leading slash (e.g., `Service/Method` instead of `/Service/Method`). While the server successfully routed these reques...
CVE-2026-39830	9.1	CRIT		0.006	golang:crypto	A malicious SSH peer could send unsolicited global request responses to fill an internal buffer, blocking the connection's read loop. The blocked goroutine could not be released by calling Close(), resulting in a resource leak per connection. Unsolicited global responses are now discarded.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-39832	9.1	CRIT		0.006	golang:crypto	When adding a key to a remote agent constraint extensions such as restrict-destination-v00@openssh.com were not serialized in the request. Destination restrictions were silently stripped when forwarding keys, allowing unrestricted use of the key on the remote host. The client now serializes all constraint extensions. Additionally, the in-memory keyring returned by NewKeyring() now rejects keys with unsupported con...
CVE-2026-42264	9.1	CRIT		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. From version 1.0.0 to before version 1.15.2, fFive config properties (auth, baseURL, socketPath, beforeRedirect, and insecureHTTPParser) in the HTTP adapter are read via direct property access without hasOwnProperty guards, making them exploitable as prototype pollution gadgets. When Object.prototype is polluted by another dependency in the same pro...
CVE-2026-42508	9.1	CRIT		0.073	golang:crypto	Previously, a revoked 'SignatureKey' belonging to a CA was not correctly checked for revocation. Now, both the 'key' and 'key.SignatureKey' are checked for @revoked.
CVE-2026-42584	9.1	CRIT		0.008	netty:netty	Netty is an asynchronous, event-driven network application framework. Prior to 4.2.13.Final and 4.1.133.Final, HttpClientCodec pairs each inbound response with an outbound request by queue.poll() once per response, including for 1xx. If the client pipelines GET then HEAD and the server sends 103, then 200 with GET body, then 200 for HEAD, the queue pairs HEAD with the first 200. The HEAD rule then skips reading th...
CVE-2026-45764	9.1	CRIT		0.004		Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a protocol change while processing HTTP/2 traffic could lead to type confusion in Suricata. Crafted traffic may cause Suricata to crash, resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a fix. As a workaround, disable HTTP/2 parsing if it is not ...
CVE-2026-73309	9.1	CRIT		0.005	xenforo:xenforo	XenForo before 2.3.13 contains an authentication bypass vulnerability in the OAuth2 token endpoint that allows unauthenticated attackers to obtain valid token pairs by submitting empty values for client_secret and code_verifier parameters. Attackers can exploit PHP truthy evaluation logic, which treats empty strings as false and skips client secret validation and PKCE code verifier validation, to exchange a valid ...
CVE-2026-73311	9.1	CRIT		0.004	xenforo:xenforo	XenForo before 2.3.13 contains an OAuth2 authorization code reuse vulnerability that allows attackers to obtain unauthorized token pairs by submitting a previously used authorization code. Attackers can exploit the failure to invalidate or mark authorization codes as consumed after initial token issuance to receive an independent token pair for the same user and scopes, bypassing the single-use guarantee of the OA...
CVE-2026-73312	9.1	CRIT		0.004	xenforo:xenforo	XenForo before 2.3.13 contains a refresh token replay vulnerability that allows attackers to reuse a refresh token multiple times by exploiting the failure to mark tokens as consumed when the parent access token has expired. Attackers can repeatedly submit the same refresh token to generate additional independent token pairs, achieving persistent unauthorized access for the token's full lifetime.
CVE-2026-75803	9.1	CRIT		0.002	openssl:openssl	Issue summary: ChaCha20-Poly1305 and AES-OCB decryption with an empty ciphertext can report success without verifying the supplied authentication tag when the operation is finalized by calling the EVP_Cipher() function. Impact summary: Applications calling EVP_Cipher() on an empty ciphertext and expecting the call to check the AEAD tag may accept forged messages. CWE: CWE-354 (Improper Validation of Integrity Ch...
CVE-2026-76242	9.1	CRIT		0.003		stigmem-node 0.9.0a1 accepts federation peer key material during peer registration without a separate administrator out-of-band fingerprint approval step. On nodes that accept federation peer registration over a network where initial registration can be intercepted or misdirected, an attacker can register a malicious peer and gain access to or tamper with federation traffic. Fixed in 0.9.0a2, which introduces a pe...
CVE-2026-76244	9.1	CRIT		0.002		stigmem-node contains an insecure default configuration vulnerability that allows federation traffic to traverse networks without mTLS protection when non-loopback endpoints are enabled. Operators who explicitly disabled mTLS while binding federation to non-loopback addresses expose federation traffic to cleartext interception and man-in-the-middle attacks.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80424	9.1	CRIT		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to create arbitrary files due to path traversal during archive extraction.
CVE-2026-81468	9.1	CRIT		0.023		Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Command execution.
CVE-2026-84939	9.1	CRIT		0.005	apache:freemarker	Path traversal vulnerability in Apache FreeMarker template loading mechanism, if the attacker can specify an arbitrary malformed locale identifier to FreeMarker, and the localized lookup configuration setting is enabled (it's by default enabled). This issue affects Apache FreeMarker from 2.2.0 through 2.3.34. Users are recommended to upgrade to version 2.3.35. Disabling localized lookup in previous versions also...
CVE-2026-69854	9.0	CRIT		0.006		Improper authentication in Spring Cloud Azure allows an unauthorized attacker to elevate privileges over a network.

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-21441	8.9	HIGH		0.03	python:urllib3	urllib3 is an HTTP client library for Python. urllib3's streaming API is designed for the efficient handling of large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once. urllib3 can perform decoding or decompression based on the HTTP `Content-Encoding` header (e.g., `gzip`, `deflate`, `br`, or `zstd`). When using the streaming API, the library decompre...
CVE-2026-58592	8.9	HIGH		0.005		Ladybird before commit 2f9dc7e contains a dangling-reference memory-safety flaw in its WebAssembly ESM-integration module loader. When a JavaScript function is imported into a WebAssembly module via the ESM path, WebAssemblyModule.cpp passes a stack-local Wasm::FunctionType by reference to create_host_function, whose host callback captures and later reads that reference; once the ESM link-loop iteration ends the F...
CVE-2026-12894	8.8	HIGH		0.005		A flaw was found in the Qute template engine, which is used by Quarkus to generate dynamic content like HTML pages or emails. The issue exists in the component responsible for looking up data values (ReflectionValueResolver), which fails to properly block access to sensitive Java internal functions when processing certain data types like Enums. An attacker who can provide or influence the template text can exploit...
CVE-2026-19002	8.8	HIGH		0.003	mongodb:bi_connector_odbc_driver	A missing bounds check when parsing stored procedure parameter metadata in the MongoDB BI Connector ODBC Driver can result in an out-of-bounds write in the client application process. Triggering this issue requires control over the server the driver connects to, or the ability to respond in its place, in order to return malformed metadata. The resulting memory corruption may cause the client application to termina...
CVE-2026-19004	8.8	HIGH		0.004	mongodb:bi_connector_odbc_driver	An application using the MongoDB BI Connector ODBC Driver may experience a memory-safety issue when processing output parameters from a stored procedure. Triggering this issue requires connecting to an untrusted or impersonated database server that returns crafted metadata. This may result in process termination, disclosure of process memory, or, under certain conditions, arbitrary code execution.
CVE-2026-41870	8.8	HIGH		0.005	apache:nutch	Missing Authorization, Improper Control of Generation of Code ('Code Injection'), Improper Control of Dynamically-Managed Code Resources, Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.11 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Ser...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45447	8.8	HIGH		0.036	openssl:openssl	Issue summary: A specially crafted PKCS#7 or S/MIME signed message could trigger a use-after-free during PKCS#7 signature verification. Impact summary: A use-after-free may result in process crashes, heap corruption, or potentially remote code execution. When processing a PKCS#7 or S/MIME signed message, if the SignedData digestAlgorithms field is present as an empty ASN.1 SET, OpenSSL may incorrectly free a cal...
CVE-2026-57163	8.8	HIGH		0.003	teluu:pjsip	PJSIP is a free and open source multimedia communication library written in C. Prior to commit c4a151a, a stack buffer overflow exists in the GnuTLS TLS backend when parsing the Subject Alternative Name extension of a peer certificate (tls_cert_get_info() in ssl_sock_gtls.c). Only GnuTLS builds are affected (--with-gnutls); OpenSSL and Apple SecureTransport/Network.framework builds are not affected. While extracti...
CVE-2026-69291	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-70737	8.8	HIGH		0.004	oracle:enterprise_manager_for_syst ems_infrastructure	Vulnerability in the Oracle Enterprise Manager for Systems Infrastructure product of Oracle Enterprise Manager (component: Storage Server Management). Supported versions that are affected are 13.5 and 24.1. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Enterprise Manager for Systems Infrastructure. Successful attacks of this vulnerability can r...
CVE-2026-70922	8.8	HIGH		0.004	oracle:financial_services_enterprise _case_management	Vulnerability in the Oracle Financial Services Enterprise Case Management product of Oracle Financial Services Applications (component: Web UI). Supported versions that are affected are 8.0.8.2 and 8.1.2.11. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Financial Services Enterprise Case Management. Successful attacks of this vulnerability can ...
CVE-2026-71328	8.8	HIGH		0.006	microsoft:.net, microsoft:visual_studio_2022, microsoft:visual_studio_2026, microsoft:windows	Heap-based buffer overflow in Visual Studio allows an unauthorized attacker to execute code over a network.
CVE-2026-72984	8.8	HIGH		0.004	microsoft:edge_chromium	Access of resource using incompatible type ('type confusion') in Microsoft Edge (Chromium-based) allows an unauthorized attacker to execute code over a network.
CVE-2026-75624	8.8	HIGH		0.004		IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.27 could allow a remote authenticated attacker to bypass security restrictions due to incorrect authorization.
CVE-2026-75777	8.8	HIGH		0.001		IBM Aspera Enterprise WebApps 1.0.0 through 1.0.5 could allow a local attacker to escape container protections due to unrestricted system calls being permitted within the container.
CVE-2026-76059	8.8	HIGH		0.005		IBM Langflow OSS 1.0.0 through 1.11.5 An attacker who could submit custom component source code could bypass the static security scanner by crafting an annotated class-body assignment that resolved to a dangerous callable through alias tracking; the resolved value was never checked against the dangerous callable blacklist due to the logic error. If the crafted component reached the runtime execution path, the atta...
CVE-2026-77906	8.8	HIGH		0.008	microsoft:visual_studio_2026	Heap-based buffer overflow in Visual Studio allows an unauthorized attacker to execute code over a network.
CVE-2026-78462	8.8	HIGH		0.005	microsoft:visual_studio_code	Authorization bypass through user-controlled key in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-78569	8.8	HIGH		0.004		IBM Langflow OSS 1.0.0 through 1.11.5 could allow an authenticated attacker to execute arbitrary code due to an incomplete denylist in the security scanner.
CVE-2026-78571	8.8	HIGH		0.005		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to an unguarded eval() call on attacker-controlled input.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78575	8.8	HIGH		0.005		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary commands due to improper validation of command-line arguments in the MCP stdio server configuration.
CVE-2026-79742	8.8	HIGH		0.005		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to an incomplete environment variable blacklist.
CVE-2026-81211	8.8	HIGH		0.003		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary Python code due to improper authorization of custom components in stored flows.
CVE-2026-81550	8.8	HIGH		0.005		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-81551	8.8	HIGH		0.005		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to arbitrarily write to or delete files on shared storage due to a path traversal vulnerability.
CVE-2026-81554	8.8	HIGH		0.005		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an absolute-path traversal vulnerability.
CVE-2026-81940	8.8	HIGH		0.005		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special characters in flow display names.
CVE-2026-81941	8.8	HIGH		0.008		IBM Langflow OSS 1.0.0 through 1.11.5 allows an authenticated non-administrative user could execute arbitrary operating system commands on the server at the privilege level of the application process by constructing a flow with an MCP Tools component configured to use a local stdio subprocess transport. This bypasses both the LANGFLOW_CUSTOM_COMPONENT_ADMIN_ONLY and LANGFLOW_BLOCK_CODE_INTERPRETER_COMPONENTS serve...
CVE-2026-82092	8.8	HIGH		0.005		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an absolute-path traversal vulnerability.
CVE-2026-82095	8.8	HIGH		0.005		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-82097	8.8	HIGH		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to a Server-Side Request Forgery (SSRF) vulnerability.
CVE-2026-82098	8.8	HIGH		0.008		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-82099	8.8	HIGH		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-84645	8.8	HIGH		0.007	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, objects of types marked as storing their configuration in independent top-level configuration files in Jenkins (such as the global configuration and jobs) can appear as nested field values in user-submitted `config.xml` documents and subsequently handle HTTP requests via Stapler, resulting in remote code execution.
CVE-2026-84648	8.8	HIGH		0.003	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, the system log viewer does not escape log record metadata (source, level, and timestamp) resulting in a stored cross-site scripting (XSS) vulnerability exploitable by attackers in control of agent processes.
CVE-2026-84650	8.8	HIGH		0.003	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, transient fields cannot be excluded from deserialization, allowing attackers able to submit configuration updates to specify the values of transient fields that will be deserialized, the impact depending on how those fields are used.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84889	8.8	HIGH		0.005		IBM Langflow OSS 1.0.0 through 1.10.3 could allow a remote authenticated attacker to execute arbitrary code due to improper limitation of a pathname to a restricted directory.
CVE-2026-85677	8.8	HIGH		0.002		The Gutenverse News WordPress plugin before 3.3.3 does not restrict the extra HTML it adds to WordPress's allowed elements to the context it is meant for, applying the same relaxed list to every sanitisation context including untrusted comments, allowing unauthenticated users to store JavaScript that will execute in the browser of any administrator who reviews the comment queue, and of any visitor to the post onc...
CVE-2026-16174	8.7	HIGH		0.001		Netskope was notified about a potential gap in Netskope Endpoint DLP (EPDLP) running on Windows systems. Successful exploitation of the gap could potentially allow a privileged user to send a crafted message to the EPDLP process port to trigger an integer overflow, leading to memory corruption. Successful exploitation would require the EPDLP module to be enabled in the client configuration, and that Memory Integri...
CVE-2026-44494	8.7	HIGH		0.01	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. From 1.0.0 to before 1.16.0, the Axios library is vulnerable to a Prototype Pollution "Gadget" attack that allows any Object.prototype pollution in the application's dependency tree to be escalated into a full Man-in-the-Middle (MITM) attack — intercepting, reading, and modifying all HTTP traffic including authentication credentials. The HTTP adapte...
CVE-2026-72708	8.7	HIGH				SPIP before 4.4.18 contains an unauthenticated blind SQL injection vulnerability in the public sitemap endpoint where the MySQL escaper spip_mysql_cite() in ecrire/req/mysql.php returns values unescaped when the target column is a date type and the supplied value matches the pattern of a word character followed by an open parenthesis. Attackers can supply a crafted value such as a time-based payload through the an...
CVE-2026-81532	8.7	HIGH		0.003	mongodb:bi_connector_odbc_driver	A user able to submit SQL through an application using the MongoDB Connector for BI ODBC driver can supply a positioned-cursor statement whose cursor name exceeds the size of an internal fixed-length buffer. Because the name length is not bounded before the driver builds its diagnostic message, memory adjacent to that buffer is overwritten with user-supplied content. This can terminate the hosting application proc...
CVE-2026-86076	8.7	HIGH		0.003	n8n:n8n	n8n is an open source workflow automation platform. Prior to 1.123.76, 2.37.7, and 2.38.2, the expression compiler sanitizer resolved through dynamically scoped this and did not reject reserved class member names. A class field named __sanitize could rebind the sanitizer and reach the Function constructor, enabling backend code execution and editor-preview JavaScript execution. The affected AST hook is PrototypeSa...
CVE-2026-86169	8.7	HIGH		0.005		Axolotl before 0.19.0 contains a remote code execution vulnerability in the multipack patch path where trust_remote_code defaults to None instead of False, causing the security guard to be bypassed. Attackers can execute arbitrary Python code by crafting a malicious Hugging Face model repository selected as base_model, which is loaded with hardcoded trust_remote_code=True during AutoModelForCausalLM.from_pretrained.
CVE-2026-44492	8.6	HIGH		0.009	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 0.32.0 and 1.16.0, Axios does not normalise IPv4-mapped IPv6 addresses. When NO_PROXY lists an IPv4 address such as 127.0.0.1 or 169.254.169.254, a request URL using the IPv4-mapped IPv6 form (::ffff:7f00:1, ::ffff:a9fe:a9fe) still routes through the configured proxy. Node.js resolves these addresses to the underlying IPv4 host, so the requ...
CVE-2026-74239	8.6	HIGH		0.007	xenforo:xenforo	XenForo before 2.3.13 contains a path traversal vulnerability in the style archive importer on Windows deployments that allows authenticated non-super administrators with style permissions to write arbitrary files outside the intended extraction directory by using backslash-based traversal sequences in ZIP member names. Attackers can craft a malicious ZIP archive with backslash path separators that bypass forward-...
CVE-2026-76199	8.6	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Uncontrolled Search Path Element vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81213	8.6	HIGH		0.004		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to obtain sensitive information from internal network resources due to improper validation of user-supplied URLs.
CVE-2026-85979	8.6	HIGH				Affected versions of Puppet Enterprise contain a command injection vulnerability in the handling of the java_keystore_passwd parameter. An authenticated user with Puppet administrative privileges can inject arbitrary shell commands by providing a specially crafted value for this parameter, which is passed to a shell execution context without sufficient sanitization. Because the resulting commands are executed with...
CVE-2026-88058	8.6	HIGH		0.005		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular server-side rendering (SSR) in @angular/platform-server serializes ProcessingInstruction DOM nodes inside fallback raw-content elements without escaping matching ancestor closing tags. ProcessingInstruction data escaped greater-than chara...
CVE-2026-70341	8.5	HIGH				Use after free in Microsoft Edge (Chromium-based) allows an authorized attacker to execute code over a network.
CVE-2026-80378	8.5	HIGH		0.003		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to improper authorization.
CVE-2026-80436	8.5	HIGH		0.003		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service by deleting arbitrary RabbitMQ queues or exchanges due to improper authorization.
CVE-2026-81207	8.5	HIGH		0.002		IBM DataStage on Cloud Pak for Data 5.4.0.0 allows any authenticated tenant — with no project membership or role — fully controls scheme/host/port/path of an outbound fetch originating from a shared-infrastructure pod, and the WSDL body is reflected verbatim to the caller. The ds-canvas pod sits on the OpenShift overlay with reach to co-tenant services, in-cluster CP4D APIs, and link-local addresses. Scope is Chan...
CVE-2026-81540	8.5	HIGH		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to overwrite ruleset files belonging to other tenants due to a path traversal vulnerability.
CVE-2026-19003	8.4	HIGH		0.001	mongodb:bi_connector_odbc_driver	A data source definition containing an over-length file path setting may cause the MongoDB BI Connector ODBC Driver setup dialog to write outside the bounds of an allocated buffer. The issue stems from an incorrect buffer capacity calculation in the dialog's file and folder selection handling, and is reached only when a user opens the setup dialog for such a data source and initiates a file or folder selection. De...
CVE-2026-88890	8.4	HIGH		0.003		OpenPanel through commit cd24bb8 contains an SQL injection vulnerability in the analytics filter builder that fails to validate profile.* filter column identifiers before interpolating them into ClickHouse WHERE clauses. An authenticated attacker with project-scoped read or root export credentials can inject arbitrary ClickHouse SQL to bypass project isolation and read other organizations' analytics data and profi...
CVE-2026-44487	8.2	HIGH		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 0.32.0 and 1.16.0, Axios's Node.js HTTP adapter may forward a Proxy-Authorization header to a redirected origin during specific proxy-to-direct redirect flows. This affects Node.js usage, where an initial HTTP request is sent through an authenticated HTTP proxy, redirects are followed, and the redirected URL is no longer proxied. Under affe...
CVE-2026-70852	8.2	HIGH		0.002	oracle:demand_planning	Vulnerability in the Oracle Demand Planning product of Oracle Supply Chain (component: Internal Operations). Supported versions that are affected are 12.1 and 12.2. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Demand Planning. Successful attacks of this vulnerability can result in unauthorized access to critical data or complete access to al...
CVE-2026-81356	8.2	HIGH		0.003	microsoft:visual_studio_code	Inconsistent interpretation of http requests ('http request/response smuggling') in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81357	8.2	HIGH		0.003	microsoft:visual_studio_code	Server-side request forgery (ssrf) in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-81378	8.2	HIGH		0.003	microsoft:visual_studio_code	Interpretation conflict in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-81379	8.2	HIGH		0.003	microsoft:visual_studio_code	Not failing securely ('failing open') in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-89090	8.2	HIGH				An unrecovered panic in the event stream header decoder in Amazon AWS SDK for Go v2 before release-2026-03-23 might allow an unauthenticated remote actor to terminate the consuming application process via a crafted event stream response frame containing a header value type outside the valid range. To remediate this issue, users should upgrade to release-2026-03-23 or later, and patch any forked or derivative code.
CVE-2026-69438	8.1	HIGH		0.007		Incorrect conversion between numeric types in Microsoft JScript allows an unauthorized attacker to execute code over a network.
CVE-2026-78444	8.1	HIGH		0.005	microsoft:windows_10_1809, microsoft:windows_server_2019, microsoft:windows_server_2022, microsoft:windows_server_2025	Untrusted pointer dereference in Windows Failover Cluster allows an unauthorized attacker to execute code over a network.
CVE-2026-81268	8.1	HIGH		0.003		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute flows and obtain sensitive information due to insufficient session expiration of API keys after user deactivation.
CVE-2026-83997	8.1	HIGH		0.005	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Use after free in Windows Message Queuing allows an unauthorized attacker to execute code over a network.
CVE-2026-87958	8.1	HIGH		0.002		IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 is vulnerable to a denial of service where a specific functionality on a Db2 server can be disabled by a privileged user under certain conditions.
CVE-2026-69727	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69773	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69777	8.0	HIGH		0.005	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Heap-based buffer overflow in Windows DHCP Client allows an authorized attacker to elevate privileges over an adjacent network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2022-24958	7.8	HIGH		0.004	debian:debian_linux, fedoraproject:fedora, linux:linux_kernel, netapp:h300e, netapp:h300e_firmware, netapp:h300s, netapp	drivers/usb/gadget/legacy/inode.c in the Linux kernel through 5.16.8 mishandles dev->buf release.
CVE-2023-3609	7.8	HIGH		0.005	debian:debian_linux, linux:linux_kernel	A use-after-free vulnerability in the Linux kernel's net/sched: cls_u32 component can be exploited to achieve local privilege escalation. If tcf_change_indev() fails, u32_set_parms() will immediately return an error after incrementing or decrementing the reference counter in tcf_bind_filter(). If an attacker can control the reference counter and set it to zero, they can cause the reference to be freed, leading ...
CVE-2026-2310	7.8	HIGH		0.003		IBM webMethods Integration Server 11.1 IBM webMethods Integration is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.
CVE-2026-69270	7.8	HIGH		0.002		Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69352	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69391	7.8	HIGH		0.003		Stack-based buffer overflow in Windows Broker Infrastructure Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69426	7.8	HIGH		0.003		Heap-based buffer overflow in Windows VOLSnap.SYS allows an authorized attacker to execute code locally.
CVE-2026-69456	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Speech allows an authorized attacker to elevate privileges locally.
CVE-2026-69476	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69489	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69583	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69589	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69593	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69594	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges locally.
CVE-2026-69787	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70334	7.8	HIGH		0.004	microsoft:visual_studio_code	Incomplete list of disallowed inputs in Visual Studio Code allows an unauthorized attacker to bypass a security feature locally.
CVE-2026-70572	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70581	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72941	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72988	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72991	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72992	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72993	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72994	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72996	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72997	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73000	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73002	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73007	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73015	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73020	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-75771	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75862	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75863	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-77489	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Null pointer dereference in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77904	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-78448	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80075	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:wi	Heap-based buffer overflow in Windows Work Folders allows an authorized attacker to elevate privileges locally.
CVE-2026-82005	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-82006	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by a Heap-based Buffer Overflow vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-82007	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-83954	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83967	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83970	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83971	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83972	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83973	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83977	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83978	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83980	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83981	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83982	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83983	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83985	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83987	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83988	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83990	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to elevate privileges locally.
CVE-2026-84000	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to execute code locally.
CVE-2026-44495	7.7	HIGH		0.008	axios:axios, redhat:advanced_cluste r_management_for_kubernetes, redhat:advanced_cluster_security, redhat:ansible_automat	Axios is a promise based HTTP client for the browser and Node.js. From 0.19.0 to before 0.31.1 and 1.15.2, Axios contains prototype-pollution gadgets in request config processing. If another vulnerability in the same JavaScript process has already polluted Object.prototype.transformResponse, affected Axios versions may treat that inherited value as request configuration or as an option validator. Axios does not it...
CVE-2026-81210	7.7	HIGH		0.002		IBM DataStage on Cloud Pak for Data 5.4.0.0 concatenates three caller-supplied strings into a String.format path on the shared /ds-storage RWX PVC and returns the file with no project ACL — pure IDOR plus traversal. Read is constrained to files named job.log/error.log, but DataStage job logs routinely carry connection strings, {dsnextenc} ciphertxts (decryptable via d2-f023), and customer-data row samples. This i...
CVE-2026-89099	7.7	HIGH				A race condition in the document value layer of MongoDB Server can allow concurrent server threads to operate on the same internal memory without synchronization, leading to memory corruption. An authenticated user holding ordinary read-write privileges on a database may be able to trigger this condition over the normal client protocol, resulting in server termination and potential corruption of process memory wit...
CVE-2022-1199	7.5	HIGH		0.02	linux:linux_kernel, netapp:active_iq_unified_manager, netapp:h300s, netapp:h300s_firmware, netapp:h410c, netapp:h410c_fi	A flaw was found in the Linux kernel. This flaw allows an attacker to crash the Linux kernel by simulating amateur radio from the user space, resulting in a null-ptr-deref vulnerability and a use-after-free vulnerability.
CVE-2026-14457	7.5	HIGH		0.01	openssl:openssl	Issue summary: In a server or client configuration with RFC7250 Raw Public Keys (RPKs) enabled, and only the private key (with no associated certificate) configured locally, a NULL pointer dereference may occur when the remote peer solicits raw public keys and also sends the typically omitted "signature_algorithms_cert" TLS extension. Impact summary: The impact is limited to a possible Denial of Service as a resu...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-42198	7.5	HIGH		0.033	postgresql:postgresql_jdbc_driver	pgjdbc is an open source postgresql JDBC Driver. From version 42.2.0 to before version 42.7.11, pgjdbc is vulnerable to a client-side denial of service during SCRAM-SHA-256 authentication. A malicious server can instruct the driver to perform SCRAM authentication with a very large iteration count. With a large enough value, the client spends an unbounded amount of CPU time inside PBKDF2 before authentication can f...
CVE-2026-44486	7.5	HIGH		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 0.32.0 and 1.16.0, Axios' Node.js HTTP adapter can leak proxy credentials to a redirect target in affected versions. When a request is sent through an authenticated proxy, Axios may add a Proxy-Authorization header. If Axios then follows a redirect and the redirected request is no longer sent through that proxy, the stale Proxy-Authorizatio...
CVE-2026-44488	7.5	HIGH		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Axios versions 1.7.0 through 1.15.x did not enforce configured request and response size limits when requests were sent with the fetch adapter. Applications that selected adapter: 'fetch', or ran in environments where axios resolved to the fetch adapter, could receive or send bodies larger than maxContentLength or maxBodyLength despite those limits ...
CVE-2026-44496	7.5	HIGH		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Axios versions before 0.32.0 on the 0.x line and before 1.16.0 on the 1.x line build a regular expression from the configured XSRF cookie name without escaping regex metacharacters. In standard browser environments, an attacker who can influence the cookie name passed to axios can cause expensive regex backtracking while axios reads document.cookie....
CVE-2026-45736	7.5	HIGH		0.007	ws_project:ws	ws is an open source WebSocket client and server for Node.js. Prior to 8.20.1, the websocket.close() implementation is vulnerable to uninitialized memory disclosure when a TypedArray is passed as the reason argument. This vulnerability is fixed in 8.20.1.
CVE-2026-48779	7.5	HIGH		0.008	ws_project:ws	ws is an open source WebSocket client and server for Node.js. All versions from 1.1.0 up to (but not including) 5.2.5, from 6.0.0 up to 6.2.4, from 7.0.0 up to 7.5.11, and from 8.0.0 up to 8.21.0 are affected by a memory exhaustion DoS vulnerability. A peer can send a high volume of exceptionally small fragments and data chunks, with modest network traffic, to force the remote peer into allocating and holding stru...
CVE-2026-50010	7.5	HIGH		0.005	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, SimpleTrustManagerFactory.engineGetTrustManagers() and related paths wrap any user-supplied plain X509TrustManager in X509TrustManagerWrapper, which extends X509ExtendedTrustManager but implements the 3-arg checkServerTrusted(chain, authType, SSLEngine) by discarding the SSLEn...
CVE-2026-54874	7.5	HIGH		0.005	openssl:openssl	Issue summary: Receiving a DTLS record for a future epoch while a handshake is in progress causes OpenSSL to buffer far more memory than the record itself requires. Impact summary: A peer can use a small amount of network traffic to make an OpenSSL DTLS endpoint retain a disproportionately large amount of memory, which may lead to a Denial of Service. CWE: CWE-405: Asymmetric Resource Consumption (Amplification)...
CVE-2026-63072	7.5	HIGH		0.006	openssl:openssl	Issue summary: OpenSSL CMS decryption sizes the key-unwrap output buffer based on querying the unwrapped key size, but the AES-WRAP-PAD unwrap primitive can write and cleanse more bytes than that query reports, causing an 8-byte out-of-bounds heap write. Impact summary: An attacker who supplies a crafted CMS message can trigger a deterministic 8-byte out-of-bounds heap write when the victim decrypts it with CMS_d...
CVE-2026-63075	7.5	HIGH		0.005	openssl:openssl	Issue summary: When OpenSSL processes QUIC traffic from a peer that repeatedly sends ack-eliciting packets while not acknowledging ACK-only responses, the QUIC stack can retain ACK-only packet metadata for the lifetime of the connection. Impact summary: A remote peer that can complete a QUIC handshake can cause connection-scoped memory growth which may lead to Denial of Service through memory exhaustion, especial...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-63076	7.5	HIGH		0.013	openssl:openssl	Issue summary: OpenSSL CMP password based protection verification only checks whether the protectionAlg parameter was not NULL and not its ASN.1 type, before treating it as a PBMPParameter. A crafted message can contain a parameter of a different type, which is then dereferenced as an invalid pointer. Impact summary: A remote, unauthenticated attacker can crash an application acting as a CMP server that accepts PB...
CVE-2026-68497	7.5	HIGH				jackson-databind binds a JSON string to a javax.xml.datatype.Duration or javax.xml.datatype.XMLGregorianCalendar field by passing the raw string verbatim to DatatypeFactory.newDuration(value) or newXMLGregorianCalendar(value) in CoreXMLDeserializers.Std._deserialize. These deserializers are registered by default with no opt-in, so a plain ObjectMapper or JsonMapper with no polymorphic typing and no special configu...
CVE-2026-70910	7.5	HIGH		0.004	oracle:siebel_crm	Vulnerability in the Siebel CRM Integration product of Oracle Siebel CRM (component: REST). Supported versions that are affected are 17.0-26.6. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Siebel CRM Integration. Successful attacks of this vulnerability can result in unauthorized access to critical data or complete access to all Siebel CRM Integrati...
CVE-2026-73017	7.5	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows Graphics Kernel allows an authorized attacker to execute code locally.
CVE-2026-80229	7.5	HIGH		0.006	haxx:curl	When performing transfers via libcurl's multi interface, pooled TLS connections can outlive their originating easy handles. In OpenSSL 3 provider configurations, libcurl attaches an allocated library context to the easy handle's state and passes it to OpenSSL without acquiring an ownership reference; destroying the easy handle prematurely frees this context while the active connection retains a dangling pointer, l...
CVE-2026-81265	7.5	HIGH		0.002		IBM Langflow OSS 1.0.0 through 1.11.5.
CVE-2026-86093	7.5	HIGH		0.005		IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an attacker with the ability to control or impersonate a DRDA server endpoint to execute arbitrary commands on Db2 clients due to a stack-based buffer overflow that improperly copies user-controlled data into a fixed-size stack buffer without bounds checking.
CVE-2026-87776	7.5	HIGH				compression is a Node.js and Express compression middleware. In versions before 1.8.2, when a client aborts the connection while a compressed response is still being sent, the zlib stream created to compress that response is never destroyed, so each aborted compressed response leaks its native zlib memory. A remote unauthenticated attacker can repeatedly open requests and disconnect early, exhausting the available...
CVE-2026-87908	7.5	HIGH		0.003		multipart is a Node.js library for parsing multipart/form-data request bodies. In versions from 2.1.0 up to but not including 4.3.1, the parser does not bound the amount of memory used while accumulating the headers of a single multipart part. An unauthenticated attacker can send a single request whose part carries a very large volume of header bytes, forcing the parser to buffer all of them and exhausting the pr...
CVE-2026-78461	7.4	HIGH		0.011	microsoft:visual_studio_code	Improper limitation of a pathname to a restricted directory ('path traversal') in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-80434	7.4	HIGH		0.002		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to manipulate runtime caches and cause a denial of service due to an insecure direct object reference.
CVE-2026-84003	7.4	HIGH		0.004		Authentication bypass by capture-replay in Microsoft Authentication Library (MSAL) for Node.js allows an unauthorized attacker to perform spoofing over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84652	7.3	HIGH		0.004	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, Jenkins does not rotate the session when a user is authenticated via the "remember me" cookie, allowing attackers able to serve content on the same site as Jenkins to set a known session cookie in the victim's browser, which after the victim authenticates via the "remember me" cookie, grants the attacker access to Jenkins as that user.
CVE-2026-66256	7.2	HIGH		0.005	apache:shindig	** UNSUPPORTED WHEN ASSIGNED ** Deserialization of Untrusted Data vulnerability in Apache Shindig. This issue affects Apache Shindig: all versions. Users with access to the Shindig REST API can send specially-crafted requests to trigger arbitrary code execution on the server. As this project is retired, we do not plan to release a version that fixes this issue. Users are recommended to find an alternative or re...
CVE-2026-18888	7.1	HIGH		0.003	mongodb:bi_connector_odbc_driver	The MongoDB BI Connector ODBC Driver converts floating point column values into text without checking that the result fits within the destination buffer. When an application reads a sufficiently large floating point value as text, the driver may write beyond the end of that buffer and corrupt adjacent memory. A user who can store data in a collection read through the BI Connector could use this to crash the applic...
CVE-2026-20293	7.1	HIGH		0.001		A vulnerability in the Unified Extensible Firmware Interface (UEFI) Shell implementation of Cisco UCS Servers and UCS-based appliances could allow an authenticated attacker with valid credentials for a user account with the role of user or admin or an unauthenticated attacker with physical access to an affected device to bypass UEFI Secure Boot validation checks and execute unauthorized software. This vuln...
CVE-2026-68846	7.1	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges over a network.
CVE-2026-68889	7.1	HIGH		0.004		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69296	7.1	HIGH		0.005		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69313	7.1	HIGH		0.005		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69396	7.1	HIGH		0.005		Use after free in Windows NDIS allows an authorized attacker to elevate privileges over a network.
CVE-2026-80380	7.1	HIGH		0.001		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote attacker to perform unauthorized actions due to cross-site request forgery.
CVE-2026-89012	7.1	HIGH				Dolibarr 24.0.0 before 24.0.1 contains a case-sensitive denylist bypass vulnerability in the sqlfilters API query parameter that allows authenticated attackers to recover protected database fields by supplying uppercase variants of denylist-protected field names. Attackers can exploit the case-insensitive database column resolution against the case-sensitive denylist check in the core library to use prefix-matchin...
CVE-2023-4622	7.0	HIGH		0.006	debian:debian_linux, linux:linux_kernel	A use-after-free vulnerability in the Linux kernel's af_unix component can be exploited to achieve local privilege escalation. The unix_stream_sendpage() function tries to add data to the last skb in the peer's recv queue without locking the queue. Thus there is a race where unix_stream_sendpage() could access an skb locklessly that is being released by garbage collection, resulting in use-after-free. We recomme...
CVE-2026-69472	7.0	HIGH		0.003		Use after free in Windows Devices Human Interface allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69573	7.0	HIGH		0.003		Use after free in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69605	7.0	HIGH		0.003		Use after free in Microsoft Install Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69859	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-70573	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70577	7.0	HIGH		0.003		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-73022	7.0	HIGH		0.002		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-77905	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Management Instrumentation allows an authorized attacker to elevate privileges locally.
CVE-2026-78457	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2022, microsof	Use after free in Windows Security Health Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83999	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Improper link resolution before file access ('link following') in Windows Resilient File System (ReFS) Deduplication Service allows an authorized attacker to elevate privileges locally.
CVE-2026-50025	6.9	MEDI				Mousehole is a background service to update a seedbox IP for MAM and web app to manage it. Prior to version 0.4.05, Mousehole's HTTP/WebSocket management boundary is reachable without application-layer authentication or browser/LAN provenance checks. The service stores a MyAnonamouse (MAM) session cookie in state and reuses the same cookie-bearing serialization for persisted state, public API responses, and WebSoc...
CVE-2026-89261	6.9	MEDI				MoguBlog through 6.2 exposes Elasticsearch index management endpoints in the mogu_search service without authentication, allowing remote attackers to delete, recreate, or alter the blog search index. Attackers can invoke POST endpoints to wipe the entire search index, delete specific documents, or inject malicious index entries, causing search functionality to return incorrect or no results.
CVE-2026-89263	6.9	MEDI				MoguBlog through 6.2 fails to authenticate requests to the /web/comment/closeEmailNotification endpoint, allowing unauthenticated attackers to disable email notifications for arbitrary users. Remote callers can modify the startEmailNotification flag in Redis cache for any user identifier to suppress reply notifications without authorization.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-15710	6.8	MEDI				An information leakage vulnerability exists in the Endpoint DLP component (epdlpdrv.sys) of Netskope Client for Windows prior to version R141. An internal communication channel used by the user-space hook DLL to pass messages through the kernel driver to the daemon lacked proper token-based message validation, allowing local unprivileged processes to send unauthorized queries. Additionally, a reply buffer used by ...
CVE-2026-69415	6.8	MEDI		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing authentication for critical function in Windows DHCP Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-69490	6.8	MEDI		0.004		Out-of-bounds read in Windows USB Mass Storage Class Driver allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-71348	6.8	MEDI		0.004		Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-78451	6.8	MEDI		0.004	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Untrusted pointer dereference in Microsoft Windows SCSI Class System File allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-83545	6.8	MEDI		0.002		The CoolClock WordPress plugin before 4.3.8 does not properly escape a custom skin setting before outputting it inside an inline script, allowing users with contributor-level access and above to inject arbitrary JavaScript that executes when the content is viewed.
CVE-2026-85678	6.8	MEDI		0.002		The AI Builder WordPress plugin before 2.7.8 does not sanitise custom JavaScript saved against a post before echoing it inside a script tag on the front end, allowing users with contributor level access and above to store arbitrary JavaScript that will execute in the browser of anyone who views the post, including the editor or administrator who reviews it.
CVE-2026-9176	6.7	MEDI		0.001		IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a security bypass due to improper authentication controls. A local attacker could exploit this vulnerability to escalate privileges and gain unauthorized access to protected resources.
CVE-2026-15439	6.5	MEDI				The GamiPress plugin for WordPress is vulnerable to authenticated (Subscriber+) SQL Injection via the 'q' parameter of the wpForo integration AJAX selector (action gamipress_wpforo_get_posts) in versions up to, and including, 7.9.7. The value is passed only through \$wpdb->esc_like() and interpolated directly into a single-quoted LIKE clause with no %s placeholder. Because esc_like() runs after WordPress core magic...
CVE-2026-54248	6.5	MEDI				Doco-CD is a GitOps continuous delivery tool that automatically deploys and updates Docker Compose projects/services and Swarm stacks. Prior to version 0.90.1, a trust-boundary flaw in OCI artifact verification allowed artifact-provided deployment config to influence the policy used to verify that same artifact. When global OCI signature verification was enabled via `OCI_TRUST_POLICY` ('enabled: true'), an attacke...
CVE-2026-66324	6.5	MEDI		0.007	microsoft:edge_chromium	External control of file name or path in Microsoft Edge (Chromium-based) allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-69375	6.5	MEDI		0.006		Authorization bypass through user-controlled key in Microsoft Exchange Server allows an authorized attacker to perform tampering over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78453	6.5	MEDI		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer underflow (wrap or wraparound) in Microsoft Windows SCSI Class System File allows an unauthorized attacker to disclose information over a network.
CVE-2026-79725	6.5	MEDI		0.003		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to read arbitrary files due to improper access control.
CVE-2026-81377	6.5	MEDI		0.008	microsoft:visual_studio_code	Improper limitation of a pathname to a restricted directory ('path traversal') in Visual Studio Code allows an unauthorized attacker to perform tampering over a network.
CVE-2026-9225	6.5	MEDI		0.002		IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an authenticated attacker to access sensitive files belonging to other users due to improper access control in the File/Read File component. When executing flows through the /api/v1/run/advanced/{flow_id} endpoint, the application allows component inputs to reference storage paths using arbitrary user or flow identifiers without verifying ownership. An att...
CVE-2023-4611	6.3	MEDI		0.003	linux:linux_kernel	A use-after-free flaw was found in mm/mempolicy.c in the memory management subsystem in the Linux Kernel. This issue is caused by a race between mbind() and VMA-locked page fault, and may allow a local attacker to crash the system or lead to a kernel information leak.
CVE-2026-5588	6.3	MEDI		0.006		Use of a Broken or Risky Cryptographic Algorithm vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcpkix on all (pkix modules), Legion of the Bouncy Castle Inc. BCPKIX-FIPS bcpkix on All (pkix modules), Legion of the Bouncy Castle Inc. BCPIX-LTS bcpkix on All (pkix modules). This vulnerability is associated with program files JcaContentVerifierProviderBuilder.Java, JcaContentVerfierProviderBuilder.Java....
CVE-2026-81824	6.3	MEDI		0.002		The vulnerability, if exploited, could allow a miscreant to run arbitrary JavaScript code in a browser session of a PIMBoards user who was socially engineered to click on a malicious link.
CVE-2026-84651	6.3	MEDI		0.002	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, the REST API and CLI endpoints for updating agent configuration do not prevent a submitted configuration from overwriting a different agent by specifying that agent's name in the submitted XML document, allowing attackers with Agent/Configure permission on one agent to take over a different agent, gaining control of its configuration and obtaining access to it...
CVE-2026-86079	6.3	MEDI		0.003	n8n:n8n	n8n is an open source workflow automation platform. Prior to 1.123.76, 2.37.7, and 2.38.2, the Elasticsearch and ElasticSecurity nodes interpolated workflow-controlled index and document identifiers directly into REST request paths. An identifier containing path separators or dot segments could select another index or a cluster administration endpoint under the stored Elasticsearch credential. The affected request...
CVE-2026-9327	6.3	MEDI		0.002		IBM WebSphere Application Server 9.0, and 8.5 could allow an authenticated user with a low-privilege administrative role to modify security configuration. This could result in information disclosure or denial of service.
CVE-2026-18562	6.1	MEDI		0.002		The HUSKY – Products Filter Professional for WooCommerce plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via SEO-friendly permalink filter URL segments in versions up to, and including, 1.4.3. This is due to insufficient input sanitization and output escaping in the wp_load_js() function, which reads filter values from the URL path via the url_request extension's parse_url_query() and embeds t...
CVE-2026-69234	6.1	MEDI		0.002	esri:portal_for_arccgis	There is a reflected cross site scripting vulnerability in Esri Portal for ArcGIS versions 11.5 and prior which may allow a remote, unauthenticated attacker to create a crafted link which when clicked could potentially execute arbitrary JavaScript code in the victim's browser. Users working with ArcGIS Enterprise 11.1, 11.3, and 11.5 are encouraged to patch. All users are advised to upgrade to the latest long-term...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69236	6.1	MEDI		0.002	esri:portal_for_arcgis	There is a stored cross site scripting issue in Esri Portal for ArcGIS versions 12.1 and prior that may allow a remote, privileged attacker to inject malicious code that could potentially execute arbitrary JavaScript in a victim's browser. Users working with ArcGIS Enterprise 11.1, 11.3, 11.5, 12.0 or 12.1 are encouraged to patch. All users are advised to upgrade to the latest long-term support release and apply t...
CVE-2026-77490	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Edge (Chromium-based) allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-18061	6.0	MEDI				Improper restriction of XML external entity references in the RemoteQueryCachePlugin in AWS Advanced JDBC Wrapper 3.3.0 through 4.2.0 might allow an actor with write access to the shared cache infrastructure to disclose sensitive files from application hosts that read cached query results, including stored database and IAM role credentials, via crafted XML data in a cached column value. To remediate this issue,...
CVE-2026-81533	6.0	MEDI		0.002	mongodb:bi_connector_odbc_driver	An application using the MongoDB BI Connector ODBC Driver may encounter a memory-safety issue when a submitted SQL statement contains an unusually long run of digits following a LIMIT clause. The issue occurs only on connections where the driver's optional prefetch setting is enabled, and stems from the driver copying the digit sequence into a fixed-size internal buffer without checking its length. A user able to ...
CVE-2026-63074	5.9	MEDI		0.005	openssl:openssl	Issue summary: The OpenSSL Certificate Management Protocol (CMP) caches additional certificates (extraCerts) sent in a CMP message, but never expunges them (for instance if they are invalid). If a server reuses an OSSL_CMP_CTX frequently, this cache of extraCerts may grow unboundedly, and a malicious client may flood a CMP server with requests driving this growth. Impact summary: Users utilizing a CMP server tha...
CVE-2026-78123	5.9	MEDI		0.004		strongSwan 5.0.2 through 6.0.7 has an Expired Pointer Dereference in PKCS#7 parsing in the openssl plugin.
CVE-2026-87123	5.9	MEDI		0.004		hbs is an Express view engine wrapper for Handlebars. Version 4.3.0 can crash the Node.js process during output escaping when an async helper, registered with registerAsyncHelper, resolves to an object whose toHTML property is truthy but not callable. Handlebars escapeExpression calls the toHTML method on any value that has a truthy toHTML, so such a value throws a TypeError, and because the async substitution run...
CVE-2026-81911	5.8	MEDI				Concrete CMS versions 9.0.0 to 9.5.2 is vulnerable to Stored XSS in Board Custom Slot dialog. The custom_slot save_template endpoint authorizes the request only against the target board instance (canEditBoardContents()) and then persists the client-supplied selectedTemplateOption[collection] verbatim, rather than rebuilding the content object collection server-side and verifying that each item belongs to the autho...
CVE-2026-0636	5.5	MEDI		0.005		Improper neutralization of special elements used in an LDAP query ('LDAP injection') vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcprov on all (prov modules). This vulnerability is associated with program files LDAPStoreHelper. This issue affects BC-JAVA: from 1.74 before 1.80.2, from 1.81 before 1.81.1, from 1.82 before 1.84.
CVE-2026-69231	5.5	MEDI		0.002	esri:portal_for_arcgis	There is a stored cross site scripting issue in Esri Portal for ArcGIS versions 11.5 and prior that may allow a remote, privileged attacker to inject malicious code that could potentially execute arbitrary JavaScript in a victim's browser. Users working with ArcGIS Enterprise 11.1, 11.3, 11.5 are encouraged to patch. All users are advised to upgrade to the latest long-term support release.
CVE-2026-69232	5.5	MEDI		0.002	esri:portal_for_arcgis	There is a stored cross site scripting issue in Esri Portal for ArcGIS versions 11.5 and prior that may allow a remote, privileged attacker to inject malicious code that could potentially execute arbitrary JavaScript in a victim's browser. Users working with ArcGIS Enterprise 11.1, 11.3, 11.5 are encouraged to patch. All users are advised to upgrade to the latest long-term support release.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78454	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows CD-ROM Driver allows an authorized attacker to disclose information locally.
CVE-2026-81977	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Integer Underflow (Wrap or Wraparound) vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81982	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-82001	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Uncontrolled Resource Consumption vulnerability that could lead to application denial-of-service. An attacker could exploit this vulnerability to exhaust system resources, resulting in an application denial-of-service condition. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-86224	5.5	MEDI		0.003		A vulnerability was determined in SourceCodester Class and Exam Timetabling System 1.0. Affected is the function mysqli_query of the file /admin/modal_add_product.php. Executing a manipulation of the argument fname can lead to sql injection. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-86262	5.5	MEDI		0.004		A security vulnerability has been detected in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. This affects the function updateOrderSta1/updateOrderdiseaseInfo of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Handler. The manipulation of the argument userID/id leads to authorization bypass. The attack is possible to be carried out remotely. The exploi...
CVE-2026-86273	5.5	MEDI		0.003		A weakness has been identified in projeto-siga siga up to 11.1.1. Affected by this issue is the function DownloadExterno.getUrl of the file sigaex/src/main/java/br/gov/jfrj/siga/vraptor/ExUtilController.java of the component HTML-to-PDF Endpoint. This manipulation of the argument html causes server-side request forgery. The attack may be initiated remotely. The exploit has been made available to the public and cou...
CVE-2026-86672	5.5	MEDI		0.003		A vulnerability has been found in ningzichun Student Management System up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected is an unknown function of the file example.7z of the component Backup Handler. The manipulation leads to information disclosure. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used. Continious delivery with rolling releases is used by this pr...
CVE-2025-64542	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2025-64584	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-64588	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64589	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64610	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64618	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64830	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64838	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64854	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64866	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64868	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-14565	5.4	MEDI		0.002		The advanced-customized-prompts WordPress plugin through 1.0.1 does not perform any capability, ownership, or nonce check before saving popup configuration to a product, nor escape the stored values on output, allowing any authenticated user such as a subscriber to store JavaScript that executes in the browser of visitors viewing the affected product.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19479	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19612	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19644	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19713	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-27227	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-36392	5.4	MEDI		0.003		FairSketch Rise CRM Version 3.9.6 is vulnerable to Cross Site Scripting (XSS). An authenticated administrator can inject arbitrary JavaScript into an item's title, which is stored server-side and executed in the browser of any client user who visits the store page, enabling session hijacking, account takeover, and phishing.
CVE-2026-62904	5.4	MEDI		0.003	microsoft:edge_chromium	Incorrect authorization in Microsoft Edge (Chromium-based) allows an unauthorized attacker to disclose information over a network.
CVE-2026-66323	5.4	MEDI		0.003	microsoft:edge_chromium	Improper neutralization of parameter/argument delimiters in Microsoft Edge (Chromium-based) allows an unauthorized attacker to execute code over a network.
CVE-2026-71356	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71357	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71388	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71440	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-71565	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-72626	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-72627	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75629	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75635	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75636	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75637	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75639	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75640	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75642	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75643	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75644	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75646	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75647	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75651	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75652	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75657	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75659	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75660	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75661	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75666	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75667	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75668	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75670	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75674	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75677	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75683	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75692	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75700	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75706	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75709	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75711	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75716	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75722	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75729	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75733	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75735	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75738	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75740	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-42338	5.3	MEDI		0.005	beaugunderson:ip-address	ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.1.1, Address6.group() and Address6.link() do not HTML-escape attacker-controlled content before embedding it in the HTML strings they return, and AddressError.parseMessage (emitted by the Address6 constructor for invalid input) can contain unescaped attacker-controlled content in one branch. An application that ...
CVE-2026-78446	5.3	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Distributed File System (DFS) allows an authorized attacker to deny service over a network.
CVE-2026-87859	5.3	MEDI		0.003		morgan is an HTTP request logger middleware for Node.js. In versions before 1.12.1, its escapeLogField() function does not escape the double quote character, which delimits the quoted fields of the Apache combined log format that morgan emits. An unauthenticated remote attacker who controls a value written to a quoted field, such as the User-Agent or Referer header, can include a double quote to close that field e...
CVE-2026-88057	5.3	MEDI		0.004		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.28, 21.2.20, and 22.1.0, Angular's compiler and runtime in @angular/core and @angular/compiler could omit or select an incorrect sanitizer for security-sensitive directive host bindings because SecurityContext was derived from the declaring directive or component selecto...
CVE-2026-89239	5.3	MEDI				WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a reflected cross-site scripting vulnerability in the showAlertMessage() function that inserts the raw Referer header into a JavaScript comment without encoding. Attackers can craft a Referer header containing */ to close the comment and inject arbitrary JavaScript that executes in the site origin for visitors arriving from the attacker-c...
CVE-2026-89240	5.3	MEDI				WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a reflected cross-site scripting vulnerability in plugin/Live/confirmLivePassword.php. The script interpolates the unauthenticated GET parameter u (which is not covered by \$securityFilter) directly into an attribute without URL- or HTML-encoding. A remote attacker can craft a link containing a double-quote character in u (...)
CVE-2026-73319	5.1	MEDI		0.003	xenforo:xenforo	XenForo before 2.3.13 contains a cross-site scripting vulnerability in the dynamic redirect handler that allows unauthenticated attackers to execute arbitrary JavaScript in the board origin by crafting a malicious javascript: URI that bypasses host validation. Attackers can embed the board hostname in the URI authority component and use percent-encoded newlines to evade server-side filters, causing authenticated u...
CVE-2026-89268	5.1	MEDI				QloApps through 1.7.0 renders back-office list filter POST parameters into HTML input value attributes without escaping them in the list helper template. Attackers can induce authenticated users to submit crafted POST requests with malicious payloads to list controllers, executing arbitrary JavaScript in the victim's session to read administrative data and perform actions.
CVE-2026-79723	5.0	MEDI		0.002		IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to obtain sensitive information due to improper validation of user-controlled API endpoints.
CVE-2026-78546	4.8	MEDI				Out-of-bounds read vulnerability in Citrix Workspace app for Windows. This issue affects Workspace app for Windows: before 2603.11 Current Release (CR), before 2507.1 LTSR CU3, and before LTSR 2607.
CVE-2026-49836	4.6	MEDI		0.002		psd-tools is a Python package for working with Adobe Photoshop PSD files. Prior to version 1.17.1, `SmartObject.save()` writes an embedded smart object to a path taken verbatim from the PSD file. Because that name is attacker-controlled and unsanitised, a tool that extracts embedded objects from an untrusted `.psd` can be made to write attacker-chosen bytes to an attacker-chosen path (absolute or `../`-traversing)...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78452	4.6	MEDI		0.005	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Out-of-bounds read in Microsoft Windows SCSI Class System File allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78547	4.4	MEDI				Out-of-bounds write vulnerability in Citrix Citrix Workspace app for Windows. This issue affects Citrix Workspace app for Windows: before 2603.11 Current Release (CR), before 2507.1 LTSR CU3, and before LTSR 2607.
CVE-2026-66798	4.3	MEDI		0.006	microsoft:edge_chromium	Use after free in Microsoft Edge (Chromium-based) allows an unauthorized attacker to execute code over a network.
CVE-2026-78455	4.3	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Xbox allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-84646	4.3	MEDI		0.002	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, user objects can appear as nested field values in other deserialized XML objects, allowing attackers with Overall/Read permission to create user objects by submitting crafted XML.
CVE-2026-86087	4.3	MEDI		0.002		IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an authenticated user to send a specially crafted request to write arbitrary files on the system.
CVE-2026-88059	4.0	MEDI		0.003		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.28, 21.2.20, and 22.1.1, Angular's @angular/common HttpTransferCache can cache an authenticated response when Server-Side Rendering (SSR) and hydration use a hierarchical HttpClient configured with withRequestsMadeViaParent. The child TransferCache evaluates an initially...
CVE-2026-78124	3.7	LOW		0.002		strongSwan 5.0.2 through 6.0.7 allows PKCS#7 certificate enumeration in the openssl plugin that leads to a lack of release of memory after its effective lifetime.
CVE-2025-15695	3.5	LOW		0.002		The Translate WordPress with GTranslate WordPress plugin before 3.0.10 does not validate one of its settings before the bundled front-end scripts build markup from it, allowing users with a role as high as administrator to store JavaScript that runs in the session of any visitor to the site.
CVE-2026-58616	3.0	LOW		0.002	microsoft:edge_chromium	Concurrent execution using shared resource with improper synchronization ('race condition') in Copilot Chat (Microsoft Edge) allows an authorized attacker to disclose information over a network.
CVE-2026-86231	2.9	LOW		0.003		A security flaw has been discovered in mwiede jsch up to 2.28.5. Affected is the function getRevokedKeys of the file src/main/java/com/jcraft/jsch/KnownHosts.java. Performing a manipulation of the argument known_hosts results in improper check for certificate revocation. The attack is possible to be carried out remotely. The attack is considered to have high complexity. The exploitability is told to be difficult. ...
CVE-2026-86674	2.1	LOW		0.002		A vulnerability was found in ningzichun Student Management System up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this vulnerability is the function session_start of the file login.php. The manipulation results in session fixation. The attack can be launched remotely. The exploit has been made public and could be used. This product does not use versioning. This is why information about affected and un...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67211						OOM Denial of Service via Unbounded Map Pre-Sizing in Apache OpenNLP SymSpellModelSerializer Versions Affected: - 3.0.0-M4 - 3.0.0-M5 (The opennlp-spellcheck extension was introduced in 3.0.0-M4. Releases 1.x and 2.x do not contain the affected code.) Description: The SymSpellModelSerializer.create() method reads two 32-bit signed integer count fields (unigramCount and bigramCount) from a binary SymSpell mod...
CVE-2026-79035						A reflected cross-site scripting (XSS) vulnerability in the p.rfihub.com component of Zeta Marketing Platform (ZMP) v1.0 allows attackers to execute arbitrary Javascript in the context of the victim's browser via injecting a crafted URL into the ca parameter.
CVE-2026-80841				0.002		In the Linux kernel, the following vulnerability has been resolved: net/packet: defer vmalloc TX_RING free until skbs finish AF_PACKET TX_RING skbs keep a raw pointer to their ring frame. The skb page references preserve page-backed ring blocks after pg_vec is freed, but they do not preserve a vmalloc mapping. tpacket_destruct_skb() currently drops the pending reference before writing the timestamp and TP_STATU...
CVE-2026-80847				0.002		In the Linux kernel, the following vulnerability has been resolved: tcp: clamp route advmss to TCP_MIN_MSS tcp_select_initial_window() assumes that callers never pass an MSS smaller than 1, but route-derived advmss values can violate that assumption. A too-small explicit RTAX_ADVMSS is one way to get there, but it is not the only one. The same divide-by-zero can also be reached through the "default advmss" path...
CVE-2026-80858				0.002		In the Linux kernel, the following vulnerability has been resolved: fuse: publish io-uring queues with release semantics fuse_uring_create_queue() initializes a fuse_ring_queue and then publishes the pointer into ring->queues[qid] with WRITE_ONCE() under the fch->lock. There are several readers that may concurrently be fetching that pointer locklessly and then deferencing it. WRITE_ONCE() doesn't ensure orderin...
CVE-2026-80859				0.002		In the Linux kernel, the following vulnerability has been resolved: fuse: fix missing barrier when checking io-uring readiness fuse_block_alloc() reads fch->initialized and then fch->io_uring. fch->io_uring is set before fch->initialized, ordered by the smp_wmb() in fuse_chan_set_intialized(), but fuse_block_alloc() has no matching read barrier between the two loads. This may lead a CPU to observe fch->initiali...
CVE-2026-80860				0.002		In the Linux kernel, the following vulnerability has been resolved: fuse: fix race between interrupt and resend After commit f8fce75fedf7 ("fuse: clear intr_entry in fuse_resend and fuse_remove_pending_req") the WARN_ON(!list_empty(&req->intr_entry)) in fuse_request_free() still triggers due to the following race: In request_wait_answer() if (test_bit(FR_SENT, &req->flags)) -> returns true In fuse_chan_resen...
CVE-2026-80861				0.002		In the Linux kernel, the following vulnerability has been resolved: usb: xhci: bail out of setup if the controller is inaccessible xhci_gen_setup() locates the operational registers using the capability length read from the very first register: xhci->op_regs = hcd->regs + HC_LENGTH(readl(&xhci->cap_regs->hc_capbase)); If the controller is dead or has dropped off the bus, that read returns ~0, HC_LENGTH() tr...
CVE-2026-80878				0.002		In the Linux kernel, the following vulnerability has been resolved: afs: Fix leak of ungot volume Fix afs_lookup_volume_rcu() so that it doesn't leak a dying volume if afs_try_get_volume() fails.
CVE-2026-80925				0.002		In the Linux kernel, the following vulnerability has been resolved: vlan: fix skb_under_panic and races when toggling HW VLAN offload Toggling hardware VLAN TX offload (NETIF_F_HW_VLAN_CTAG_TX or NETIF_F_HW_VLAN_STAG_TX) on a lower device invokes vlan_transfer_features(), which dynamically changed vlandev->hard_header_len. This causes two issues: 1. Lockless TX paths (e.g. packet_snd in af_packet.c, ip6_finish_...
CVE-2026-80926						In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix use-after-free in oplock break notification smb2_oplock_break_noti() reads opinfo->conn without any lock and dereferences it after two allocations which may sleep. When the durable handle owning the oplock is disconnected, session_fd_check() clears opinfo->conn and drops its conn reference under ci->m_lock, and the last ksmbd_conn_pu...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80927						In the Linux kernel, the following vulnerability has been resolved: timekeeping: Check the return value of tk_get_aux_ts64 in __do_adjtimex() If the auxiliary clock is disabled during tk_get_aux_ts64() but is enabled before tks->clock_valid is checked, then uninitialized stackdata will be used in the calculations and indirectly leaked to userspace. The same race window also exists after this change and also for...
CVE-2026-80928						In the Linux kernel, the following vulnerability has been resolved: smack: fix cred UAF in smack_file_send_sigiotask() When inspecting the credentials of another task, objective credentials (->real_cred, accessed with __task_cred()) must always be used. Accessing ->cred on a non-current task is forbidden unless that task is being created or destroyed; a task is allowed to change its own ->cred pointer with no s...
CVE-2026-80929						In the Linux kernel, the following vulnerability has been resolved: sysctl: move the "cad_pid" entry from pid_table[] to kern_reboot_table[] cad_pid is global, and kill_cad_pid() is only used in the root namespace. However, due to pid_table_root_permissions(), a non-root user can unshare pid/user namespaces and modify it from the child namespace. This makes no sense and is simply wrong. Move it to kern_reboot_...
CVE-2026-80930						In the Linux kernel, the following vulnerability has been resolved: tpm: tpm_i2c_nuvoton: disable IRQ on wait timeout i2c_nuvoton_wait_for_stat() enables the IRQ before waiting for the interrupt handler to report a status change. If the wait times out, or is interrupted before the handler runs, the function returns without balancing the enable_irq() call. Disable the IRQ before leaving the failed wait path. Als...
CVE-2026-80931						In the Linux kernel, the following vulnerability has been resolved: w1: ds28e17: reject an oversize length on an I2C block read w1_f19_i2c_master_transfer() is the master_xfer for the DS28E17 1-Wire to I2C bridge. On an I2C_M_RECV_LEN read, it takes the length from the device. The downstream slave puts a length byte in buf[0]. The driver then reads that many bytes into buf[1] with w1_f19_i2c_read(). buf[0] is c...
CVE-2026-80932						In the Linux kernel, the following vulnerability has been resolved: vsock/virtio: flush works in dependency order virtio_vsock_remove() stops the virtqueues and then flushes each work item before freeing the enclosing virtio_vsock. The current order does not account for dependencies between those items: tx_work may queue send_pkt_work, and send_pkt_work may queue rx_work. In particular, send_pkt_work can set r...
CVE-2026-80933						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: validate default EEPROM firmware size The default EEPROM firmware is parsed and copied as a full EEPROM without checking its length. A truncated file can make the driver read beyond the firmware buffer during variant validation or the fallback copy. Reject files shorter than MT7996_EEPROM_SIZE before parsing or copying the f...
CVE-2026-80934						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: fix TX DMA mapping leak for AddBA req frames mt7996/mt7992 hand the firmware a HW MAC-TXP for AddBA req action frames (MT_TXD7_MAC_TXD, set in mt7996_mac_write_txwi_80211()), but are otherwise FW-TXP devices. On tx free mt76_connac_txp_skb_unmap() therefore decodes the per-frame txp as a struct mt76_connac_fw_txp. For a MAC-T...
CVE-2026-80935						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: bound the device EEPROM address before the EFUSE copy mt7996_mcu_get_eeprom() derives the destination of the EFUSE/EXT block copy from the address reported by the MCU response (event->addr, a device-controlled __le32) and clamps only the copy length, never the destination offset into dev->mt76.eeprom.data. A malicious or malf...
CVE-2026-80936						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7925: cancel mlo_pm_work on stop mt7925 queues mlo_pm_work with a 5 second delay during multi-link power-save setup and never cancels it on the stop path. If the device is torn down inside that window, the work outlives the teardown and its timer fires afterwards, trying to queue onto the workqueue that is already gone: workqueue...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80937						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: bound the device EEPROM address before the EFUSE copy mt7915_mcu_get_eeprom() copies a fixed EFUSE block into the driver's dev->mt76.eeprom.data buffer at the offset reported by the MCU response (res->addr, a device-controlled __le32) without checking it against the buffer size. A malicious or malfunctioning device can report...
CVE-2026-80938						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7615: avoid waiting for mac work under the mt76 mutex mt7615_suspend() acquired the mt76 mutex and then called cancel_delayed_work_sync() on mac_work. mt7615_mac_work() acquires the same mutex via mt7615_mutex_acquire() at the top of the worker, so if mac_work is already running and blocked on the mutex, the suspend path deadlocks...
CVE-2026-80939						In the Linux kernel, the following vulnerability has been resolved: wifi: rtw89: pci: add .shutdown callback to stop rkill polling on reboot Since the hardware rkill polling was introduced, arm64 platforms can panic with an asynchronous SError during warm reboot: SError Interrupt on CPU8, code 0x00000000be000011 -- SError Workqueue: events_power_efficient rkill_poll [rkill] rtw89_pci_ops_read8+0x94/...
CVE-2026-80940						In the Linux kernel, the following vulnerability has been resolved: wifi: rtw88: pci: fix resource leak on failed NAPI setup rtw_pci_probe() allocates PCI resources through rtw_pci_setup_resource() before it sets up NAPI. If rtw_pci_napi_init() fails, the error path jumps straight to err_pci_declaim and skips rtw_pci_destroy(), leaving the PCI resources allocated by rtw_pci_setup_resource() behind. Add a dedica...
CVE-2026-80941						In the Linux kernel, the following vulnerability has been resolved: wifi: rtw88: Fix potential memory leak in rtw_txq_push_skb() The skb passed to the rtw_hci_tx_write() is expected to be freed when the function fails, but the error path in rtw_txq_push_skb() does not free the skb before returning. This can lead to a memory leak in rtw_txq_push() where a dequeued skb is passed to rtw_txq_push_skb().
CVE-2026-80942						In the Linux kernel, the following vulnerability has been resolved: wifi: rtlwifi: rtl8192du: Fix possible memory leak in rtl92du_init_sw_vars() The memory allocated inside rtl92du_init_shared_data() is not freed in any of the subsequent error paths in rtl92du_init_sw_vars(). Fix that by adding a call to rtl92du_deinit_shared_data() in the error path.
CVE-2026-80943						In the Linux kernel, the following vulnerability has been resolved: wifi: rtlwifi: rtl8192du: check QoS TID before indexing tids rtl92du_tx_fill_desc() uses ieee80211_get_tid() to read the QoS TID from the 802.11 header and then uses it as an index into sta_entry->tids[]. ieee80211_get_tid() returns the low 4-bit QoS TID value, so the result can be in the range 0..15. rtlwifi only allocates MAX_TID_COUNT entrie...
CVE-2026-80944						In the Linux kernel, the following vulnerability has been resolved: wifi: mwifiex: Detach sync cmd buffer on interrupted wait mwifiex synchronous commands keep the caller-provided data buffer in cmd_node->data_buf. Several callers pass stack-allocated objects there. If wait_event_interruptible_timeout() is interrupted, the caller can return and release that stack object while the firmware command is still the c...
CVE-2026-80945						In the Linux kernel, the following vulnerability has been resolved: crypto: iaa - unmap dst before software fallback on decompress On a hardware analytics error, decompress retries through the software fallback, which writes req->dst with the CPU while it is still mapped DMA_FROM_DEVICE. With SWIOTLB active the later dma_unmap_sg() copies the stale bounce buffer over req->dst, corrupting the result. Unmap befor...
CVE-2026-80946						In the Linux kernel, the following vulnerability has been resolved: fuse: copy request headers via a stack buffer for io-uring The fuse-io-uring transport copies req->in.h out to the ring in fuse_uring_copy_to_ring() and req->out.h back in fuse_uring_commit(). Both headers live inside the fuse_request slab object, whose cache (fuse_req_cachep) is created without a usercopy whitelist, so copying them directly to/...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80947						In the Linux kernel, the following vulnerability has been resolved: wifi: rtl8xxxu: fix use-after-free from rx_urb_wq on stop rtl8xxxu arms rx_urb_wq from the RX completion path: rtl8xxxu_rx_complete() hands the URB to rtl8xxxu_queue_rx_urb(), which queues it on rx_urb_pending_list and, once the list grows past RTL8XXXU_RX_URB_PENDING_WATER, schedules rx_urb_wq. The worker rtl8xxxu_rx_urb_work() drains rx_urb_p...
CVE-2026-80948						In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: dvm: fix memory leak in iwl_op_mode_dvm_start() In iwl_op_mode_dvm_start(), jumping to out_free_eeprom currently bypasses the out_free_eeprom_blob label. Consequently, error paths triggered after successfully parsing the EEPROM free priv->nvm_data but leak priv->eeprom_blob. Fix this memory leak by reordering the error handling l...
CVE-2026-80949						In the Linux kernel, the following vulnerability has been resolved: wifi: brcmfmac: Fix memory leak in brcmf_sdio_read_control() The memory allocated for buf is not freed in some of the error paths in brcmf_sdio_read_control(). Fix that by adding vfree() calls. [arend: rework as suggested by Johannes]
CVE-2026-80950						In the Linux kernel, the following vulnerability has been resolved: i3c: renesas: Check that the transfer is valid before accessing it The Renesas I3C driver uses an asynchronous model to transfer data. It prepares a struct renesas_i3c_xfer, enqueues it, and waits for completion. The interrupt handler dequeues the transfer, updates/uses it, and signals the waiting thread. If the completion times out, the waitin...
CVE-2026-80951						In the Linux kernel, the following vulnerability has been resolved: i3c: master: svc: bound IBI payload to the requested max_payload_len svc_i3c_master_handle_ibi() reads the IBI payload from the RX FIFO into the IBI slot. The loop is bounded by the hardware FIFO size (SVC_I3C_FIFO_SIZE), not by the slot size. slot->data points into the IBI pool, which i3c_generic_ibi_alloc_pool() sizes at max_payload_len per s...
CVE-2026-80952						In the Linux kernel, the following vulnerability has been resolved: i3c: master: Fix info leak and UAF in device_unregister path i3c_master_unregister_i3c_devs() clears i3cdev->dev->desc before calling device_unregister(). During device_unregister(), device_del() emits a KOBJ_REMOVE uevent and unbinds the driver while the device descriptor is still expected to be valid. As a result, i3c_device_uevent() and a r...
CVE-2026-80953						In the Linux kernel, the following vulnerability has been resolved: i3c: master: adi: initialize the lock before enabling interrupts adi_i3c_master_probe() requests the IRQ and unmaskes REG_IRQ_PENDING_CMDR before the controller's IBI state, transfer queue list and transfer queue lock are initialized. A pending CMDR interrupt can therefore run adi_i3c_master_irq() and take master->xferqueue.lock before the dynam...
CVE-2026-80954						In the Linux kernel, the following vulnerability has been resolved: i3c: Fix unlocked dereference of dev->desc in i3c_device_get_supported_xfer_mode() i3c_device_get_supported_xfer_mode() uses dev->desc to obtain the master controller. However, dev->desc must not be dereferenced unless bus->lock is held, and this function does not take that lock. The function only needs access to the master controller associat...
CVE-2026-80955						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: fix use-after-free and invalid seg operations in kset_replay() In kset_replay, when key->seg_gen is stale (key->seg_gen < key->cache_pos.cache_seg->gen), cache_key_put(key) is called but then key->cache_pos.cache_seg is accessed as the argument to cache_seg_get(). This is a use-after-free on the freed key memory. Although mempool recy...
CVE-2026-80956						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: only hand out initialized cache segments get_cache_segment() scans the segment map up to cache->n_segs, the physical device segment count, but cache_segs_init() only initializes the first cache_info->n_segs segments. A crafted image with cache_info->n_segs smaller than the device count leaves the remaining pcache_cache_segment structs...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80957						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: detect a cycle in the last-kset chain during replay cache_replay() follows the on-media last-kset chain by next_cache_seg_id with no cond_resched(). A forged chain that points back into a segment it has already visited makes the replay loop follow it forever. Cap the last-kset hops at cache->n_segs; a valid chain visits each segment ...
CVE-2026-80958						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: clamp the tail kset read to the segment data region The tail-kset read in cache_replay(), the writeback worker and the GC worker bounds its length by PCACHE_SEG_SIZE - seg_off, the raw segment size rather than the data region. A tail near the segment end reads past the segment data into the following control area. Clamp the read to c...
CVE-2026-80959						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: bound the persisted tail-position offset cache_pos_decode() takes the persisted key_tail and dirty_tail seg_off from the cache device and addresses within the segment with it. A seg_off at or past the segment data_size, controllable by whoever supplies the device (CAP_SYS_ADMIN), reads past the segment data. Reject a decoded seg_off ...
CVE-2026-80960						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: validate on-media seg_num against the cache device size seg_num is read from the crc32c-only superblock, so whoever supplies the cache device on a table load (CAP_SYS_ADMIN) controls it. It sizes cache->segments[] and is the value every later on-media segment id is bounded against, yet it is never checked against the device. Because c...
CVE-2026-80961						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: validate kset key_num and intra-segment bounds Two more fields decoded from the cache device go unbounded. The kset key_num drives cache_kset_crc() and the replay loop in cache_replay(), the writeback worker and the GC worker, but only the magic and a fixed-seed CRC are checked first, so a non-last kset whose key_num exceeds the PCACH...
CVE-2026-80962						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: validate geometry fields from on-disk cache_info cache_segs_init() iterates cache_info->n_segs times indexing cache->segments[], which is sized to the cache device geometry, and get_seg_id() takes each segment id from the on-media cache_info and the per-segment next_seg link. Both come from cache device metadata that is only CRC-prot...
CVE-2026-80963						In the Linux kernel, the following vulnerability has been resolved: dm-stats: fix a crash if allocation of per-cpu data fails If "dm_kvzalloc(percpu_alloc_size, cpu_to_node(cpu))" fails, the code jumps to the "out" label and calls dm_stat_free. dm_stat_free does "for_each_possible_cpu(cpu) { dm_kvfree(s->stat_percpu[cpu][0].histogram, s->histogram_alloc_size);", which crashes with NULL pointer dereference if s->...
CVE-2026-80964						In the Linux kernel, the following vulnerability has been resolved: ALSA: virmidi: Check card index validity at probe virmidi driver blindly trusts that the given devptr->id value is within the proper card index range at probe. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this leads to OOB acc...
CVE-2026-80965						In the Linux kernel, the following vulnerability has been resolved: ALSA: serial-u16550: Check card index validity at probe serial-u16550 driver blindly trusts that the given devptr->id value is within the proper card index range at probe. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this lead...
CVE-2026-80966						In the Linux kernel, the following vulnerability has been resolved: ALSA: portman2x4: Check card index validity at probe Although portman2x4 driver has a check of the given devptr->id value, it doesn't check for a negative id, which is often given as "none" or such value when bound via sysfs. This may lead to OOB access for index[] and other parameters. Add a sanity check for the card index and warn/correct it...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80967						In the Linux kernel, the following vulnerability has been resolved: ALSA: pcxhr: initialize mutexes before requesting threaded IRQ pcxhr_probe() requests pcxhr_threaded_irq() before initializing mgr->lock, even though the threaded handler takes that mutex. Initialize the manager locks before request_threaded_irq() so an early interrupt cannot run against uninitialized mutex state during probe.
CVE-2026-80968						In the Linux kernel, the following vulnerability has been resolved: ALSA: mts64: Check card index validity at probe Although mts64 driver has a check of the given devptr->id value, it doesn't check for a negative id, which is often given as "none" or such value when bound via sysfs. This may lead to OOB access for index[] and other parameters. Add a sanity check for the card index and warn/correct it if it's a...
CVE-2026-80969						In the Linux kernel, the following vulnerability has been resolved: ALSA: mpu401: Check card index validity at probe mpu401 driver blindly trusts that the given devptr->id value is within the proper card index range at probe. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this leads to OOB acces...
CVE-2026-80970						In the Linux kernel, the following vulnerability has been resolved: ALSA: FCP: do not copy out an uninitialised init response fcp_ioctl_init() allocates its response buffer with kmalloc() and copies the whole buffer back to userspace: buf_size = init.step0_resp_size + init.step2_resp_size; void *resp __free(kfree) = kmalloc(buf_size, GFP_KERNEL); ... if (copy_to_user(arg->resp, resp, buf_size)) return ...
CVE-2026-80971						In the Linux kernel, the following vulnerability has been resolved: ALSA: bcd2000: clear the URB pointers on disconnect bcd2000_free_usb_related_resources() frees both URBs and leaves the pointers behind: usb_kill_urb(bcd2k->midi_out_urb); usb_kill_urb(bcd2k->midi_in_urb); usb_free_urb(bcd2k->midi_out_urb); usb_free_urb(bcd2k->midi_in_urb); The rawmidi device outlives that call. A substream that is still...
CVE-2026-80972						In the Linux kernel, the following vulnerability has been resolved: ALSA: aloop: Check card index validity at probe aloop driver blindly trusts that the given devptr->id value is within the proper card index range at probe. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this leads to OOB access ...
CVE-2026-80973						In the Linux kernel, the following vulnerability has been resolved: ALSA: 6fire: bound the MIDI event length from the device usb6fire_comm_receiver_handler() forwards a MIDI event using a length byte the device supplies, with no bound and no check that the transfer delivered that many bytes: if (!urb->status) { if (rt->receiver_buffer[0] == 0x10) /* midi in event */ if (midi_rt) midi_rt->in_received(m...
CVE-2026-80974						In the Linux kernel, the following vulnerability has been resolved: mfd: sm501: Fix potential memory leaks during remove The memory allocated for struct sm501_devdata in sm501_pci_probe() and sm501_plat_probe() is not freed by the corresponding remove functions sm501_pci_remove() and sm501_plat_remove(). Fix that by adding a call to kfree().
CVE-2026-80975						In the Linux kernel, the following vulnerability has been resolved: mfd: qnap-mcu: keep the reply buffer alive past a command timeout qnap_mcu_exec() publishes an on-stack buffer to the receive path: unsigned char rx[QNAP_MCU_RX_BUFFER_SIZE]; ... reply->data = rx; reply->length = length; and qnap_mcu_receive_buf() writes into it from the serdev receive path, which runs out of flush_to_ldisc() and is not se...
CVE-2026-80976						In the Linux kernel, the following vulnerability has been resolved: seg6: reset IP6CB after IPv6 decapsulation decap_and_validate() pulls the outer SRv6 headers and makes the inner packet the skb network header. The IPv6 control block still contains values collected while parsing the outer packet, including nhoff and extension-header flags. End.DX6 and End.DT6 route the inner IPv6 packet directly to the IPv6 in...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80977						In the Linux kernel, the following vulnerability has been resolved: net: skbuff: don't touch shared zerocopy state in skb_tx_error() skb_tx_error() completes the zerocopy uarg and clears SKBFL_ALL_ZEROCOPY, and skb_zcopy_downgrade_managed() clears SKBFL_MANAGED_FRAG_REFS. Both live in skb_shinfo(), which every clone shares, while the caller only owns the reference it is about to drop. Through a clone it tells th...
CVE-2026-80978						In the Linux kernel, the following vulnerability has been resolved: net: cap advertised IP tunnel headroom IP tunnel devices derive their advertised needed_headroom from lower output devices. A stack of user-created devices can make the derived value larger than the 16-bit skb header offsets can represent. Once IP output reserves it, skb head expansion can wrap those offsets. The runtime transmit path already c...
CVE-2026-80979						In the Linux kernel, the following vulnerability has been resolved: net/smc: unregister the connection before draining the rx tasklet smc_conn_free() calls smc_ism_unset_conn() only while the link group is still on its device list, and never sets conn->killed. smc_lgr_terminate_sched() unlinks the group immediately and defers killing its connections to a work item, so a connection freed in that window keeps its ...
CVE-2026-80980						In the Linux kernel, the following vulnerability has been resolved: net/smc: stop killed, freed and out_of_sync sharing a byte The three connection state flags are single-bit bitfields, so they occupy one byte of struct smc_connection and every store to one is a read-modify-write of the other two: u8 killed : 1; u8 freed : 1; u8 out_of_sync : 1; They are not written under a common lock. smc_cdc_...
CVE-2026-80981						In the Linux kernel, the following vulnerability has been resolved: net/smc: fix use-after-free of the LLC qentry in smc_llc_srv_add_link() smc_llc_srv_add_link() keeps add_llc pointing into the queue entry: add_llc = &qentry->msg.add_link; smc_llc.c:1482 ... smc_llc_save_add_link_info(link_new, add_llc); smc_llc.c:1494 smc_llc_flow_qentry_del(&lgr->llc_flow_lcl); smc_llc.c:1495 ... u8 *llc_msg =...
CVE-2026-80982						In the Linux kernel, the following vulnerability has been resolved: net/smc: fix use-after-free in smc_rx_pipe_buf_release() smc_rx_splice() hands RMB pages to a pipe and takes a socket reference per entry so the smc_sock stays alive until the reader finishes. The connection does not: a concurrent close runs smc_conn_free(), which releases the receive buffer back to the link group pool. smc_rx_pipe_buf_release(...
CVE-2026-80983						In the Linux kernel, the following vulnerability has been resolved: net/smc: fix socket refcount leak in smc_switch_conns() smc_switch_conns() takes a reference on the SMC socket before dropping lgr->conns_lock, so the connection stays alive while the CDC slot is fetched: sock_hold(&smc->sk); read_unlock_bh(&lgr->conns_lock); /* pre-fetch buffer outside of send_lock, might sleep */ ...
CVE-2026-80984						In the Linux kernel, the following vulnerability has been resolved: net/smc: do not dereference an unset send buffer on the SMC-D teardown path smc_close_stream_wait() calls smc_tx_prepared_sends() from inside its sk_wait_event() condition, and sk_wait_event() evaluates that condition once with the socket lock released. smcd_buf_detach() clears conn->sndbuf_desc from smc_conn_kill() under lock_sock(), so a link ...
CVE-2026-80985						In the Linux kernel, the following vulnerability has been resolved: net/smc: carry oversized SMC-Rv2 LLC messages in the queue entry smc_llc_rmt_delete_rkey() and smc_llc_save_add_link_rkeys() read the part of a v2 message that does not fit into the 44-byte union smc_llc_msg, and both bound themselves by the size of the buffer it landed in, not by what arrived. On a link with a shared v2 receive buffer a 44-byte...
CVE-2026-80986						In the Linux kernel, the following vulnerability has been resolved: net/smc: bound the peer rkey counts in SMC-Rv2 LLC messages On a link whose device has max_rcv_sge == 1 there is no shared v2 receive buffer, and smc_llc_save_add_link_rkeys() takes the v2 extension from 44 bytes past the start of the queue entry's inline message: ext = (struct smc_llc_msg_add_link_v2_ext *) (llc_msg + SMC_WR_TX_SIZE); The e...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80987						In the Linux kernel, the following vulnerability has been resolved: NTB: ntb_transport: Reject oversized TX buffers ntb_process_tx() handles an oversized buffer by calling tx_handler() with a NULL data pointer and returning success. ntb_netdev therefore neither frees the skb in its completion callback nor takes its enqueue error path, leaking it. Reject oversized buffers in ntb_transport_tx_enqueue() before acq...
CVE-2026-80988						In the Linux kernel, the following vulnerability has been resolved: NTB: ntb_transport: Fail TX enqueue when the QP link is down Commit f195a1a6fe41 ("ntb: Drop packets when qp link is down") meant to make ntb_transport_tx_enqueue() drop packets submitted while the QP link is down, but it only returns 0 without consuming the packet. Zero means success by this function's contract, so ntb_netdev reports NETDEV_TX...
CVE-2026-80989						In the Linux kernel, the following vulnerability has been resolved: net: thunderbolt: Mark the connection down when bringing it up fails Every failure path in tbnnet_connected_work() undoes its own work and returns without clearing login_sent, so the connection still looks established. The next tbnnet_tear_down() therefore takes its main branch and repeats a teardown that already happened: it stops rings that are ...
CVE-2026-80990						In the Linux kernel, the following vulnerability has been resolved: net: thunderbolt: Release the Rx HopID that was handed out on mismatch tb_xdomain_alloc_in_hopid() passes the wanted HopID to ida_alloc_range() as the lower bound, so a taken id is not an error there: the allocator returns the next free one above it. tbnnet_connected_work() asks for the peer's transmit path, treats any other id as a failure and r...
CVE-2026-80991						In the Linux kernel, the following vulnerability has been resolved: net: ravb: serialize PTP clock teardown ravb_ptp_interrupt() can race with ravb_ptp_stop() and pass the clock to ptp_clock_event() while ptp_clock_unregister() is freeing it. This can lead to a use-after-free. Use READ_ONCE() and WRITE_ONCE() for lockless access to the clock pointer. Atomically detach it with xchg() before disabling PTP interr...
CVE-2026-80992						In the Linux kernel, the following vulnerability has been resolved: net: ravb: avoid dereferencing an invalid PTP clock The PTP clock is unavailable before the first open, so querying its index can dereference a NULL pointer. Registration failures can also leave an error pointer in priv->ptp.clock. Cache the PHC index separately and report -1 while no clock is registered. Normalize registration errors to NULL a...
CVE-2026-80993						In the Linux kernel, the following vulnerability has been resolved: net: phylink: correctly validate returned PCS in phylink_inband_caps In phylink_inband_caps(), the PCS returned by mac_select_pcs is only checked if NULL but mac_select_pcs can also return an error pointer. This can cause a kernel panic as phylink_pcs_inband_caps() only checks if passed PCS is not NULL and directly dereference ops from the phyl...
CVE-2026-80994						In the Linux kernel, the following vulnerability has been resolved: net: openvswitch: fix flow mask use-after-free on flow deletion The commit in the Fixes tag below made so flow->mask free is scheduled via RCU right after it is removed from the flow table. The pointer stays in the flow structure and it can be accessible while in the same RCU critical section. This is done to avoid requiring ovs_mutex for the ...
CVE-2026-80995						In the Linux kernel, the following vulnerability has been resolved: net: mctp: hold a reference to the route device in mctp_route_lookup() mctp_route_lookup() uses rt->dev without holding a reference on it. mctp_route_lookup_single() returns the route under RCU only, so the route's device can be torn down concurrently: mctp_dev_put() drops the last reference and synchronously kfree(s mdev->addrs. mctp_dev_sadd...
CVE-2026-80996						In the Linux kernel, the following vulnerability has been resolved: net: l2tp: do not propagate multicast notification errors The tunnel create, tunnel modify, session create, and session modify netlink handlers send multicast notifications through helpers that can fail while allocating or encoding a message, or while multicasting it. For tunnel and session create/modify, a notification is sent after the live o...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80997						In the Linux kernel, the following vulnerability has been resolved: net: ipa: fix stalled modem TX queue after runtime resume ipa_start_xmit() unconditionally stops the TX queue before calling pm_runtime_get(), relying on the wake scheduled by runtime resume (ipa_modem_wake_queue_work()) to restart it once power is ACTIVE. But that work is queued from within the runtime resume callback, before the device's power...
CVE-2026-80998						In the Linux kernel, the following vulnerability has been resolved: net: bnxt: ring the doorbell when SW USO exits early When a burst of packets is handed down to the driver, the driver defers the doorbell to the end by setting txr->kick_pending = 1. The normal TX path handles this, but the SW USO path can miss it if it returns early. If bnxt_sw_udp_gso_xmit runs but returns early with NETDEV_TX_BUSY and txr->k...
CVE-2026-80999						In the Linux kernel, the following vulnerability has been resolved: net: dsa: realtek: use gpiod_set_value_cansleep for reset GPIO rtl83xx_reset_assert() and rtl83xx_reset_deassert() are only called from the probe path, which may sleep and is not timing-critical. When the reset GPIO is provided by a sleeping controller such as an I2C I/O expander, gpiod_set_value() warns: WARNING: drivers/gpio/gpiolib.c:4030...
CVE-2026-81000						In the Linux kernel, the following vulnerability has been resolved: net: tun: bound receive headroom tun_get_user() uses tun->align both as skb headroom and when choosing how much packet data to keep linear. OVS can propagate an oversized headroom request from another port to TUN or TAP. When align is larger than the usable space in a one-page skb head, SKB_MAX_HEAD(align) underflows and the result becomes nega...
CVE-2026-81001						In the Linux kernel, the following vulnerability has been resolved: slip: fix use-after-free in sl_sync() slip_devs[] stores bare net_device pointers and takes no reference on them. sl_sync() and sl_alloc() walk that table from slip_open() under rtnl_lock(), while an entry is dropped by sl_free_netdev(), which sl_setup() installs as dev->priv_destructor. priv_destructor is called from netdev_run_todo(), which ...
CVE-2026-81002						In the Linux kernel, the following vulnerability has been resolved: xdp: fix zero-copy frame layout xdp_convert_zc_to_xdp_frame() clones an XSK packet into an order-0 page and advertises PAGE_SIZE as its frame size. It allows the copied frame to occupy the page tail needed by skb_shared_info and records zero headroom even when metadata separates the frame header from packet data. An AF_XDP zero-copy packet redi...
CVE-2026-81003						In the Linux kernel, the following vulnerability has been resolved: net/iucv: filter frames in afiucv_hs_rcv() by ingress device afiucv_hs_rcv() selects a socket from iucv_sk_list by matching four 8-byte name fields in the transport header alone. No check is made against the net_device the frame arrived on. This can cause a frame arriving on any netdev to be delivered to an AF_IUCV socket. Three problems follow...
CVE-2026-81004						In the Linux kernel, the following vulnerability has been resolved: ipmi:msghandler: Cancel work cleanly on an error If an error occurs during startup of an IPMI interface, it may have scheduled work to run. The work needs to be canceled before the interface can be freed.
CVE-2026-81005						In the Linux kernel, the following vulnerability has been resolved: ipmi: si: Fix NULL pointer dereference after failed registration try_smi_init() allocates new_smi->si_sm and later calls ipmi_register_smi_mod(), which maps to ipmi_add_smi(). During ipmi_add_smi(), the upper IPMI message handler obtains the initial BMC device information through __bmc_get_device_id(). This can fail if the BMC does not return a...
CVE-2026-81006						In the Linux kernel, the following vulnerability has been resolved: ipmi: Remove all sysfs files on registration failure ipmi_add_smi() creates the nr_users and nr_msgs files before trying to create the maintenance_mode file. If that last creation fails, the error path removes only nr_users before dropping the final reference to the interface. Remove nr_msgs as well so no sysfs attribute embedded in the freed i...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81007						In the Linux kernel, the following vulnerability has been resolved: ipmi: ipmb: validate write message length ipmb_write() read message fields before validating the length byte. A zero or short write can read uninitialized stack bytes. A length smaller than the SMBus header underflows the block write length. Require a non-empty buffer and the minimum IPMB request length. Also require the length byte plus pay...
CVE-2026-81008						In the Linux kernel, the following vulnerability has been resolved: interconnect: Fix use after free in icc_get() and of_icc_get_by_index() In of_icc_get_by_index() and icc_get(), if the dynamic allocation for path->name fails via kasprintf(), the error handling path directly calls kfree(path) to free the path object and returns an error. However, prior to this point, path_find() calls path_init(), which ahead...
CVE-2026-81009						In the Linux kernel, the following vulnerability has been resolved: io_uring/query: cap user size passed to copy_struct_to_user io_handle_query_entry() clamps hdr.size for the inbound copy_from_user() but keeps the original user value as usize. copy_struct_to_user() uses that usize and, when it is larger than the kernel result, clear_user()s the trailing bytes. As hdr.size is a __u32, a query can request nearly...
CVE-2026-81010						In the Linux kernel, the following vulnerability has been resolved: io_uring/waitid: honor task_work cancellation io_waitid_cb() may run through the fallback task_work path when task_work_add() can no longer queue work to the originating task. The fallback runs from a kworker and io_uring marks such task work as canceled through tw.cancel. io_waitid_cb() currently ignores tw.cancel and calls __do_wait(). waitid...
CVE-2026-81011						In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: pass validated element count to package parsers The per-type package parsers are handed the wrong element count. hp_init_bios_package_attribute() validates obj->package.count and then calls one of the five hp_populate_*_package_data() wrappers (string, integer, enumeration, ordered list, password). Each wrapper forward...
CVE-2026-81012						In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: fix off-by-one write in hp_get_string_from_buffer() hp_get_string_from_buffer() clamps the converted string length against the destination buffer size with "size > dst_size", so when the converted length is exactly equal to dst_size, conv_dst_size is left at dst_size and the unconditional NUL terminator write dst[conv...
CVE-2026-81013						In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: fix heap OOB read on empty password write validate_password_input() computes length = strlen(buf) and then checks buff[length - 1] to strip a trailing newline, without checking that length is nonzero first. Writing an empty string (a bare '\n') to current_password or new_password gives length == 0, and buff[length - 1] re...
CVE-2026-81014						In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: fix heap OOB read in sk_store() and kek_store() sk_store() and kek_store() strip a trailing newline from the sysfs write before allocating the key buffer: length = count; if (buff[length - 1] == '\n') length--; bioscfg_drv.spm_data.signing_key = kmemdup(buf, length, GFP_KERNEL); but then pass the original "count" ...
CVE-2026-81015						In the Linux kernel, the following vulnerability has been resolved: platform/x86/amd/pmc: Fix LPS0 and debugfs leaks when STB init fails amd_pmc_probe() registers the LPS0 s2idle handler with acpi_register_lps0_dev() and creates the driver's debugfs directory before calling amd_stb_s2d_init(), which is the last step in probe that can fail. When amd_stb_s2d_init() fails (for example the S2D telemetry region cann...
CVE-2026-81016						In the Linux kernel, the following vulnerability has been resolved: platform/x86/amd/pmc: Propagate SMU errors and validate S2D address amd_stb_s2d_init() discards the return value of several S2D SMU commands. When the SMU refuses a command (e.g. "SMU cmd failed. err: 0xff") the failure is only noticed indirectly - if at all - and reported as -EIO, masking the real error. More seriously, the S2D_PHYS_ADDR_LOW/H...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81017						In the Linux kernel, the following vulnerability has been resolved: platform/chrome: sensorhub: Bound the EC-reported sensor number Each EC FIFO event carries an 8-bit sensor number (in->sensor_num). cros_ec_sensorhub_ring_handler() validates the FIFO event count, the per-read count and the ring bound, but not the sensor number, which cros_ec_sensor_ring_process_event() then uses unchecked to index sensorhub->ba...
CVE-2026-81018						In the Linux kernel, the following vulnerability has been resolved: platform/x86: think-lmi: Free system certificate signatures Multi-certificate support also allows the system authentication object to store ->signature and ->save_signature, which leak when the driver is removed. Free the signatures to avoid leaking memory.
CVE-2026-87888						The YayPricing WordPress plugin before 3.5.7 does not perform an authorization check on a REST route that saves its pricing rules, allowing users with the subscriber role and above to store JavaScript that executes in the browser of an administrator who opens the YayPricing WordPress plugin before 3.5.7's settings page.
CVE-2026-89436						In the Linux kernel, the following vulnerability has been resolved: platform/x86: panasonic-laptop: Fix sentinel write past pcc->sinff[] acpi_pcc_retrieve_biosdata() rejects SINF packages only when pcc->num_sifr is strictly less than hkey->package.count, then unconditionally writes a trailing sentinel at pcc->sinff[hkey->package.count]. But pcc->sinff[] is allocated with exactly pcc->num_sifr elements (valid indice...
CVE-2026-89437						In the Linux kernel, the following vulnerability has been resolved: platform/x86: int1092: Fix potential memory leak in sar_probe() The memory allocated for device_mode_info in parse_package() called by sar_get_data() is not freed in some of the error paths in sar_probe(). Fix that by converting to use device managed allocations.
CVE-2026-89438						In the Linux kernel, the following vulnerability has been resolved: platform/x86: ISST: Validate logical CPU id and clos id Validate max CLOS ID and logical CPU ID for core power feature. Reject any clos level or logical CPU number greater than the supported maximum. These are used to calculate MMIO offset.
CVE-2026-89439						In the Linux kernel, the following vulnerability has been resolved: platform/x86: ISST: Add a NULL check for sst_inst[] To be consistent with other places, add a NULL check for failed socket loading by checking isst_common.sst_inst[].
CVE-2026-89440						In the Linux kernel, the following vulnerability has been resolved: mmc: via-sdmmc: stop card-detect handling on probe failure request_irq() registers the SD card-detect interrupt and the probe enables it before mmc_add_host() runs. If mmc_add_host() fails, the error path only unmaps the registers and returns: the interrupt stays registered, so the handler keeps running against the host once it is freed. via_sdc...
CVE-2026-89441						In the Linux kernel, the following vulnerability has been resolved: mmc: via-sdmmc: cancel card-detect work on remove Disabling the device interrupt and freeing the IRQ prevents new card-detect work from being queued, but carddet_work already queued by the handler can still run after via_sd_remove() returns. via_sdc_card_detect() recovers the host through container_of() and dereferences its MMIO base; once remov...
CVE-2026-89442						In the Linux kernel, the following vulnerability has been resolved: platform/x86: ISST: Validate socket ID in clos_assoc ioctl isst_if_clos_assoc() validates the user-supplied socket_id with 'socket_id > topology_max_packages()', but isst_common.sst_inst[] is allocated with topology_max_packages() entries, so the valid index range is [0, topology_max_packages()). The '>' comparison lets socket_id == topology_ma...
CVE-2026-89443						In the Linux kernel, the following vulnerability has been resolved: platform/x86: ISST: Validate level in perf mask ioctls isst_if_get_perf_level_mask() and isst_if_get_base_freq_mask() use the user-provided level as an index into perf_levels[] via _read_pp_level_info() and _read_bf_level_info(), but neither helper validates it first. The adjacent level-info helpers reject levels above max_level before reading ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89444						In the Linux kernel, the following vulnerability has been resolved: platform/x86: dell-wmi-sysman: Don't hex dump attribute security buffer set_attribute() populates the security area of the BIOS attribute request buffer with the current admin password via populate_security_buffer(), then dumps the whole request buffer with print_hex_dump_bytes(). This can expose the plaintext admin password in the kernel log. ...
CVE-2026-89445						In the Linux kernel, the following vulnerability has been resolved: iommufd: Fix UAF in selftest IOPF reporting IOMMUFD selftest TRIGGER_IOPF borrows an attach handle from group->pasid_array without synchronizing against PASID detach, then a concurrent iommu_report_device_fault() can dereference that borrowed handle's domain pointer after the detach erases the handle and frees the backing struct iommufd_attach_h...
CVE-2026-89446						In the Linux kernel, the following vulnerability has been resolved: iommufd: Release current IOAS on xa_store() failure iommufd_take_all_iova_rwsem() takes an object reference and the iova_rwsem write lock before storing the IOAS in the temporary ioas_list xarray. If xa_store() fails, the current IOAS has not been inserted into ioas_list yet. iommufd_release_all_iova_rwsem() only unwinds IOAS objects already pr...
CVE-2026-89447						In the Linux kernel, the following vulnerability has been resolved: iommufd: Avoid locking internal accesses during unmap iommufd_access_notify_unmap() skips internal accesses because they do not have an external unmap callback to invoke. However, the current test calls iommufd_lock_obj() before checking whether the access is internal. If iommufd_lock_obj() succeeds, the loop then sees the internal access and c...
CVE-2026-89448						In the Linux kernel, the following vulnerability has been resolved: iommu/vt-d: Force requesting ACS when tboot is enabled Currently the conditions of requesting ACS in detect_intel_iommu() don't include tboot, leading to a possible misconfiguration with ACS disabled (e.g. due to user opts) while iommu is later forced on by tboot_force_iommu(). Fix it by checking tboot in detect_intel_iommu().
CVE-2026-89449						In the Linux kernel, the following vulnerability has been resolved: iommu: Fix dev_iommu memory leak when device_add fails in iommu_mock_device_add iommu_mock_device_add() first calls iommu_fwspec_init(), which on success allocates both dev->iommu (via dev_iommu_get()) and dev->iommu->fwspec. If the subsequent device_add(dev) call fails, the error path only calls iommu_fwspec_free(dev), which frees fwspec but le...
CVE-2026-89450						In the Linux kernel, the following vulnerability has been resolved: iommu/tegra241-cmdq: Reject a vSID wider than the SID_MATCH field tegra241_vintf_init_vsid() programs the guest-provided vSID into SID_MATCH, whose VIRT_SID field spans bits [20:1] with bit 0 as the match-enable flag. The HW therefore matches only a 20-bit Stream ID. The bound check rejects only virt_sid > UINT_MAX, which admits a value far wi...
CVE-2026-89451						In the Linux kernel, the following vulnerability has been resolved: iommu/sva: Set handle->dev before the SVA handle is visible iommu_attach_device_pasid() installs the new SVA attach handle in the group PASID lookup before iommu_sva_bind_device() returns. A concurrent bind can therefore find and reuse the same handle after iommu_sva_lock is dropped. handle->dev was initialized after dropping iommu_sva_lock. Th...
CVE-2026-89452						In the Linux kernel, the following vulnerability has been resolved: iommu/msm: Unwind probe state on registration failure msm_iommu_probe() adds its devm-managed IOMMU object to qcom_iommu_devices before adding the IOMMU sysfs device and registering it with the IOMMU core. If iommu_device_sysfs_add() fails, probe returns with the object still on qcom_iommu_devices. The driver core then releases the devm allocat...
CVE-2026-89453						In the Linux kernel, the following vulnerability has been resolved: iommu/amd: Put PCI device after handling PPR faults iommu_call_iopf_notifier() looks up the requester with pci_get_domain_bus_and_slot(), which returns a PCI device with its reference count incremented. Neither the successful iommu_report_device_fault() path nor the abort path drops that reference, so every handled PPR request leaks a PCI devic...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89454						In the Linux kernel, the following vulnerability has been resolved: PCI: plda: Fix IRQ domain leaks in the error paths of plda_init_interrupts() plda_init_interrupts() initializes IRQ domains and creates IRQ mapping but does not unwind them when later step fails. If platform_get_irq() or either irq_create_mapping() fails in plda_init_interrupts(), the domains are never deinitialized. If irq_create_mapping() fai...
CVE-2026-89455						In the Linux kernel, the following vulnerability has been resolved: PCI: plda: Fix use-after-free of event IRQs during teardown plda_pcie_irq_domain_deinit() removes pcie->event_domain via irq_domain_remove(), but the per-event IRQs mapped from that domain are requested with devm_request_irq() in plda_init_interrupts(). The actual free_irq() for a devm-managed IRQ is deferred by devres until after the calling pr...
CVE-2026-89456						In the Linux kernel, the following vulnerability has been resolved: s390/dasd: Propagate partial completion length across ERP recovery dasd_default_erp_postaction() copies the timing and device state from the finished ERP request back to the original request but drops proc_bytes. A request that was partially completed, an ESE read of a not-yet-allocated track returns fewer bytes than requested, and then recovere...
CVE-2026-89457						In the Linux kernel, the following vulnerability has been resolved: s390/dasd: Guard sysfs discipline callbacks against unallocated private data Several sysfs show/store handlers call a discipline callback that dereferences device->private, either directly or through the DASD_DEFINE_ATTR() macro. During dasd_generic_set_online() the discipline is assigned before check_device() allocates device->private, so an un...
CVE-2026-89458						In the Linux kernel, the following vulnerability has been resolved: s390/dasd: Do not complete a failed ESE read as successful dasd_int_handler() completes an NRF read of an unallocated ESE track by calling ese_read() and unconditionally marking the request DASD_CQR_SUCCESS. dasd_eckd_ese_read() can return an error before it has zeroed the destination buffer: a failed sense-data parse or a current track outside ...
CVE-2026-89459						In the Linux kernel, the following vulnerability has been resolved: s390/percpu: Fix MVIY_PERCPU() with older binutils Commit a737737cdb9c ("s390/percpu: Infrastructure for more efficient this_cpu operations") introduced MVIY_PERCPU(), which stringifies arguments that are already C string literals. This generates an assembler macro invocation with whitespace-separated quoted arguments: GEN_MVIY "459712" "%r3"...
CVE-2026-89460						In the Linux kernel, the following vulnerability has been resolved: s390/cpum_cf: Handle CPU hotplug via prepare/dead callbacks The command 'perf stat -e cycles -- <command>' crashes the kernel when CPUs are hotplug added during that run. Root cause is the allocation of struct cpu_cf_events at first event initialization. The allocation is dynamic and the first event that has task context creates such a structur...
CVE-2026-89461						In the Linux kernel, the following vulnerability has been resolved: power: supply: max17040: synchronize work cancellation on suspend max17040_work() requeues itself after every poll. cancel_delayed_work() only cancels a pending instance and does not wait for a callback that is already running. If system suspend races with the polling callback, the callback can continue accessing the fuel gauge and requeue itse...
CVE-2026-89462						In the Linux kernel, the following vulnerability has been resolved: power: supply: max17040: propagate register read errors max17040_get_vcell() and max17040_get_soc() ignore errors returned by regmap_read(). When an I2C transfer fails, the uninitialized register value is converted and reported to userspace as a valid voltage or state of charge. The polling worker can also replace the cached state of charge wi...
CVE-2026-89463						In the Linux kernel, the following vulnerability has been resolved: power: supply: ucs1002: fix use-after-free on remove ucs1002 has no remove callback, so unbind runs entirely through devm. The alert IRQ handler queues the health_poll delayed work, and the work reschedules itself while the chip reports a bad-health condition. devm frees the alert IRQ, which only synchronizes the handler; it does not cancel the...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89464						In the Linux kernel, the following vulnerability has been resolved: power: supply: twl4030_charger: cancel workers via devm bci is devm-allocated. Two workers (bci->work and bci->current_worker) dereference it. twl4030_bci_remove() disables charging and masks interrupts. It cancels neither worker. A worker pending at remove() can run after devm frees bci. The USB transceiver comes from devm_usb_get_phy_by_node(...
CVE-2026-89465						In the Linux kernel, the following vulnerability has been resolved: power: supply: rt9455: quiesce delayed work before teardown The threaded IRQ handler can queue pwr_rdy_work, max_charging_time_work and batt_presence_work. pwr_rdy_work and batt_presence_work can also queue max_charging_time_work, while batt_presence_work can requeue itself. rt9455_remove() cancels max_charging_time_work before batt_presence_w...
CVE-2026-89466						In the Linux kernel, the following vulnerability has been resolved: power: supply: qcom_battmgr: terminate the strings from firmware The qcom_battmgr_sc8280xp_strcpy() takes a Pascal-style string when the firmware sends one. Otherwise it copies all BATTMGR_STRING_LEN bytes and leaves the destination without a terminator. Those destinations are model_number, serial_number and oem_info, each BATTMGR_STRING_LEN an...
CVE-2026-89467						In the Linux kernel, the following vulnerability has been resolved: power: supply: qcom_battmgr: fix use-after-free qcom_battmgr_pdr_notify() queues enable_work when the PMIC GLINK service comes up, and the worker recovers battmgr through container_of() to issue firmware requests. The PMIC GLINK client stays on the client list until its devres release action runs, so a PDR notification can keep queueing the work...
CVE-2026-89468						In the Linux kernel, the following vulnerability has been resolved: power: supply: lp8788-charger: fix use-after-free on remove lp8788_charger_remove() flushes charger_work before unregistering the IRQs. An IRQ thread can queue charger_work after flush_work() has returned. The work can then run after devres frees pchg and dereference it in lp8788_charger_event(). Unregister the IRQs first. free_irq() waits for ...
CVE-2026-89469						In the Linux kernel, the following vulnerability has been resolved: power: supply: lp8727: fix use-after-free in lp8727_release_irq() lp8727_isr_func(), the threaded IRQ handler, is the only caller that arms pchg->work via schedule_delayed_work(). lp8727_release_irq() currently cancels the work before freeing the IRQ, so an IRQ delivered in between can re-arm the work through the threaded handler. After .remov...
CVE-2026-89470						In the Linux kernel, the following vulnerability has been resolved: power: supply: cros_usbpd: Limit port counts to EC_USB_PD_MAX_PORTS Currently the cros_usbpd-charger driver probe iterates based on raw charger port count returned by the embedded controller. The only check is against the number of USB PD ports which the embedded controller also defines. A malicious embedded controller could return an inaccurate...
CVE-2026-89471						In the Linux kernel, the following vulnerability has been resolved: power: supply: cros_usbpd-charger: bound the EC-reported port count cros_usbpd_charger_probe() reads two port counts from the EC and uses one of them, num_charger_ports, as the loop bound when populating a fixed-size array: struct port_data *ports[EC_USB_PD_MAX_PORTS]; /* 8 entries */ ... for (i = 0; i < charger->num_charger_ports; i++) ch...
CVE-2026-89472						In the Linux kernel, the following vulnerability has been resolved: power: supply: charger-manager: register regulators before exposing sysfs charger_manager_remove() and the err_reg_extcon probe error path free each charger regulator with regulator_put() before tearing down the power_supply sysfs entries (power_supply_unregister()). charger_manager_remove() also calls try_charger_enable(cm, false) after the reg...
CVE-2026-89473						In the Linux kernel, the following vulnerability has been resolved: power: supply: bq25890: Fix power_supply reference leak bq25890_fw_probe() acquires a reference to a secondary charger using power_supply_get_by_name(), but the reference is not released on later probe failures or on driver detach. In particular, failures after bq25890_fw_probe() returns successfully, such as a failure in bq25890_hw_init(), als...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89474						In the Linux kernel, the following vulnerability has been resolved: power: supply: bq256xx: drain usb_work before freeing the charger The USB-PHY notifier queues usb_work, whose handler calls power_supply_changed(bq->charger). The reset devm action only unregisters the notifier and was registered before the power supplies, so devm frees bq->charger on unwind before the action runs; a usb_work still queued can th...
CVE-2026-89475						In the Linux kernel, the following vulnerability has been resolved: power: supply: bq24257: fix use-after-free on remove The STAT-pin interrupt is devm-managed, so it stays armed until the devm cleanup that runs after remove() returns. remove() cancels bq->iilimit_setup_work while the threaded handler can still fire; that handler reschedules the work and dereferences bq, so the work runs against freed memory onc...
CVE-2026-89476						In the Linux kernel, the following vulnerability has been resolved: sctp: fix stream->outcnt underflow on duplicate RECONF responses A cached RECONF chunk may contain more than one request parameter. A duplicate response can therefore find and process the same ADD_OUT request again while another parameter is still outstanding, rolling back outcnt twice and possibly underflowing it. Track outstanding request ty...
CVE-2026-89477						In the Linux kernel, the following vulnerability has been resolved: sctp: fix NULL deref on untransmitted RECONF completion sctp_process_streset_outreq(), sctp_process_streset_addstrm_out() and sctp_process_streset_resp() complete a pending stream reconfiguration request by stopping the reconf timer on the transport it was sent on: t = asoc->streset_chunk->transport; if (timer_delete(&t->reconf_timer)) ...
CVE-2026-89478						In the Linux kernel, the following vulnerability has been resolved: sctp: drop a chunk if its transport was removed sctp_rcv() resolves the transport once per packet and leaves it in chunk->transport. The lookup reference, or the one sctp_add_backlog() takes if the socket is owned by userspace, keeps it around until the chunk has been processed. An authenticated ASCONF DEL-IP can remove it in the meantime. sctp...
CVE-2026-89479						In the Linux kernel, the following vulnerability has been resolved: sctp: stop processing a packet once its association is deleted sctp_endpoint_bh_rcv() looks the association up only when chunk->asoc is NULL, and caches the result in chunk->asoc and chunk->transport without taking a reference. A packet that matches no association is handed to the endpoint, so a peer can bundle COOKIE ECHO, SHUTDOWN and SHUTDOWN...
CVE-2026-89480						In the Linux kernel, the following vulnerability has been resolved: nvme-tcp: reject a read that transferred too few bytes nvme_tcp_rcv_data() completes a request once the current C2HData PDU has been consumed. Nothing compares the total bytes received against the length the command asked for: struct nvme_tcp_request has no receive-side counter, queue->data_remaining is per queue, and blk_mq_end_request() compl...
CVE-2026-89481						In the Linux kernel, the following vulnerability has been resolved: nvme-tcp: fix host memory disclosure on R2T for a read command nvme_tcp_handle_r2t() does not check the direction of the request the R2T refers to. A malicious controller can send an R2T for a READ and the host will answer it: nvme_tcp_setup_h2c_data_pdu() builds the H2CData header and nvme_tcp_try_send_data() sends the request's data buffer. Th...
CVE-2026-89482						In the Linux kernel, the following vulnerability has been resolved: nvme-tcp: do not accept C2HData based on blk_rq_payload_bytes() alone Commit 25e5cb780e62 ("nvme-tcp: fix possible crash in write_zeroes processing") established that blk_rq_payload_bytes() must not be read without first checking blk_rq_nr_phys_segments(), and recorded the result in nvme_tcp_setup_cmd_pdu() as req->data_len. The receive side was...
CVE-2026-89483						In the Linux kernel, the following vulnerability has been resolved: nvme: zero the discard fallback page nvme_setup_discard() always maps sizeof(struct nvme_dsm_range) * NVME_DSM_MAX_RANGES = 4096 bytes as the DSM payload however many ranges the command declares, because some devices ignore the 'Number of Ranges' field - the Fixes: commit records two that read past the declared ranges. A single-range discard fil...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89484						In the Linux kernel, the following vulnerability has been resolved: lockd: fix NULL dereference on lockowner allocation failure nlmclnt_locks_init_private() installs NLM file lock operations even when nlmclnt_find_lockowner() fails to allocate a lockowner. nlmclnt_proc() then returns -ENOMEM, but the VFS still tears down the partially initialized file_lock and calls locks_release_private(). That invokes nlmclnt...
CVE-2026-89485						In the Linux kernel, the following vulnerability has been resolved: lockd: pin next file across nlm_inspect_file lock-drop nlm_traverse_files() pins the current file with f_count++ across a mutex_unlock for nlm_inspect_file(), but nothing pins the saved next pointer. A concurrent nlm_release_file() can kfree the next file during the unlock window, and the iterator dereferences freed memory on the next loop step...
CVE-2026-89486						In the Linux kernel, the following vulnerability has been resolved: ipmi: Fix use-after-free of cmd_rcvr in _ipmi_destroy_user() Commit 9e91f8a6c868 ("ipmi:msghandler: Remove srcu for the ipmi_interfaces list") dropped the synchronize_rcu() between unlinking the command receivers from intf->cmd_rcvrs and freeing them, updating only the comment that explains why the barrier is needed. The cmd_rcvrs list is still...
CVE-2026-89487						In the Linux kernel, the following vulnerability has been resolved: openvswitch: only skb_tx_error() a packet we are about to drop queue_userspace_packet() borrows the packet skb -- it only copies it into a private netlink message (user_skb) and does not own it; on return do_execute_actions() keeps forwarding it through the flow's remaining actions. Its error path nevertheless calls skb_tx_error(skb), which via ...
CVE-2026-89488						In the Linux kernel, the following vulnerability has been resolved: openvswitch: Fix CT limit teardown use-after-free Packet processing uses CT limit state under RCU, while netns teardown frees that state under ovs_mutex. The CT limit pointer was neither removed from readers nor protected by a grace period, allowing packet processing to dereference the freed state. An unprivileged user can trigger this bug from...
CVE-2026-89489						In the Linux kernel, the following vulnerability has been resolved: openrisc: fix arbitrary kernel memory access via or1k_atomic syscall sys_or1k_atomic() (syscall 244 in the "or1k" ABI) takes two user pointers, v1 and v2, and swaps the words they point to in hand-written assembly. l.lwz r29,0(r4) l.lwz r27,0(r5) l.sw 0(r4),r27 l.sw 0(r5),r29 The pointers are not checked with access_o...
CVE-2026-89490						In the Linux kernel, the following vulnerability has been resolved: ocfs2: fix readdir position truncation on 32-bit kernels In ocfs2_dir_foreach_blk_el(), the directory cookie position is rebuilt with ctx->pos = (ctx->pos & ~(sb->s_blocksize - 1)) offset; `ctx->pos` is loff_t (signed 64-bit), while `sb->s_blocksize` is unsigned long. On 32-bit kernels unsigned long is 32-bit, so the mask ~(sb->s_blocksi...
CVE-2026-89491						In the Linux kernel, the following vulnerability has been resolved: ocfs2: cluster: don't sleep while holding o2hb_live_lock in o2hb_region_pin() Patch series "ocfs2: cluster: o2hb_region_pin() fixes", v2. This series fixes three related issues in o2hb_region_pin(), all are from the original implementation in commit: 58a3158a5d17 ("ocfs2/cluster: Pin/unpin o2hb regions"): 1) It is called with o2hb_live_lock (a...
CVE-2026-89492						In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate directory-index entry counts when reading metadata ocfs2_validate_dx_leaf() and ocfs2_validate_dx_root() check the ECC and signature of an indexed-directory block before it reaches higher-level callers, but neither validator bounds the ocfs2_dx_entry_list counts against the capacity of the block that holds them. ocfs2_dx_dir_sea...
CVE-2026-89493						In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate rl_used against rl_count in refcount block validator ocfs2_find_refcount_rec_in_rl() walks the on-disk refcount record array with: for (; i < le16_to_cpu(rb->rf_records.rl_used); i++) { rec = &rb->rf_records.rl_recs[i]; ... rl_recs[] lives in a single metadata block (4096 bytes on the common configuration), so its real cap...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89494						In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate lengths in dlm_mig_lockres_handler A node receiving a DLM_MIG_LOCKRES message trusts several fields of the peer-supplied dlm_migratable_lockres without validation. num_locks and lockname_len are bounded only on the sending side, and the message is never checked to actually carry num_locks migratable_lock entries. As a result dl...
CVE-2026-89495						In the Linux kernel, the following vulnerability has been resolved: ocfs2: bound namelen in dlm_migrate_request_handler Patch series "ocfs2/dlm: bound peer-controlled lengths in the o2dlm". The o2dlm receive handlers trust u8 length and count fields from the wire without bounding them, so a node in a DLM domain can corrupt or panic any other node with a malformed message. Three defects: - dlm_migrate_reques...
CVE-2026-89496						In the Linux kernel, the following vulnerability has been resolved: ocfs2: always run deallocs on copy-on-write completion Local fuzzing of 6.12.94 has found the following memory leak caused by doing 'copy_file_range()' within the same filesystem: unreferenced object 0xffff88812192c980 (size 32): comm "syz.0.49", pid 12095, jiffies 4294964143 hex dump (first 32 bytes): 00 00 00 00 00 00 00 00 08 00 00 0...
CVE-2026-89497						In the Linux kernel, the following vulnerability has been resolved: oranges: skip leading spaces before parsing client debug masks oranges_prepare_cdm_array() sizes each client debug keyword buffer with strcspn(cds_head, " "), but then parses the keyword with %s. The %s conversion skips leading whitespace, while strcspn() does not. If a client debug entry starts with a space, the allocation can be sized for a...
CVE-2026-89498						In the Linux kernel, the following vulnerability has been resolved: oranges: fix double-free of trailer_buf on readdir copy failure On a readdir downcall, oranges_devreq_write_iter() frees op->downcall.trailer_buf with vfree() when copy_from_iter_full() fails, but does not clear the pointer before goto Efault. The waiter in do_readdir() is then woken with a negative status and frees the same pointer again on i...
CVE-2026-89499						In the Linux kernel, the following vulnerability has been resolved: ring-buffer: Stop remote reader update when page swap fails The remote swap_reader_page callback can return -EBUSY when the writer moves the head before the remote catches it, particularly during an event storm on a small buffer. __rb_get_reader_page_from_remote() currently warns about that failure but continues with the unchanged reader ID and ...
CVE-2026-89500						In the Linux kernel, the following vulnerability has been resolved: ring-buffer: Make cpu_buffer::free_page a buffer_data_read_page Discarding a cached reader page after a concurrent ring buffer resize uses the new global subbuf_order for the free_pages() call. This mismatched order may crashes the kernel or leaks memory because the cached page was allocated under the old size. Save the actual free_page order a...
CVE-2026-89501						In the Linux kernel, the following vulnerability has been resolved: ring-buffer: Hold cpu_buffer::lock when resizing a subbuf Because, ring_buffer_subbuf_order_set() can clear cpu_buffer->free_page, hold cpu_buffer->lock to prevent races with ring_buffer_alloc_read_page() and ring_buffer_free_read_page().
CVE-2026-89502						In the Linux kernel, the following vulnerability has been resolved: ring-buffer: Free cpu_buffer::free_page with subbuf_order When sub-buffers use an order greater than 0, cpu_buffer->free_page is allocated with subbuf_order. Use the correct order for cpu_buffer->free_page.
CVE-2026-89503						In the Linux kernel, the following vulnerability has been resolved: ring-buffer: Fix subbuf resize race with ring_buffer_alloc_read_page() ring_buffer_alloc_read_page() is racy with ring_buffer_subbuf_order_set, it can allocate a reader page with an outdated order. This isn't a big issue, the user can still re-allocate a new reader page and try again. However, what is more problematic is if the value of subbuf_...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89504						In the Linux kernel, the following vulnerability has been resolved: regulator: as3722_get_regulator_dt_data: fix premature of_node_put leaving dangling of_node pointer In as3722_get_regulator_dt_data(), of_get_child_by_name() acquires a reference on np, which is then assigned to pdev->dev.of_node. The function immediately calls of_node_put(np), releasing the reference and leaving pdev->dev.of_node as a dangling ...
CVE-2026-89505						In the Linux kernel, the following vulnerability has been resolved: RDMA/uverbs: Guard legacy bundles without method_elm The legacy write() path dispatches through a uverbs_api_write_method, but the uverbs_attr_bundle passed to provider code does not have an ioctl method element. If malformed provider input causes the common uverbs validation code to emit an error message, uverbs_get_handler_fn() dereferences th...
CVE-2026-89506						In the Linux kernel, the following vulnerability has been resolved: RDMA/uverbs: Add UVERBS_ATTR_UHW to UVERBS_METHOD_REG_MR The original commit missed that three drivers (mthca, irdma, siw) have UHW data associated with reg_mr that cannot be passed through the ioctl. They also assume that the udata cannot be NULL, so failing to pass a valid udata can trigger a NULL udata crash in those drivers. This never happ...
CVE-2026-89507						In the Linux kernel, the following vulnerability has been resolved: RDMA/ucma: Lock the handler in ucma_write_cm_event() ctx->file may only be changed under the handler lock and the xa_lock, which is what stops uevents being queued for a ctx while ucma_migrate_id() moves it to another file. The CM core takes that lock before invoking ucma_event_handler(), but the write() paths that queue uevents themselves do n...
CVE-2026-89508						In the Linux kernel, the following vulnerability has been resolved: RDMA/ucma: Lock the handler in ucma_set_ib_path() ucma_set_ib_path() calls ucma_event_handler() straight from the write() path, without the handler lock that keeps ctx->file stable while a uevent is queued. The handler re-reads ctx->file for every dereference: mutex_lock(&ctx->file->mut); /* file A */ list_add_tail(&uevent->list, &ctx->fil...
CVE-2026-89509						In the Linux kernel, the following vulnerability has been resolved: RDMA/ionic: Embed counter driver data in rdma_counter allocation Commit 7e53b31acc7f ("RDMA/core: Create and destroy rdma_counter using rdma_zalloc_drv_obj()") requires drivers implementing counter ops to embed struct rdma_counter in a driver-specific struct, register its size via INIT_RDMA_OBJ_SIZE, and provide a counter_init callback. The ion...
CVE-2026-89510						In the Linux kernel, the following vulnerability has been resolved: RDMA/cxgb4: Cancel reg_work before freeing device on remove c4iw_uld_state_change() queues reg_work to register the RDMA device. c4iw_remove() can free ctx->dev while this work is pending or running, leaving c4iw_register_device() accessing the freed device. Cancel reg_work before removing the device. The registration work can tear down ctx->d...
CVE-2026-89511						In the Linux kernel, the following vulnerability has been resolved: qede: Fix NULL pointer dereference in TPA fragment processing Under memory pressure, the qede driver encounters NULL pointer dereferences when processing TPA continuation fragments. Commit 8a8633978b84 ("qede: Add build_skb() support.") accidentally dropped the assignment of tpa_info->buffer.data in qede_tpa_start(). When memory pressure cause...
CVE-2026-89512						In the Linux kernel, the following vulnerability has been resolved: remoteproc: scp: Fix device reference leak on failed lookup Make sure to drop the reference taken to the SCP device when attempting to look up its driver data before the driver has been bound. Note that holding a reference to a device does not prevent its driver data from going away.
CVE-2026-89513						In the Linux kernel, the following vulnerability has been resolved: RISC-V: KVM: Fix PMU event info array size overflow SBI PMU EVENT_GET_INFO stores guest-controlled num_events * sizeof(*einfo) in a 32-bit integer. On RV64, num_events = 0x100000001 makes 0x100000010 truncate to 16. KVM then allocates one entry but loops over the original num_events, causing out-of-bounds reads and writes. A nested guest trigger...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89514						In the Linux kernel, the following vulnerability has been resolved: scsi: fnic: Use GFP_ATOMIC for VLAN alloc under spinlock fnic_fcoe_process_vlan_resp() allocates a VLAN descriptor with kzalloc_obj() (default GFP_KERNEL) while holding vlans_lock via spin_lock_irqsave(). GFP_KERNEL may sleep, which is not allowed in this atomic context and can trigger a sleeping-from-invalid-context warning or deadlock. Pass G...
CVE-2026-89515						In the Linux kernel, the following vulnerability has been resolved: scsi: core: Fill in DMA padding bytes in scsi_alloc_sgtables() During fuzz testing, the following issue was discovered: BUG: KMSAN: uninit-value in __dma_map_sg_attrs+0x217/0x310 __dma_map_sg_attrs+0x217/0x310 dma_map_sg_attrs+0x4a/0x70 ata_qc_issue+0x9f8/0x1420 __ata_scsi_queuecmd+0x1657/0x1740 ata_scsi_queuecmd+0x79a/0x920 scsi_queue_rq...
CVE-2026-89516						In the Linux kernel, the following vulnerability has been resolved: sched_ext: Don't BUG_ON a destroyed DSQ in process_deferred_reenq_users scx_bpf_dsq_reenq() queues a deferred reenq (dru) that runs from run_deferred(), not ops.dispatch(). If the DSQ is destroyed before the dru runs, process_deferred_reenq_users() sees dsq->id == SCX_DSQ_INVALID and hits the BUG_ON. destroy_dsq() doesn't flush pending drus, so ...
CVE-2026-89517						In the Linux kernel, the following vulnerability has been resolved: sched_ext: Fix rq->core_pick corruption under core scheduling Core scheduling's pick_next_task() picks what to run on every SMT sibling of the core in a single pass under the shared core-wide rq lock. The selection state is consistent only while the lock is held continuously, so ->pick_task() originally could not release it. However, since 4c953...
CVE-2026-89518						In the Linux kernel, the following vulnerability has been resolved: sched_ext: Fix this_rq() assumptions in dispatch kfuncs Under core scheduling, dispatch runs from within the core-wide pick and can target a sibling rq, so ops.dispatch() may execute on a CPU different from the dispatched rq's. Several kfunc paths assumed the two always coincide: - scx_dsq_move() decided whether an rq lock is held by testing th...
CVE-2026-89519						In the Linux kernel, the following vulnerability has been resolved: sched_ext: Replace SCX_RQ_BAL_KEEP with a dispatch verdict return SCX_RQ_BAL_KEEP tells the pick to keep running the previous task, a leftover from when balancing and picking were separate operations. An rq-level flag only works while dispatches and picks pair up one to one, which core scheduling breaks: selections interleave through dispatch's ...
CVE-2026-89520						In the Linux kernel, the following vulnerability has been resolved: sched/core: Make core-sched flips wait for in-flight selections Core scheduling's pick_next_task() operates on all sibling rqs under one acquisition of the shared core-wide lock. A ->pick_task() that releases the rq lock leaves every sibling __lock momentarily free, letting __sched_core_flip(false) complete mid-selection and rebind rq_lockp() un...
CVE-2026-89521						In the Linux kernel, the following vulnerability has been resolved: sched/core: Handle pick_task() releasing the rq lock Core scheduling's pick_next_task() breaks when a ->pick_task() implementation can release the rq lock. The selection state derived on entry is only valid while the lock is held continuously. Once a pick can drop the lock, an interleaving selection can invalidate all of it: the single-CPU fast ...
CVE-2026-89522						In the Linux kernel, the following vulnerability has been resolved: media: staging/ipu7: fix async notifier UAF on probe error path isys_register_devices() registers the V4L2 async notifier via isys_notifier_init(). If a subsequent probe step such as isys_fw_log_init() fails, isys_probe() jumps to the out_cleanup label which only calls isys_unregister_devices(). That helper tears down the video devices, subdevic...
CVE-2026-89523						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7925: cancel pending mlo_pm_work If the device is reset, suspended or unregistered within that window, the pending work can still run and access vif/bss data that may already be freed, or send MCU commands while the firmware is not available. Add cancel_delayed_work_sync(&dev->mlo_pm_work) in all relevant teardown and suspend path...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89524						In the Linux kernel, the following vulnerability has been resolved: wifi: ath6kl: clamp assoc request/response lengths before subtracting IE offsets ath6kl_cfg80211_connect_event() subtracts fixed IE offsets from assoc_req_len (-= 4) and assoc_resp_len (-= 6), both u8, with no lower bound. The aggregate check recently added to ath6kl_wmi_connect_event_rx() bounds the declared lengths from above (their sum must f...
CVE-2026-89525						In the Linux kernel, the following vulnerability has been resolved: udf: reject VAT indexes equal to the entry count UDF 1.50 virtual partition mapping uses the VAT as an array of physical block mappings. s_num_entries stores the number of entries in that array, not the highest valid index. The valid VAT indexes are therefore below s_num_entries. udf_get_pblock_virt15() currently rejects only indexes greater th...
CVE-2026-89526						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Validate Read chunk positions before reconstruction The RPC/RDMA Read chunk position field is supplied by the remote client and stored verbatim in the parsed chunk list. xdr_count_read_segments() checks only 4-byte alignment; it never compares the position against the received inline body length. In the single-chunk path, svc_rdma_read...
CVE-2026-89527						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Use svc_xprt_put to free listener on create failure svc_rdma_create() calls kfree(cma_xprt) when svc_rdma_create_listen_id() fails. svc_xprt_init() has already acquired a net namespace reference via get_net_track(); kfree bypasses svc_xprt_free() which releases it. Replace the kfree() with svc_xprt_put() so the kref_init birth referenc...
CVE-2026-89528						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Reject Read lists that exceed the page budget Individual Read segment lengths are validated at decode time, but nothing prevents a requester from sending multiple segments whose cumulative length exceeds the rq_pages array budget. When one segment fills the page array exactly, the runtime guard in svc_rdma_build_read_segment() is bypass...
CVE-2026-89529						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Reject oversized Read segments at decode time The RPC/RDMA Read list decoder stores wire-supplied segment lengths without validation. xdr_count_read_segments() checks 4-byte alignment for non-zero position values but does not cap the segment length. An oversized rs_length reaches svc_rdma_build_read_segment(), which derives nr_bvec fro...
CVE-2026-89530						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Reject inline replies that overflow the pull-up buffer An RPC-over-RDMA client can request a reply, such as an NFS READ payload, without providing a Write list or a Reply chunk to carry it. When such a reply needs more scatter/gather entries than the device's Send Queue supports, svc_rdma_pull_up_needed() selects pull-up and svc_rdma_pu...
CVE-2026-89531						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Reject connection when transport allocation fails handle_connect_req() returns without action when svc_rdma_create_xprt() fails to allocate the new transport. The CM core returns 0 for CONNECT_REQUEST events, so it does not destroy the new rdma_cm_id. Each allocation failure under memory pressure leaks one rdma_cm_id, and a remote peer ...
CVE-2026-89532						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix pcl_for_each_segment for empty chunks When a parsed chunk list contains a chunk whose ch_segcount is zero, pcl_for_each_segment computes its inclusive upper bound as &chunk->ch_segments[ch_segcount - 1]. ch_segcount is u32, so the subtraction wraps to 0xFFFFFFFF and the bound lands far past the ch_segments flex array. The loop body ...
CVE-2026-89533						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix offset arithmetic in read_chunk_range svc_rdma_read_chunk_range() walks a Read chunk's segment list to build a sub-range starting at byte offset and spanning length bytes for a Position-Zero or Call chunk. Two arithmetic defects in the per-segment loop produce wrong DMA lengths and a u32 underflow: pcl_for_each_segment(segment,...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89534						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Clear sc_cm_id when ADDR_CHANGE replacement fails When svc_rdma_listen_handler() handles RDMA_CM_EVENT_ADDR_CHANGE, it creates a replacement listener cm_id and returns 1, telling the CM core to destroy the old one. If the replacement allocation fails, sc_cm_id still points at the old cm_id that the CM core is about to destroy. Any subse...
CVE-2026-89535						In the Linux kernel, the following vulnerability has been resolved: svcrdma: Reorder rpcrdma_rn_unregister before rdma_destroy_id svc_rdma_free() caches rdma->sc_cm_id->device before teardown, then calls rdma_destroy_id(sc_cm_id) which frees the cm_id. rpcrdma_rn_unregister() follows, but between those two calls the transport's sc_rn entry is still installed in the device's rd_xa. A concurrent ib_unregister_devi...
CVE-2026-89536						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: wait for in-flight client TLS handshake callback xs_tls_handshake_sync() gives xs_tls_handshake_done() a reference to the lower transport before submitting the handshake request. On timeout or signal, the synchronous waiter drops that reference after calling tls_handshake_cancel(). handshake_req_cancel() returns false when handshake_com...
CVE-2026-89537						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Reject short RFC 4121 MIC tokens in gss_krb5_verify_mic_v2 gss_krb5_verify_mic_v2() reads the token ID at ptr[0..1], the flags byte at ptr[2], and padding at ptr[3..7], then passes ptr + GSS_KRB5_TOK_HDR_LEN and cksum_len to gss_krb5_mic_build_sg(). None of these accesses check read_token->len first. The minimum safe token size is GSS_K...
CVE-2026-89538						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Reject krb5 v2 wrap tokens with oversized ec field gss_krb5_unwrap_v2() sets buf->len to a logical length, which can be much smaller than head[0].iov_len (the allocated receive-page capacity). It then calls xdr_buf_trim() with a trim length derived from the 16-bit "extra count" (ec) field in the Kerberos v2 token header. The ec field i...
CVE-2026-89539						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: reject duplicate CREDSD_VALUE options gssx_dec_option_array() walks the wire-supplied option array and, for every entry whose name matches CREDSD_VALUE, calls gssx_dec_linux_creds() on the same struct svc_cred. That helper unconditionally installs a fresh groups_alloc() result into creds->cr_group_info without releasing whatever pointer wa...
CVE-2026-89540						In the Linux kernel, the following vulnerability has been resolved: sunrpc: init gssp_lock before publishing proc entry create_use_gss_proxy_proc_entry() publishes /proc/net/rpc/use-gss-proxy via proc_create_data() before init_gssp_clnt() runs mutex_init() on sn->gssp_lock. Once the dentry is linked under proc_subdir_lock it is immediately reachable from userspace, so a write that lands in the window drives set...
CVE-2026-89541						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: harden gss_unwrap_resp_priv length checks gss_unwrap_resp_priv() validates the RPCSEC_GSS opaque length with offset = (u8 *) (p) - (u8 *) head->iov_base; if (offset + opaque_len > rcv_buf->len) goto unwrap_failed; maj_stat = gss_unwrap(ctx->gc_gss_ctx, offset, offset + opaque_len, rcv_buf)...
CVE-2026-89542						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: harden gss_krb5_unwrap_v2 against short tokens gss_krb5_unwrap_v2() reads the EC and RRC header fields at ptr+4 and ptr+6 before validating that the token is at least GSS_KRB5_TOK_HDR_LEN (16) bytes long, and its rotate_left() helper passes buf->len - base to xdr_buf_subsegment() without verifying that base <= buf->len. When a caller han...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89543						In the Linux kernel, the following vulnerability has been resolved: sunrpc: fix use-after-free in __rpc_clnt_handle_event and __rpc_clnt_remove_pipedir Normal client creation goes through rpc_setup_pipedir(), which records clnt->pipefs_sb, but the mount-event path in __rpc_clnt_handle_event() calls rpc_setup_pipedir_sb() directly and never refreshes that field. The umount path also removes the directory without ...
CVE-2026-89544						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: fix gssx_dec_option_array error path bugs Four coupled defects in the gssx XDR option-array decoder make the error paths unsafe: a NULL deref in the caller, a refcount leak on the decoded group_info, and a latent use-after-free that the leak fix would otherwise expose. gssx_dec_option_array() sets oa->count = 1 before allocating oa->dat...
CVE-2026-89545						In the Linux kernel, the following vulnerability has been resolved: sunrpc: defer rq_argp and rq_resp free until after RCU grace period svc_rqst_free() frees rqstp->rq_argp and rqstp->rq_resp synchronously via kfree(), but defers the rqstp struct free via kfree_rcu(). After svc_exit_thread() calls list_del_rcu() and svc_rqst_free(), there is a window where RCU readers that started before list_del_rcu() can stil...
CVE-2026-89546						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: close backchannel before destroying callback service A backchannel receive can complete a request while the NFS callback service is being torn down. xprt_complete_bc_request() removes the request from bc_pa_list, drops bc_alloc_count, marks the request in use, and then asks xprt_enqueue_bc_request() to hand it to the callback service. ...
CVE-2026-89547						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Check svc pool percpu counter allocation __svc_create() initializes three per-pool percpu_counter stats and ignores every return value. On SMP, percpu_counter_init() fails when __alloc_percpu_gfp() cannot satisfy the allocation, leaving the failed counter with fbc->counters == NULL and its embedded raw_spinlock_t, list_head, and count ne...
CVE-2026-89548						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: always drain cache_cleaner before destroying a cache_detail sunrpc_destroy_cache_detail() only cancels the global cache_cleaner delayed_work when cache_list is empty. During per-netns teardown cache_list is never empty because init_net's caches remain registered, so the cancel never fires. After unlink, the caller proceeds to cache_des...
CVE-2026-89549						In the Linux kernel, the following vulnerability has been resolved: sunrpc: route to a populated pool in svc_pool_for_cpu() svc_set_num_threads() spreads the requested threads evenly across the service's pools (base = nrservs / sv_nrpoools). When a service runs fewer threads than it has pools -- e.g. an nfsd configured with fewer threads than the host has NUMA nodes while running in "pernode" or "percpu" mode --...
CVE-2026-89550						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: svcauth_gss: enforce krb5 token minimum length svcauth_gss_unwrap_priv() validates only an upper bound on the wire-supplied opaque length before handing the buffer to gss_unwrap(): if (len > xdr_stream_remaining(xdr)) goto unwrap_failed; offset = xdr_stream_pos(xdr); ... maj_stat = gss_unwrap(ctx, offset, off...
CVE-2026-89551						In the Linux kernel, the following vulnerability has been resolved: SUNRPC: xdr_buf_trim: clamp buf->len to avoid underflow xdr_buf_trim() trims `len` bytes from the tail of an xdr_buf by walking the tail, pages, and head iovecs. Each per-section step uses min_t() so it never removes more bytes than that section holds, but the final accounting at the fix_len label subtracts the total bytes actually consumed fro...
CVE-2026-89552						In the Linux kernel, the following vulnerability has been resolved: params: fix charp corruption on allocation failure param_set_charp() stores charp parameters in allocated memory after slab is available, and releases the previous value when the parameter is updated. The previous value is released before the replacement allocation succeeds. If kmalloc_parameter() fails, the setter returns -ENOMEM with the para...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89553						In the Linux kernel, the following vulnerability has been resolved: nouveau/gem: reserve the bo in the info ioctl around the vma lookup In the non-uvmm path, there could be a race between the info lookup finding the vma, and the gem close path closing the vma leading to a use-after-free. Spotted with the help of Opus 4.6.
CVE-2026-89554						In the Linux kernel, the following vulnerability has been resolved: mptcp: fix uninitialized local_id in synccookie MP_JOIN reconstruction mptcp_token_join_cookie_init_state() restores remote_nonce, local_nonce, backup, join_id, token and msk from the saved cookie entry when rebuilding the request socket for a MP_JOIN 4th-ACK handled under SYN cookies, but it does not restore local_id, even though the SYN path sa...
CVE-2026-89555						In the Linux kernel, the following vulnerability has been resolved: mpls: reload header after pskb_may_pull() mpls_select_multipath() calls mpls_multipath_hash() to choose a nexthop when an MPLS route has multiple nexthops. While walking the MPLS label stack, the hash routine caches hdr for the current label. After finding the bottom-of-stack label, it calls pskb_may_pull() before reading the inner IP header. ...
CVE-2026-89556						In the Linux kernel, the following vulnerability has been resolved: module: validate string table section types In elf_validity_cache_sechdrs, section sizes and offsets are validated, unless the section type is SHT_NULL or SHT_NOBITS. Later, elf_validity_cache_secstrings and elf_validity_cache_index_str access the section name table (.shstrtab) and symbol string table (.strtab) headers without first ensuring th...
CVE-2026-89557						In the Linux kernel, the following vulnerability has been resolved: md: do overflow check for sb->bblog_shift in super_1_load() In super_1_load(), sb->bblog_shift is an __u8 type value loaded from on- disk superblock. It is used for badblocks API badblocks_set() by the following sequence, 1930 rdev->badblocks.shift = sb->bblog_shift; 1931 for (i = 0 ; i < (sectors << (9-3)) ; i++, bbp++) { 1932 ...
CVE-2026-89558						In the Linux kernel, the following vulnerability has been resolved: md/raid10: fix still_degraded being inverted in raid10_sync_request() Commit fe6a19d40ceb ("md/md-bitmap: merge md_bitmap_start_sync() into bitmap_operations") converted still_degraded from int to bool, but inverted the assignment in the loop that checks whether the array will still be degraded after the current device is recovered: "still_degra...
CVE-2026-89559						In the Linux kernel, the following vulnerability has been resolved: libnvdimm/labels: Prevent integer overflow in __nd_label_validate() The on-media namespace index field nslot is a u32 read from the DIMM label storage area. __nd_label_validate() bounds it against the config area size, but sizeof_namespace_label() returns unsigned, so the product nslot * label_size is evaluated in 32-bit and wraps modulo 2^32 b...
CVE-2026-89560						In the Linux kernel, the following vulnerability has been resolved: landlock: Require LANDLOCK_ACCESS_FS_MAKE_REG for whiteout creation Whiteout objects are used in the upper layer of an OverlayFS to indicate that the file with this name does not exist in the unified view, even if it is present in one of the lower layer file systems. For the userspace implementations of OverlayFS (fuse-overlayfs), whiteout obje...
CVE-2026-89561						In the Linux kernel, the following vulnerability has been resolved: ipv6: rpl: fix NULL dereference of idev in ipv6_rpl_srh_rcv() ipv6_rpl_srh_rcv() dereferences idev from __in6_dev_get() without a NULL check when reading idev->cnf.rpl_seg_enabled. When the device's MTU drops below IPV6_MIN_MTU, addrconf_ifdown() clears dev->ip6_ptr through RCU_INIT_POINTER(). A packet that passed the idev check in ip6_rcv_core...
CVE-2026-89562						In the Linux kernel, the following vulnerability has been resolved: ip6_gre: fix hardware header length for NBMA tunnels ip6gre_tnl_link_config_route() accumulates the lower device's hardware header length into dev->hard_header_len whenever header_ops is set. This is incorrect for both users of header_ops. ip6gretap and ip6erspan have a fixed Ethernet hardware header length. For an NBMA ip6gre tunnel, ip6gre_he...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89563						In the Linux kernel, the following vulnerability has been resolved: ip6_tunnel: use skb_cow_head() in ip6_tnl_xmit() ip6_tnl_xmit() may need to expand headroom before it can push the outer IPv6 and optional encap headers. It currently does that with skb_realloc_headroom(), copies skb->sk ownership, consumes the original skb, and then continues processing with the replacement skb kept only in its local variable. ...
CVE-2026-89564						In the Linux kernel, the following vulnerability has been resolved: ip: orphan prefetched skbs before multicast forwarding IPv4 and IPv6 input preserve an skb->sk association installed by bpf_sk_assign() so that local delivery can use the selected socket under RCU. Both address families can also prefetch a socket in UDP early demux. In both paths (BPF and UDP early demux) a reference is not guaranteed to be held...
CVE-2026-89565						In the Linux kernel, the following vulnerability has been resolved: ipip: fix skb leak in collect_md mode when metadata_dst allocation fails In collect_md mode ipip_tunnel_rcv() returns 0 without freeing the skb when ip_tun_rx_dst() fails to allocate the metadata_dst. ipip_rcv() and mplsip_rcv() are registered as xfrm_tunnel handlers, so tunnel4_rcv() and tunnelmpls4_rcv() read the zero return as "the packet has..."
CVE-2026-89566						In the Linux kernel, the following vulnerability has been resolved: jbd2: check need_resched() when skipping busy checkpoint buffers journal_shrink_one_cp_list() skips busy checkpoint buffers when called with JBD2_SHRINK_BUSY_SKIP. The continue statement on this path also skips the need_resched() check at the end of the loop body. Consequently, when a checkpoint list contains mostly busy buffers, the shrinker ...
CVE-2026-89567						In the Linux kernel, the following vulnerability has been resolved: jbd2: bound shrinker scans by examined checkpoint buffers The jbd2 shrinker currently accounts only checkpoint buffers that it successfully releases against nr_to_scan. Busy buffers therefore do not consume the scan budget. If a checkpoint transaction contains mostly busy buffers, the shrinker can scan its entire checkpoint list while holding ...
CVE-2026-89568						In the Linux kernel, the following vulnerability has been resolved: kho: fix size calculation in kho_preserved_memory_reserve() kho_preserved_memory_reserve() calculates the size of a preservation by doing 1 << (order + PAGE_SHIFT). Since the '1' is a 32-bit integer, it can only be shifted by 31. That is, it will only work for preservations up to 2 GiB. Larger preservations will trigger undefined behaviour. Whi...
CVE-2026-89569						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: RFCOMM: serialize security confirmation handling rfcomm_security_cfm() looks up a session on session_list and then walks its DLC list without holding rfcomm_mutex. Since RFCOMM session teardown uses rfcomm_mutex, krfcommd can close and free the same session and DLCs concurrently: hci_rx_work krfcommd -----...
CVE-2026-89570						In the Linux kernel, the following vulnerability has been resolved: cxl/mce: Make the MCE notifier per-region Flavien Solt reported lifetime issues with the CXL MCE notifier, which can lead to NULL dereferences and use-after-free in the MCE handler. The notifier was registered per memory device and stored in 'struct cxl_memdev_state', even though it only needs the region state (the region's SPA range and its ext...
CVE-2026-89571						In the Linux kernel, the following vulnerability has been resolved: cxl/features: bound fwctl command payload to the input buffer fwctl_cmd_rpc() copies cmd->in_len bytes into inbuf = kzalloc(cmd->in_len) and passes inbuf and in_len to ->fw_rpc(). The CXL callback cxlctl_fw_rpc() ignores in_len and never checks the user-controlled op_size against it. cxlctl_set_feature() bounds op_size only from below (op_size...
CVE-2026-89572						In the Linux kernel, the following vulnerability has been resolved: cpufreq: apple-soc: Fix OPP table cleanup apple_soc_cpufreq_init() adds OPP tables from firmware, but some failure paths do not remove them. The driver also uses dev_pm_opp_remove_all_dynamic(), which is not the right cleanup helper for OPP tables loaded from firmware. Use the cpumask OPP helper after the policy CPU mask has been populated. Pai...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89573						In the Linux kernel, the following vulnerability has been resolved: dm array: reject an array block whose value size is not the caller's array_block_check() can only compare the header against itself, so a block with value_size 4 and max_entries 1018 is internally consistent and passes. dm-cache keeps two arrays -- mappings at 8 bytes and hints at 4 -- and the roots for both live in the superblock. Point the map...
CVE-2026-89574						In the Linux kernel, the following vulnerability has been resolved: dm array: validate array block headers on read array_block_check() validates blocknr and csum and nothing else, while node_check(), next to it, has bounded the structural fields since both were written. dm_array_cursor_next() takes its loop bound from the on-disk nr_entries and element_at() is unguarded pointer arithmetic, so a count larger than...
CVE-2026-89575						In the Linux kernel, the following vulnerability has been resolved: dm raid1: reserve space for NUL-terminator in build_constructor_string() Reserve space for the termination NUL after the maximum 20 decimal digits of a long long value to avoid buffer overflow in sprintf().
CVE-2026-89576						In the Linux kernel, the following vulnerability has been resolved: dm-era: fix shadowed superblock leak on take-snap failure metadata_take_snap() bumps the live superblock refcount and then dm_tm_shadow_block() allocates a new block for the metadata snapshot. If the subsequent dm_sm_inc_block() of writeset_tree_root or era_array_root fails, the function only unlocks the clone and returns. The newly allocated s...
CVE-2026-89577						In the Linux kernel, the following vulnerability has been resolved: dm-io: report non-retryable errors separately The error codes BLK_STS_NOTSUPP and BLK_STS_INVALID should not cause leg failure on dm-raid1. This patch changes the interface to dm-io, so that it reports two error bitmaps - error_bits and unsup_bits. The unsup_bit bitmap tracks BLK_STS_NOTSUPP or BLK_STS_INVALID errors, the error_bits bitmap tracks a...
CVE-2026-89578						In the Linux kernel, the following vulnerability has been resolved: dm-io: clone the source bio instead of copying its biovec For DM_IO_BIO requests, do_region() built each destination bio by walking the source bio's biovec and re-adding the pages one at a time, tracking the remaining transfer in sectors. The vector lengths are byte granular and need not be sector aligned (e.g. a misaligned O_DIRECT buffer split...
CVE-2026-89579						In the Linux kernel, the following vulnerability has been resolved: bpf: Harden bloom filter sizing and indexing on 32-bit kernels bloom_map_alloc() has two 32-bit-specific problems when the computed bitmap reaches the U32_MAX fallback case. First, BITS_TO_BYTES(U32_MAX) is evaluated with 32-bit arithmetic. The addition performed by DIV_ROUND_UP wraps, so the map allocates only the fixed-size bloom filter objec...
CVE-2026-89580						In the Linux kernel, the following vulnerability has been resolved: bpf: Disable preemption in __bpf_get_stack get_perf_callchain() returns a per-CPU perf_callchain_entry buffer and releases its recursion slot via put_callchain_entry() before returning, so nothing keeps the entry reserved while __bpf_get_stack() consumes it below. A preemptible BPF program (e.g. a non-sleepable raw tracepoint program on a PREEM...
CVE-2026-89581						In the Linux kernel, the following vulnerability has been resolved: bpf, x86: Fix per-CPU address resolution into an extended register The destination of the per-CPU address MOV is encoded in ModRM.reg, which is extended by REX.R, but the REX prefix is built with add_1mod(), which sets REX.B. REX.B extends ModRM.rm and SIB.base, and this instruction addresses memory as disp32 with no base, so the bit has no effe...
CVE-2026-89582						In the Linux kernel, the following vulnerability has been resolved: bnx2x: fix double free in bnx2x_init_firmware() error path bnx2x_init_firmware() frees bp->init_ops, bp->init_data and bp->init_ops_offsets in its error path without setting them to NULL. The cleanup function bnx2x_release_firmware() frees the same three pointers unconditionally, so if init_firmware fails and release_firmware is later called (e....
CVE-2026-89583						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: eir: Fix OOB read in eir_get_service_data() eir_get_service_data() walks the advertising data for a Service Data field with a matching UUID. On a mismatch it advances: eir += dlen; eir_len -= dlen; eir_get_data() reports dlen as the field's data length, but the field spans dlen + 2 bytes once its length and type bytes count...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89584						In the Linux kernel, the following vulnerability has been resolved: block: validate user space vectors during extraction The bio-based drivers don't necessarily check the alignment split, and stacking block drivers don't always handle a misalignment detected after submitting the bio. Validate user vectors against the device's dma_alignment as the bio is built from the iov_iter, rejecting misaligned early with -E...
CVE-2026-89585						In the Linux kernel, the following vulnerability has been resolved: auxdisplay: charlcd: cancel backlight work on registration failure With CONFIG_CHARLCD_BL_FLASH, charlcd_init() schedules bl_work before charlcd_register() calls misc_register(). If registration fails, the caller frees the charlcd object while delayed work still contains its address. Add charlcd_deinit() to cancel the delayed work and turn the ...
CVE-2026-89586						In the Linux kernel, the following vulnerability has been resolved: ata: libata-scsi: fix DSM TRIM for sector sizes larger than 2048 bytes ata_scsi_write_same_xlat() translates a SCSI WRITE SAME command with the UNMAP bit set into an ATA DATA SET MANAGEMENT TRIM command. The TRIM descriptor is built by ata_format_dsm_trim_descr() into the 2048-byte ata_scsi_rbuf staging buffer, and the number of bytes copied is...
CVE-2026-89587						In the Linux kernel, the following vulnerability has been resolved: ACPI: pfr_update: fix stack buffer overflow in query_capability() query_capability() copies four ACPI buffer objects returned by the firmware _DSM into fixed-size u8[16] fields in struct pfru_update_cap_info using memcpy with the firmware-supplied length: memcpy(&cap_hdr->code_type, elements[CAP_CODE_TYPE_IDX].buffer.pointer, ...
CVE-2026-89588						In the Linux kernel, the following vulnerability has been resolved: ACPI: APEI: GHES: fix ARM section length accounting after header In ghes_handle_arm_hw_error(), after skipping the cper_sec_proc_arm header with (err + 1), the remaining length was reduced by sizeof(err) (pointer size) instead of sizeof(*err) (structure size). That overestimates the bytes left for cper_arm_err_info records and can let the parse...
CVE-2026-89589						In the Linux kernel, the following vulnerability has been resolved: acpi/apei/ghes: Use raw_spinlock_t for CXL CPER work locks The CXL CPER work registration and unregistration helpers acquire cxl_cper_work_lock and cxl_cper_prot_err_work_lock with a spinlock guard(), which leaves local interrupts enabled. The corresponding post paths (cxl_cper_post_event(), cxl_cper_post_prot_err()) execute in hard IRQ context ...
CVE-2026-89590						In the Linux kernel, the following vulnerability has been resolved: accel/rocket: Fix error path handling in rocket_job_run() In rocket_job_run(), after taking an extra fence reference for job->done_fence via dma_fence_get(), the error paths have three bugs: - The dma_fence reference held by job->done_fence is never released, causing a reference leak. - pm_runtime_get_sync() increments the usage counter even ...
CVE-2026-89591						In the Linux kernel, the following vulnerability has been resolved: accel/rocket: initialize job domain before cleanup paths rocket_ioctl_submit_job() releases rjob through rocket_job_put() on allocation error paths. rocket_job_cleanup() unconditionally calls rocket_iommu_domain_put(job->domain), but job->domain is assigned only after task copying and BO lookups. A failure before that assignment can therefore cl...
CVE-2026-89592						In the Linux kernel, the following vulnerability has been resolved: accel/rocket: fix NULL dereference and integer overflow in rocket_job_push() rocket_job_push() allocates a temporary array to hold all input and output GEM object pointers: bos = kvmalloc_array(job->in_bo_count + job->out_bo_count, sizeof(void *), GFP_KERNEL); memcpy(bos, job->in_bos, job->in_bo_count * sizeof(v...
CVE-2026-89593						In the Linux kernel, the following vulnerability has been resolved: hugetlb: only adjust reservation during unmapping if mapcount is 0 Since df7a6d1f6405, __unmap_hugepage_range can adjust reservations. In the case of folio mapped in both a parent and a child, if the parent unmaps the range first, the reservation adjustment will result in an underflow of the reserved count. Once the child unmaps the range, the...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89594						In the Linux kernel, the following vulnerability has been resolved: hsi: omap_ssi_core: fix missing DMA mask setup for SSI controller device The OMAP SSI driver uses a synthetic HSI controller device allocated via hsi_alloc_controller(), which does not go through the normal OF/platform device initialization path. As a result, the embedded struct device does not have a DMA mask initialized by default. After rec...
CVE-2026-89595						In the Linux kernel, the following vulnerability has been resolved: fsnotify: Fix stale object mask after concurrent mark updates When a mark gets a new event bit, fanotify and inotify may avoid recalculating the object mask if the cached aggregate already contains that bit. This is racy with a recalculation triggered by a concurrent update to another mark on the same connector. The concurrent scan can read the...
CVE-2026-89596						In the Linux kernel, the following vulnerability has been resolved: forcedeth: fix off-by-one when saving/restoring non-PCI config space nv_suspend() and nv_resume() walk the non-PCI configuration space with for (i = 0; i <= np->register_size/sizeof(u32); i++) which runs one iteration too many. saved_config_space is declared as u32 saved_config_space[NV_PCI_REGSZ_MAX/4]; and NV_PCI_REGSZ_VER3 is equal to N...
CVE-2026-89597						In the Linux kernel, the following vulnerability has been resolved: fbdev: uvesafb: unregister connector callback on init failure uvesafb_init() registers the v86d connector callback before registering the platform driver. If platform_driver_register() fails, the function returns the error directly and leaves the connector callback registered. The later platform-device failure path already unregisters the callb...
CVE-2026-89598						In the Linux kernel, the following vulnerability has been resolved: fbdev: ssd1307fb: defer I2C transfers from damage callbacks The fbdev damage callbacks may run from fbcon while printk has disabled preemption. They currently update the display synchronously, which enters the sleeping I2C transfer path from atomic context. A complete report from an RK3566 system follows: [258.129004] watchdog: watchdog0:...
CVE-2026-89599						In the Linux kernel, the following vulnerability has been resolved: fbdev: omapfb: panel-dsi-cm: initialize lock before registering display dsicm_probe() registers the display before initializing ddata->lock. Once omapdss_register_display() publishes the display, another consumer can reach a dsicm callback that takes this mutex while it is still uninitialized. Initialize the mutex before registering the display...
CVE-2026-89600						In the Linux kernel, the following vulnerability has been resolved: fanotify: fix use-after-free of file range info fsnotify_pre_content() builds its file_range on the triggering task's stack. fanotify_alloc_perm_event() saves a pointer to range.pos in the heap-allocated permission event so copy_range_info_to_user() can report the offset later. The event reader can set the event state to FAN_EVENT_REPORTED and ...
CVE-2026-89601						In the Linux kernel, the following vulnerability has been resolved: ext2: Fix lost inode updates for IS_SYNC inodes ext2_setsize() and ext2_xattr_set2() had a construct like: if (IS_SYNC(inode)) { sync_inode_metadata(inode, 1); } else { mark_inode_dirty(inode); } which leads to lost inode updates for IS_SYNC inodes because sync_inode_metadata() does anything only if the inode is already dirty and hence ...
CVE-2026-89602						In the Linux kernel, the following vulnerability has been resolved: erofs: skip sufficiently large global buffers when resizing z_erofs_gbuf_npages is advanced only after every global buffer has been grown. If a resize fails after some buffers were enlarged, a retry revisits those enlarged buffers. Retrying the same size then returns -ENOMEM because alloc_pages_bulk() has no pages to add and the unchanged retu...
CVE-2026-89603						In the Linux kernel, the following vulnerability has been resolved: entry: Fix seccomp bypass after ptrace with TSYNC Sashiko review pointed out the following issue. If a thread is stopped in syscall_trace_enter() for ptrace, another thread can install a seccomp filter with SECCOMP_FILTER_FLAG_TSYNC (e.g., via seccomp_attach_filter()). This will successfully set SYSCALL_WORK_SECCOMP on the stopped thread, but s...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89604						In the Linux kernel, the following vulnerability has been resolved: efivarfs: Rate limit statfs() handler Ravi reports that statfs() may be called by unprivileged users on the efivarfs mount point, which may result in a flood of calls to the QueryVariableInfo() runtime service. These calls are disproportionately costly on x86 systems where the variable store is backed by SMM, as each SMM entry requires a rendez-...
CVE-2026-89605						In the Linux kernel, the following vulnerability has been resolved: ecryptfs: release message context on send failure ecryptfs_send_message_locked() moves a message context from the free list to the allocated list before sending the request to the userspace daemon. If ecryptfs_send_miscdev() fails, the context is left on the allocated list and cannot be reused. Move it back to the free list on failure and clear...
CVE-2026-89606						In the Linux kernel, the following vulnerability has been resolved: ecryptfs: reject too-small tag 70 packets ecryptfs_parse_tag_70_packet() subtracts fixed metadata fields from the parsed packet body size to derive the encrypted filename size. A malformed packet with a body smaller than those fixed fields can underflow that size calculation. Reject tag 70 packets before the subtraction unless the body contain...
CVE-2026-89607						In the Linux kernel, the following vulnerability has been resolved: ecryptfs: reject oversized encrypted_key_size in parse_tag_3_packet parse_tag_3_packet() set encrypted_key_size from the Tag 3 packet body without bounding it against ECRYPTFS_MAX_KEY_BYTES (64). When encrypted_key_size > 64, decrypt_passphrase_encrypted_session_key() sets decrypted_key_size = encrypted_key_size and performs two out-of-bounds wr...
CVE-2026-89608						In the Linux kernel, the following vulnerability has been resolved: ecryptfs: pass packet set buffer size to parser ecryptfs_parse_packet_set() receives a pointer into the file header, but it calculates the remaining packet buffer size from PAGE_SIZE - 8. For version 1 headers the packet set starts later in the header, so this can overstate the available buffer. Pass the actual packet set buffer length from th...
CVE-2026-89609						In the Linux kernel, the following vulnerability has been resolved: ecryptfs: hold msg ctx list lock when cleaning daemon queue ecryptfs_exorcise_daemon() drops queued messages from a dying daemon without holding ecryptfs_msg_ctx_lists_mux, but ecryptfs_msg_ctx_alloc_to_free() requires that lock. Take the list lock while moving the queued contexts back to the free list to avoid racing with other global msg ctx ...
CVE-2026-89610						In the Linux kernel, the following vulnerability has been resolved: ntfs: verify run length exceeding volume boundary The mapping pairs decoder validates that the starting LCN is within the volume but does not check if the run extends beyond the volume boundary. A malformed NTFS image with a crafted mapping pairs array could cause the kernel to access memory beyond the volume boundary, potentially leading to me...
CVE-2026-89611						In the Linux kernel, the following vulnerability has been resolved: ntfs: validate non-resident attribute offsets ntfs_attr_update_meta() shifts the attribute name when converting between non-sparse and sparse attributes. Converting to sparse also adds the compressed_size field before the name and mapping pairs, requiring eight additional bytes in the attribute record. However, the validator does not check that...
CVE-2026-89612						In the Linux kernel, the following vulnerability has been resolved: ntfs: reject invalid MFT LCNs from boot sector The NTFS boot sector stores the MFT and MFTMirr locations as unsigned 64-bit LCNs, but parse_ntfs_boot_sector() decoded them into an s64. A crafted high-bit value could therefore become negative and pass the existing upper-bound check. The invalid value then propagated into the MFT zone allocator a...
CVE-2026-89613						In the Linux kernel, the following vulnerability has been resolved: ntfs: reject invalid empty mapping pairs Reject an attribute with empty mapping pairs if it has inconsistent highest VCN and size.
CVE-2026-89614						In the Linux kernel, the following vulnerability has been resolved: ntfs: bound the free-cluster bitmap scan to the volume vol->lc_n_empty_bits_per_page is sized from vol->nr_clusters at mount, but ntfs_cluster_alloc() bounds its scan of that array by the size of \$Bitmap. Those are independent on-disk quantities and the mount-time check only rejects a \$Bitmap that is too small, so an image whose \$Bitmap covers mo...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89615						In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: bound page_lcons[] index by the log record The copy_lcons loop and the redo shorten loop index page_lcons[] at j + i, where i runs up to the log record's lcons_follow. That count is checked only against the record's own length, not the target entry, so check_dp_table() (which validates the entry's lcons_follow) does not cover it: the copy_l...
CVE-2026-89616						In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: fix info-leak on partial LZNT decompress in ni_read_frame() ni_read_frame() decompresses an LZNT \$DATA frame into the vmapped target pages and then trusts decompress_lznt()'s return value: unc_size = decompress_lznt(frame_ondisk, ondisk_size, frame_mem, frame_size); if ((ssize_t)unc_size < 0) er...
CVE-2026-89617						In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: validate dirty page table on log replay Each DIR_PAGE_ENTRY ends in a page_lcons[] array whose length is the on-disk lcons_follow field. check_rstbl() validates the table bookkeeping but never checks that this array fits in the entry, so a crafted lcons_follow lets the v0->v1 conversion memmove and later replay passes run off the entry. ...
CVE-2026-89618						In the Linux kernel, the following vulnerability has been resolved: eventfs: Initialize ei->children and ei->list in init_ei() eventfs_create_dir() allocates the eventfs_inode and initializes it with init_ei(). But this does not initialize the eventfs_inode list_heads. If the eventfs_create_dir() fails due to memory pressure, it will call free_ei() before it initialized the lists, and that checks to make sure th...
CVE-2026-89619						In the Linux kernel, the following vulnerability has been resolved: HID: intel-thc-hid: intel-quickspi: bound GET_REPORT response to the caller buffer quickspi_hid_raw_request() receives the caller's buffer length in len, but quickspi_get_report() never sees it and copies the whole device-supplied response into buf regardless: memcpy(buf, qsdev->report_buf, qsdev->report_len); qsdev->report_len comes from ...
CVE-2026-89620						In the Linux kernel, the following vulnerability has been resolved: HID: intel-thc-hid: intel-quickspi: validate report size before copy write_cmd_to_txdma() builds an output report in qsdev->report_buf, a heap buffer allocated in quickspi_alloc_report_buf() to the device-descriptor derived max_report_len (a few hundred bytes for a touch controller). It copies the caller-supplied report into that buffer: m...
CVE-2026-89621						In the Linux kernel, the following vulnerability has been resolved: HID: mcp2221: validate report size in mcp2221_raw_event() mcp2221_raw_event() never validates the size of incoming HID reports. In the MCP2221_I2C_GET_DATA path it trusts the device-supplied data[3] as the copy length without checking that 4 + data[3] bytes actually exist in the received report. A malicious or misbehaving USB device can send a s...
CVE-2026-89622						In the Linux kernel, the following vulnerability has been resolved: HID: mcp2221: clear rxbuf after I2C/SMBus transfer completes mcp_i2c_smbus_read() stores the caller-supplied buffer pointer in mcp->rxbuf for the duration of a transfer but never clears it when the transfer finishes or times out. Once the caller frees or reuses the buffer, mcp->rxbuf becomes a dangling pointer. A delayed or spurious MCP2221_I2C_...
CVE-2026-89623						In the Linux kernel, the following vulnerability has been resolved: HID: mcp2221: stop device IO before hid_hw_stop Quiesce device IO at the start of the devm cleanup callback mcp2221_hid_unregister() so that incoming HID reports cannot race with hardware teardown during probe failure or device removal, addressing a potential use-after-free. Guard the call to hid_device_io_stop() with io_started. On normal remo...
CVE-2026-89624						In the Linux kernel, the following vulnerability has been resolved: HID: universal-pidff: stop the device when force-feedback init fails universal_pidff_probe() starts the device with hid_hw_start() and then, if force-feedback initialisation fails, returns the error through a label that only does "return error". The device is left started. The HID core does not unwind on the driver's behalf. __hid_device_prob...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89625						In the Linux kernel, the following vulnerability has been resolved: HID: sony: fix UAF of ghl_poke_timer / ghl_urb at driver unbind For GHL (Guitar Hero Live) dongles, sony_probe() arms a periodic timer: ghl_magic_poke() (the timer callback) submits sc->ghl_urb, and the URB completion ghl_magic_poke_cb() re-arms the timer with mod_timer(). sony_remove() drained the timer with timer_delete_sync() and then freed ...
CVE-2026-89626						In the Linux kernel, the following vulnerability has been resolved: HID: sensor: custom: Fix field sysfs group cleanup on failure hid_sensor_custom_add_attributes() creates one sysfs group for each custom sensor field. If sysfs_create_group() fails after some groups have already been created, the function returns the error without removing the previously created groups. Add a local unwind path to remove the gro...
CVE-2026-89627						In the Linux kernel, the following vulnerability has been resolved: HID: roccat: free buffered reports when destroying device roccat_report_event() duplicates each report with kmempdup() and stores the allocation in a circular-buffer slot. The allocation is released only when that slot is reused. The device destruction paths free struct roccat_device without releasing reports still stored in cbuff[]. This makes t...
CVE-2026-89628						In the Linux kernel, the following vulnerability has been resolved: HID: picolcd: clamp eeprom debugfs read to bytes actually received picolcd_debug_eeprom_read() trusts resp->raw_data[2] -- a length byte supplied by the device in its REPORT_EE_DATA reply -- clamped only to the caller's read() count: ret = resp->raw_data[2]; if (ret > s) ret = s; if (copy_to_user(u, resp->raw_data+3, ret)) It never checks...
CVE-2026-89629						In the Linux kernel, the following vulnerability has been resolved: HID: corsair-void: Check size of status and firmware events before reading them Malformed status and firmware events could cause an out-of-bounds read since the size wasn't being checked. Check the size and warn on unexpected values to avoid this.
CVE-2026-89630						In the Linux kernel, the following vulnerability has been resolved: smb: client: restore the data_offset bound in is_valid_oplock_break() Commit 83bfbd0bb902 ("cifs: Remove the RFC1002 header from smb_hdr") changed the quantity this bound is measured against. It used to be srv->total_read minus the 4-byte RFC1002 preamble that total_read then included, so it was the SMB message length. The same commit stopped ...
CVE-2026-89631						In the Linux kernel, the following vulnerability has been resolved: smb: client: reject a tree connect response whose byte count is too small CIFSTCon() bounds its strlen() over the byte area with the server's ByteCount minus two, which for ByteCount 0 or 1 goes negative as an int and converts to a huge size_t. The later subtraction wraps the __u16 bytes_left, and that is what bounds cifs_strndup_from_utf16():...
CVE-2026-89632						In the Linux kernel, the following vulnerability has been resolved: smb: client: fix use-before-check of ReparseDataLength in reparse_buf_ptr() reparse_buf_ptr() reads buf->ReparseDataLength before checking that count covers the full fixed header: buf = (struct reparse_data_buffer *)((u8 *)io + off); len = sizeof(*buf); /* 8 bytes */ rrlen = le16_to_cpu(buf->ReparseDataLengt...
CVE-2026-89633						In the Linux kernel, the following vulnerability has been resolved: smb: client: fix OOB read/write from unvalidated DataOffset in coalesce_t2() coalesce_t2() computes data pointers directly from server-supplied DataOffset fields with no validation against buffer bounds: data_area_of_tgt = (char *)&pSMBt->hdr.Protocol + get_unaligned_le16(&pSMBt->t2_rsp.DataOffset); data_area_of_src = (...
CVE-2026-89634						In the Linux kernel, the following vulnerability has been resolved: smb: client: fix ALIGN() overflow in symlink_data() error context loop The check added by commit 7d9a7f1f96cd ("smb/client: fix possible infinite loop and oob read in symlink_data()") compared the post-ALIGN length against the remaining buffer, but ALIGN() itself can overflow: for ErrorDataLength near UINT32_MAX (e.g. 0xFFFFFFFF9), ALIGN(x, 8) wr...
CVE-2026-89635						In the Linux kernel, the following vulnerability has been resolved: ksmbd: only rebind the reopened file's own oplock on durable reconnect ksmbd_reopen_durable_fd() walks the inode's m_op_list and rebinds every detached oplock to the reconnecting session: list_for_each_entry_rcu(op, &ci->m_op_list, op_entry, lockdep_is_held(&ci->m_lock)) { if (op->conn) continue; op->conn = ksmbd_conn_get(fp->conn);...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89636						In the Linux kernel, the following vulnerability has been resolved: smb: client: clear ce->tgthint in free_tgts() When free_tgts() frees all structures in ce->tlist, ce->tgthint is left pointing to one of the freed cache_dfs_tgt structures. If ce->tgthint is not reset before it is used later, it results in a use-after-free. Set ce->tgthint to NULL in free_tgts() after the elements are freed to reflect that no ...
CVE-2026-89637						In the Linux kernel, the following vulnerability has been resolved: smb: client: fix UAF and buffer leak in cifs_check_trans2() for malformed secondary T2 When a valid primary TRANSACT2 response has been received (mid->resp_buf set, mid->multiRsp true) and a subsequent secondary response causes cifs_check_trans2() to return false -- either because the SMB header is invalid (malformed != 0) or because check2ndT2(...
CVE-2026-89638						In the Linux kernel, the following vulnerability has been resolved: smb: client: clear setuid/setgid bit on write with cifsacl/modefromsid/posix extensions When a file has the setuid or setgid bit set and is written to, the VFS strips those bits and issues a setattr with ATTR_KILL_SUID/ATTR_KILL_SGID together with an ATTR_MODE carrying the already-cleared mode. Both cifs_setattr_unix() and cifs_setattr_nounix()...
CVE-2026-89639						In the Linux kernel, the following vulnerability has been resolved: cifs: use cifs_invalidate_cache() in cifs_do_truncate() for O_TRUNC cifs_do_truncate() is invoked from cifs_open() without i_rwsem, so it cannot use cifs_resize_file_locked() to perform a proper fscache cookie resize. Instead, add cifs_invalidate_cache() after cifs_setsize(). cifs_invalidate_cache() calls fscache_invalidate(), which works with...
CVE-2026-89640						In the Linux kernel, the following vulnerability has been resolved: cifs: fix loff_t underflow in cifs_remap_file_range() when len == 0 With len == 0 (clone to EOF), the effective length is computed as: len = src_inode->i_size - off; If off > i_size, this is a negative loff_t, corrupting the ByteCount in the FSCTL_DUPLICATE_EXTENTS_TO_FILE request and inverting the range in filemap_write_and_wait_range(). ...
CVE-2026-89641						In the Linux kernel, the following vulnerability has been resolved: cifs: clear tcon after cifsFileInfo_put() in cifs_file_set_size() When the else branch of cifs_file_set_size() finds a writable file handle via find_writable_file(), it borrows tcon and server from the handle's tlink, attempts the handle-based set_file_size() RPC, and then releases the handle with cifsFileInfo_put(). If set_file_size() fails, e...
CVE-2026-89642						In the Linux kernel, the following vulnerability has been resolved: cifs: call pagecache_isize_extended() in cifs_setsize() when extending cifs_setsize() calls truncate_pagecache() but skips pagecache_isize_extended() on extension. truncate_setsize() shows the correct pattern: i_size_write(inode, newsize); if (newsize > oldsize) pagecache_isize_extended(inode, oldsize, newsize); truncate_pagecache(...
CVE-2026-89643						In the Linux kernel, the following vulnerability has been resolved: audit: avoid dropping live tree ref on fsnotify rule autoremove audit_del_rule() is used for both netlink deletion templates and internal fsnotify autoremove. The former passes a parsed template which owns a temporary tree reference; the latter passes the installed entry itself. The unconditional audit_put_tree() at the end of audit_del_rule()...
CVE-2026-89644						In the Linux kernel, the following vulnerability has been resolved: btrfs: fix extent map leak in NOCOW direct I/O write btrfs_dio_iomap_begin() calls btrfs_get_extent(), which returns an extent map reference that must be dropped on all exit paths. For direct writes into a NOCOW range, btrfs_get_blocks_direct_write() keeps using that extent map and asks btrfs_create_dio_extent() to allocate the ordered extent. ...
CVE-2026-89645						In the Linux kernel, the following vulnerability has been resolved: btrfs: drop recovered reloc root refs on recovery failure During relocation recovery, each fs root gets a reference to its relocation root. If loading or adding a later root fails, or if the first transaction commit fails, btrfs_recover_relocation() jumps to out_unset before merge_reloc_roots() and clean_dirty_subvols(). put_reloc_control() dro...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89646						In the Linux kernel, the following vulnerability has been resolved: ceph: fix leaked inode reference on writeback abort at umount ceph_dirty_folio() takes a wrbuffer claim on each newly dirtied folio: it bumps i_wrbuffer_ref (taking an ihold() on the 0->1 transition) and attaches the snap_context to folio->private. That claim is released only by ceph_put_wrbuffer_cap_refs(), which for a submitted write runs fro...
CVE-2026-89647						In the Linux kernel, the following vulnerability has been resolved: ceph: do not repeat ceph_trim_dentries() if no progress possible ceph_cap_reclaim_work() re-queues itself for as long as ceph_trim_dentries() returns -EAGAIN, which happens whenever a lease walk exhausts its `nr_to_scan` budget. This creates a busy loop that consumes CPU without making any progress when there is nothing to reclaim: with no cap ...
CVE-2026-89648						In the Linux kernel, the following vulnerability has been resolved: ceph: cap delegated inode count in ceph_parse_deleg_inos() ceph_parse_deleg_inos() decodes interval sets of delegated inode numbers from an MDS create-with-delegation reply. For each set it reads a 64-bit start and a 64-bit len with ceph_decode_64_safe(), which only validates that the eight bytes are present in the message, not the value, and th...
CVE-2026-89649						In the Linux kernel, the following vulnerability has been resolved: ceph: bound xattr value length in __build_xattrs() __build_xattrs() decodes the MDS-supplied xattr blob one attribute at a time. For each attribute it reads a 32-bit name length, advances past the name bytes, reads a 32-bit value length, records the value pointer, and advances past the value bytes. The two length fields are read with ceph_decode...
CVE-2026-89650						In the Linux kernel, the following vulnerability has been resolved: ceph: bound num_export_targets array for mds info v2/v3 ceph_mdsmmap_decode() in fs/ceph/mdsmmap.c reads num_export_targets from each per-mds info record and advances the decode cursor by num_export_targets * sizeof(u32) without first checking that many bytes remain. The only upper-bound check that catches a runaway cursor (*p > info_end) is gated...
CVE-2026-89651						In the Linux kernel, the following vulnerability has been resolved: ceph: bound MDSCapAuth path and fs_name decode in handle_session() handle_session() decodes the MDSCapAuth records carried by a CEPH_SESSION_OPEN message (msg_version >= 6). For each record the match.path and match.fs_name byte strings are read by first decoding a 32-bit length and then copying that many bytes with the bare ceph_decode_copy(). U...
CVE-2026-89652						In the Linux kernel, the following vulnerability has been resolved: ceph: bound copied dentry name length in NFS export get_name ceph_get_name() copies the MDS-supplied name into the caller's NAME_MAX-sized buffer with memcpy(name, rinfo->dname, rinfo->dname_len) and then writes name[rinfo->dname_len] = 0, without checking dname_len against NAME_MAX. A malicious or buggy MDS that returns a LOOKUPNAME reply with ...
CVE-2026-89653						In the Linux kernel, the following vulnerability has been resolved: ceph: reject export_targets ranks >= CEPH_MAX_MDS in mdsmmap decode MDSMap export_targets entries are monitor controlled. check_new_map() uses each entry as a bit number in a fixed stack bitmap, so a rank outside the protocol namespace can make set_bit() write past the end of the array. Reject ranks outside CEPH_MAX_MDS while decoding the map. D...
CVE-2026-89654						In the Linux kernel, the following vulnerability has been resolved: ceph: fix UAF in check_new_map() on session freed during unlock check_new_map() iterates mdsc->sessions[] and for each active session drops mdsc->mutex to perform per-session operations. The forced-close path (rank removed from map) correctly takes a reference on s via ceph_get_mds_session() before releasing mdsc->mutex, but three other paths d...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89655						In the Linux kernel, the following vulnerability has been resolved: ceph: fix UAF in __kick_flushing_caps() on cf entry freed during unlock list_for_each_entry() iterates ci->i_cap_flush_list but drops i_ceph_lock to send cap messages. During the unlock window, handle_cap_flush_ack() can acquire i_ceph_lock, detach cf entries with tid <= flush_tid from the list, release i_ceph_lock, and free them via ceph_free_...
CVE-2026-89656						In the Linux kernel, the following vulnerability has been resolved: libceph: reject buckets with mismatched CRUSH ids crush_decode() stores bucket data by array slot, and the mapper later derives the per-bucket workspace index from the decoded bucket id. A malformed map can therefore make one bucket reuse another bucket's workspace by encoding an id different from -1 - slot. For uniform buckets, the second repl...
CVE-2026-89657						In the Linux kernel, the following vulnerability has been resolved: libceph: validate OSD extent maps before cursor advance net/ceph/osd_client.c:osd_sparse_read() validates that the sparse-read data length matches the summed extent lengths, but it does not validate that each OSD-supplied extent is monotonic and lies inside the original request range. A malformed authenticated OSD reply can advertise a far-forwa...
CVE-2026-89658						In the Linux kernel, the following vulnerability has been resolved: NFSv4.0 revoked-state cleanup nfs40_clean_admin_revoked() takes a stateid reference under clp->cl_lock, drops nn->client_lock, and calls nfsd4_drop_revoked_stid(), which dereferences the stateid's client through s->sc_client->cl_lock. The stateid reference does not pin the client, so a teardown racing ...
CVE-2026-89659						In the Linux kernel, the following vulnerability has been resolved: NFSv4.0 delegation revoke A delegation stateid holds only a bare pointer to its owning nfs4_client and does not keep it alive. The client survives its stateids only because __destroy_client() drains cl_delegations and cl_revoked before free_client() runs. nfs4_laundromat() breaks that invariant: it unhashes a...
CVE-2026-89660						In the Linux kernel, the following vulnerability has been resolved: NFSv4.0 delegation revoke A stateid holds only a bare pointer to its nfs4_client; a stateid reference does not pin it. The client survives only because __destroy_client() drains its stateids before free_client() runs. nfsd4_revoke_states() drops nn->client_lock across revoke_one_stid(), which dereference...
CVE-2026-89661						In the Linux kernel, the following vulnerability has been resolved: NFSv4.0 post-shutdown use-after-free in unlock_filesystem Writing a filesystem path to /proc/fs/nfsd/unlock_filesystem runs nfsd4_cancel_copy_by_sb() before nfsd_mutex is held and before the handler confirms that nn->nfsd_serv is set. Once nfsd has shut down, nfs4_state_destroy_net() has freed nn->conf_id_hashtbl but left the pointer intact...
CVE-2026-89662						In the Linux kernel, the following vulnerability has been resolved: NFSv4.0 lock owner use-after-free during client teardown __destroy_client() releases a client's open owners, but a lock owner whose only reference is a blocked lock (nbl) stays on cl_ownerstr_hashtbl. client_has_state() does not count a bare owner, so DESTROY_CLIENTID can reach __destroy_client() with such owners present. __destroy_client...
CVE-2026-89663						In the Linux kernel, the following vulnerability has been resolved: nfsd: revoke copy-notify stateids before dropping their reference Copy-notify stateids live in the s2s_cp_stateids IDR and on their parent stid's sc_cp_list, pinned by a single membership reference. _free_cpntf_state_locked() only unlinks an entry once its refcount reaches zero, so any revoke path that runs while a concurrent find_cpntf_state()/...
CVE-2026-89664						In the Linux kernel, the following vulnerability has been resolved: nfsd: release OPEN-decoded posix ACLs via op_release nfsd4_decode_createhow4() calls nfsd4_decode_fattr4(), which allocates refcounted struct posix_acl objects via posix_acl_alloc() and stores them in open->op_pacl and open->op_dpac1. These pointers must be released once the OPEN compound finishes. When nfsd4_decode_open_claim4() returns a non-...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89665						In the Linux kernel, the following vulnerability has been resolved: nfsd: reject out-of-range useconds in NFSv2 SETATTR/CREATE The NFSv2 sattr decoder converts the wire useconds to nanoseconds in svcxdr_decode_sattr(): iap->ia_atime.tv_nsec = tmp2 * NSEC_PER_USEC; tmp2 is a u32 and NSEC_PER_USEC is 1000, so the product is computed in unsigned long. On ILP32 that is 32 bits, and an out-of-range useconds value ...
CVE-2026-89666						In the Linux kernel, the following vulnerability has been resolved: nfsd: reject out-of-range nseconds in NFSv3 SETATTR and create ops A client can send an NFSv3 SETATTR, CREATE, MKDIR, SYMLINK or MKNOD carrying an atime or mtime whose nseconds field is out of range. The value is well-formed on the wire and decodes cleanly into a valid uint32, but it is not a valid timespec64: tv_nsec must be less than NSEC_PER_...
CVE-2026-89667						In the Linux kernel, the following vulnerability has been resolved: nfsd: close shrinker/GC/fsnotify vs per-net shutdown race in filecache The shrinker, GC worker, and fsnotify/lease callbacks can unhash an nfsd_file from the rhashtable and then call nfsd_file_dispose_list_delayed() to move it to the per-net dispose list. If nfsd_file_cache_shutdown_net() runs concurrently, its rhashtable walk misses the already...
CVE-2026-89668						In the Linux kernel, the following vulnerability has been resolved: nfsd: move nfsd_debugfs_init() after nfsd4_init_slabs() in init_nfsd() nfsd_debugfs_init() runs before nfsd4_init_slabs() in init_nfsd(). If the slab allocation fails, the bare "return retval" bypasses nfsd_debugfs_exit(), leaving orphan debugfs files with stale fops pointers into the freed module text. Move nfsd_debugfs_init() to after the sla...
CVE-2026-89669						In the Linux kernel, the following vulnerability has been resolved: nfsd: initialize copy-notify stateid before publishing it nfsd4_copy_notify() finished initializing the cpmntf state after nfs4_alloc_init_cpmntf_state() had already linked it into the s2s_cp_stateids IDR and the parent's sc_cp_list, with cs_count == 1 (the membership reference) and none held for the caller. A racing OFFLOAD_CANCEL (crafted cl_id ...
CVE-2026-89670						In the Linux kernel, the following vulnerability has been resolved: nfsd: hold rcu across localio cmpxchg retry nfsd_file objects are freed via call_rcu (filecache.c:296), and nfsd_file_slab is created without SLAB_TYPESAFE_BY_RCU (KMEM_CACHE(nfsd_file, 0) at filecache.c:789), so the slab page backing a freed nfsd_file becomes freely reclaimable once the RCU grace period elapses. The again: retry block in nfsd_...
CVE-2026-89671						In the Linux kernel, the following vulnerability has been resolved: nfsd: gate nfs3 setacl by argp->mask nfsd3_proc_setacl() calls set_posix_acl() unconditionally for both ACL_TYPE_ACCESS and ACL_TYPE_DEFAULT, passing argp->acl_access and argp->acl_default verbatim. The NFSv3 ACL decoder only populates those pointers when the corresponding mask bit is set: nfs3svc_decode_setaclargs() if (args->mask & ...
CVE-2026-89672						In the Linux kernel, the following vulnerability has been resolved: nfsd: gate nfs2 setacl by argp->mask The NFSACL v2 SETACL path shares the decoder convention used by its v3 sibling: nfsaclsvc_decode_setaclargs() fills in argp->acl_access only when NFS_ACL is set in the request mask and argp->acl_default only when NFS_DFACL is set, leaving the other pointer NULL because the argument buffer is zeroed up to pc_a...
CVE-2026-89673						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix XDR padding calculation in ff_encode_getdeviceinfo nfsd4_ff_encode_getdeviceinfo() computes the da_addr_body reservation as 16 + netid_len + addr_len, but the subsequent xdr_encode_opaque() calls emit 8 + round_up(netid_len, 4) + round_up(addr_len, 4) bytes. The mismatch means the declared da_addr_body length exceeds the actual encoded...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89674						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix XDR length calculation in nfsd4_ff_encode_layoutget The XDR buffer size calculation in nfsd4_ff_encode_layoutget() has multiple errors that can result in either an out-of-bounds write or leaking uninitialized kernel memory to the client: - fh_len doesn't account for XDR padding on the file handle data - uid and gid lengths use "8 + ...
CVE-2026-89675						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix UAF in async copy cancel and shutdown An async copy could be freed or used after free while a teardown caller (OFFLOAD_CANCEL, nfsd4_shutdown_copy, nfsd4_cancel_copy_by_sb) raced the copy kthread: - find_async_copy() bumped copy->refcount but left the copy on clp->async_copies, so the reaper's cleanup_async_copy() could run ...
CVE-2026-89676						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix stale s2s_cp_stateids IDR entry for async COPY For an async COPY, nfsd4_copy() called nfs4_init_copy_state() before dup_copy_fields(), so the s2s_cp_stateids IDR was pointed at &u->copy->cp_stateid -- memory in the per-rqstp COMPOUND buffer that is reused by the next request. dup_copy_fields() copies only the value into async_copy, so ...
CVE-2026-89677						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix possible fh_compose of wrong dentry in nfsd4_create_file() dentry_create() can hypothetically provide a different dentry than the one passed in. This could happen, for example, if the exported filesystem is NFS, and the server returned to OPEN a filehandle which matched a directory that was already in the dcache. Clearly this would n...
CVE-2026-89678						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix partial-write detection in nfsd_direct_write nfsd_direct_write() walks a list of write segments and, after each vfs_iocb_iter_write(), tries to detect a short write so the loop can stop before placing the next segment at a wrong file offset: host_err = vfs_iocb_iter_write(file, kiocb, &segments[j].iter); if (host_err < 0) ...
CVE-2026-89679						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix null dereference in nfsd4_setattr for deleg timestamp attrs When a SETATTR request includes FATTR4_WORD2_TIME_DELEG_ACCESS or FATTR4_WORD2_TIME_DELEG_MODIFY in the attribute bitmap, nfsd4_setattr() sets deleg_attrs=true and calls nfs4_preprocess_stateid_op() to validate the stateid. If the client supplies the NFSv4 "one stateid" (all-...
CVE-2026-89680						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix nfsd_file leak on inter-server COPY setup failure When nfsd4_setup_inter_ssc() fails, nfsd4_copy() returns nfserr_offload_denied directly, bypassing the out: label where release_copy_files() would drop the nf_dst reference taken by nfs4_preprocess_stateid_op(). Each failed inter-server COPY leaks one nfsd_file, pinning file/inode/dentr...
CVE-2026-89681						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix layout fence worker double-reference race The workqueue core clears WORK_STRUCT_PENDING before the callback is invoked, so delayed_work_pending() in lm_breaker_timedout() can return false while the fence worker is already running. This lets the breaker take a duplicate sc_count reference and schedule a new worker that coalesces with th...
CVE-2026-89682						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix fcache_disposal UAF by inlining dispose state into nfsd_net nfsd_file_dispose_list_delayed() defers fput() to nfsd service threads via a per-net freeme queue, preventing the shrinker and GC worker from bearing the cost of closing files (see ffb402596147). However, the queue lives in a separately-allocated struct nfsd_fcache_disposal t...
CVE-2026-89683						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix dentry ref leak on V4ROOT export filehandle lookup nfsd_set_fh_dentry() leaks the dentry reference from exportfs_decode_fh_raw() when the NFS3_FHSIZE or NFS_FHSIZE switch cases detect NFSEXP_V4ROOT and goto out. The out: label calls exp_put() but never dput(dentry), and fh->fh_dentry was never assigned so fh_put() cannot compensate. ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89684						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix cpntf publish race in nfs4_init_cp_state nfs4_alloc_init_cpntf_state() published the new cpntf entry into the s2s_cp_stateids IDR (with cs_type set) in one s2s_cp_lock section, then took the lock again to list_add() it onto p_stid->sc_cp_list. In the gap the entry is reachable by so_id but cp_list is still {NULL,NULL} from kzalloc. A r...
CVE-2026-89685						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix clock domain mismatch in clients_still_reclaiming() clients_still_reclaiming() computes a deadline from nn->boot_time (CLOCK_REALTIME, ~1.7 billion) but compares it against ktime_get_boottime_seconds() (CLOCK_BOOTTIME, seconds since boot). The comparison is always false — it would take ~54 years of uptime for BOOTTIME to exceed the REA...
CVE-2026-89686						In the Linux kernel, the following vulnerability has been resolved: nfsd: fix BUG_ON in nfsd4_alloc_layout_stateid on racing delegation revoke nfsd4_alloc_layout_stateid reads fp->fi_deleg_file without holding fi_lock when the parent stateid is a delegation. A concurrent delegation revoke via the laundromat can clear fi_deleg_file under fi_lock, causing nfsd_file_get() to return NULL and triggering the BUG_ON. ...
CVE-2026-89687						In the Linux kernel, the following vulnerability has been resolved: nfsd: ensure nfsd_file_do_acquire() does not use a non-opened file ->atomic_open is permitted to return success without actually opening the file. It indicates this by calling finish_no_open(). This means dentry_create() can return a file which hasn't been opened. This is extremely unlikely as ->atomic_open handlers typically use finish_no_open...
CVE-2026-89688						In the Linux kernel, the following vulnerability has been resolved: nfsd: drop the stateid, not the stateowner, on seqid_op replay retry In nfs4_preprocess_seqid_op() the stateid is obtained from nfsd4_lookup_stateid(), which holds a reference on the nfs4_stid (sc_count) but takes no reference on the stateowner. openlockstateid() merely casts that stid and likewise takes no reference. When nfsd4_cstate_assign_r...
CVE-2026-89689						In the Linux kernel, the following vulnerability has been resolved: nfsd: don't free session slots that are still in use nfsd4_sequence() can free the very slot it is currently processing. When the session shrinker has reduced se_target_maxslots below se_fchannel.maxreqs, the shrink path checks three conditions before calling free_session_slots(): 1. se_target_maxslots < maxreqs (shrink was advertised) 2. ...
CVE-2026-89690						In the Linux kernel, the following vulnerability has been resolved: nfsd: defer vfree of compound ops to fix rpc_status UAF The rpc_status netlink dumpit walks every in-flight svc_rqst under rcu_read_lock and, for NFSv4 requests, reads opnums out of args->ops[]. But args->ops is a separate vmalloc buffer freed synchronously by vfree() in nfsd4_release_compoundargs() at the end of every compound. The dumpit's rcu...
CVE-2026-89691						In the Linux kernel, the following vulnerability has been resolved: nfsd: clear opcnt on compound arg release to prevent OOB read nfsd4_release_compoundargs() resets args->ops to the inline iops[8] array when the dynamically-allocated ops buffer is freed, but leaves args->opcnt at its original value (which can be up to 200 for NFSv4.1+ compounds). If rq_status_counter is stuck at an odd value (which can happen ...
CVE-2026-89692						In the Linux kernel, the following vulnerability has been resolved: nfsd: clear CALLBACK_RUNNING on failed delegation recall queue nfsd_break_one_deleg() sets NFSD4_CALLBACK_RUNNING via test_and_set_bit at entry to serialize recall work, then calls nfsd4_run_cb() to queue the recall. When the queue attempt fails the refcount bump is undone, but the RUNNING bit is left set. The only site that clears the bit is ...
CVE-2026-89693						In the Linux kernel, the following vulnerability has been resolved: nfsd: check nfsd4_acl_to_attr() return value in nfsd4_create() nfsd4_create() stores the return value of nfsd4_acl_to_attr() in status, but the switch(create->cr_type) block unconditionally overwrites it in every branch. ACL translation errors are silently discarded, and the CREATE proceeds without the requested ACL. Add an early exit check aft...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89694						In the Linux kernel, the following vulnerability has been resolved: nfsd: check client ownership when cancelling a copy-notify stateid On the OFFLOAD_CANCEL path (clp != NULL), manage_cpntf_state() freed the target cpntf state without checking ownership. The lookup key st->si_opaque.so_id is allocated cyclically (guessable) and the embedded clientid is the fixed per-net nn->s2s_cp_cl_id, so any authenticated NFS...
CVE-2026-89695						In the Linux kernel, the following vulnerability has been resolved: nfsd: cap decoded POSIX ACL count to bound sort cost nfsd4_decode_posixacl() reads a u32 entry count off the wire and passes it straight to posix_acl_alloc() and sort_pacl_range(). The latter is an O(n^2) bubble sort, so a client-chosen count drives unbounded CPU in the server's compound processing path. nfsd4_decode_posixacl() xdr_st...
CVE-2026-89696						In the Linux kernel, the following vulnerability has been resolved: nfsd: block non-SAVEFH ops after FOREIGN PUTFH to prevent NULL deref When CONFIG_NFSD_V4_2_INTER_SSC is enabled, nfsd4_putfh() can return success with fh_dentry and fh_export both NULL if fh_verify() returns nfserr_stale and putfh->no_verify is true. The NFSD4_FH_FOREIGN flag is set, but the compound dispatch loop only uses this flag to bypass t...
CVE-2026-89697						In the Linux kernel, the following vulnerability has been resolved: nfsd: add fh_want_write() for early-verified SETATTR in nfsd_proc_setattr() The BOTH_TIME_SET branch calls fh_verify() early so setattr_prepare() can inspect the dentry. This causes nfsd_setattr() to skip fh_want_write(), so notify_change() runs without a mount write reference. Add the missing fh_want_write() call after the early fh_verify().
CVE-2026-89698						In the Linux kernel, the following vulnerability has been resolved: nfsd: widen nfsd_genl_rqstp address fields to sockaddr_storage struct nfsd_genl_rqstp declares rq_daddr and rq_saddr as plain "struct sockaddr" (16 bytes). When an IPv6 NFS client is connected, nfsd_genl_rpc_status_compose_msg() casts these fields to "struct sockaddr_in6 *" (28 bytes) and reads sin6_addr at offset 8..24, which extends 8 bytes pa...
CVE-2026-89699						In the Linux kernel, the following vulnerability has been resolved: nfsd: validate symlink target length in NFSv4 CREATE nfsd4_decode_create() accepts an unbounded cr_dataLEN from the wire for NF4LNK symlink targets, allowing a client to force a kmalloc of up to the maximum RPC payload size (several MiB) per COMPOUND op that persists until compound teardown. The VFS rejects oversized targets with ENAMETOOLONG, ...
CVE-2026-89700						In the Linux kernel, the following vulnerability has been resolved: nfsd: validate sockaddr length per family in listener_set nfsd_sock_nl_policy declares NFSD_A_SOCKET_ADDR as a bare NLA_BINARY attribute with no minimum length. A CAP_NET_ADMIN caller can send a 16-byte NFSD_A_SOCKET_ADDR with sa_family=AF_INET6, causing a 12-byte OOB read across three consumers (rpc_cmp_addr_port, svc_find_listener, kernel_bind). ...
CVE-2026-89701						In the Linux kernel, the following vulnerability has been resolved: nfsd: validate nseconds in TIME_DELEG decode paths The xdrgen-based TIME_DELEG_ACCESS and TIME_DELEG_MODIFY decode arms store a raw uint32_t nseconds directly into tv_nsec without enforcing nseconds < NSEC_PER_SEC. The legacy nfsd4_decode_nfstime4 has this check but the TIME_DELEG paths do not. A malformed timespec can propagate through notify_c...
CVE-2026-89702						In the Linux kernel, the following vulnerability has been resolved: nfsd: size fh_verify server sockaddr slot by xpt_localLEN The nfsd_fh_verify and nfsd_fh_verify_err tracepoints declare the server sockaddr slot sized by xpt_remotelen but fill it from xpt_local using xpt_localLEN: TP_STRUCT__entry(... __sockaddr(server, rqstp->rq_xprt->xpt_remotelen) ...) TP_fa...
CVE-2026-89703						In the Linux kernel, the following vulnerability has been resolved: nfsd: set SC_STATUS_FREED in nfsd4_drop_revoked_stid for delegations nfsd4_drop_revoked_stid() handles FREE_STATEID for admin-revoked delegations but does not set SC_STATUS_FREED before releasing cl_lock. revoke_delegation() uses this flag to detect whether FREE_STATEID has already processed the delegation -- without it, the freed delegation is ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89704						In the Linux kernel, the following vulnerability has been resolved: nfsd: sample writeback error cursor before async COPY loop _nfsd_copy_file_range() samples dst->f_wb_err into "since" after the copy loop, then uses it to detect writeback errors via filemap_check_wb_err() once vfs_fsync_range() returns. Because the nfsd_file cache reuses a single struct file across requests targeting the same inode, a concurren...
CVE-2026-89705						In the Linux kernel, the following vulnerability has been resolved: nfsd: restore rq_status_counter to even on all nfsd_dispatch() exit paths nfsd_dispatch() sets rq_status_counter to an odd value once a request has been decoded, and back to an even value once it has been fully processed, forming a seq-lock like protocol with the lockless reader in nfsd_nl_rpc_status_get_dumpit(). Only the fully successful path...
CVE-2026-89706						In the Linux kernel, the following vulnerability has been resolved: nfsd: Reset write verifier when async COPY writeback fails Async COPY captures nn->writeverf at request time and reports it to the client via CB_OFFLOAD after the worker kthread completes. When the post-copy vfs_fsync_range() or filemap_check_wb_err() in _nfsd_copy_file_range() reports an error, the worker correctly leaves NFSD4_COPY_F_COMMITTED...
CVE-2026-89707						In the Linux kernel, the following vulnerability has been resolved: nfsd: release path refs on follow_down() error nfsd_cross_mnt() initializes a local struct path with mntget() and dget() before calling follow_down(). On a negative return the error arm jumps to out without releasing those references: err = follow_down(&path, follow_flags); if (err < 0) goto out; follow_down() never drops t...
CVE-2026-89708						In the Linux kernel, the following vulnerability has been resolved: nfsd: RCU-protect cl_cb_session to fix use-after-free on session teardown After a DESTROY_SESSION the per-session teardown path can free a session while rpciod still holds an inflight callback rpc_task that dereferences clp->cl_cb_session. nfsd4_probe_callback_sync() flushes cl_callback_wq, but once nfsd4_run_cb_work() has called rpc_call_async...
CVE-2026-89709						In the Linux kernel, the following vulnerability has been resolved: lockd, nfsd: RCU-protect nlmsvc_ops dispatch nlmsvc_ops is published by nfsd_lockd_init() and cleared by nfsd_lockd_shutdown() with plain stores, while lockd dereferences it unguarded from dispatch sites in fs/lockd/svcs.c. The pointer targets nfsd's .rodata and the fopen/fclose callbacks live in nfsd's .text, so a stale load after rmmod nfsd...
CVE-2026-89710						In the Linux kernel, the following vulnerability has been resolved: NFSv4.1: fix layout segment leak on the pnfs_layout_process() forget path When the server returns a new layout stateid while a valid one is still held, pnfs_layout_process() calls pnfs_mark_matching_lsegs_return() on the on-stack free_me list and jumps to out_forget. Segments whose reference count drops to zero are unlinked from lo->plh_segs and...
CVE-2026-89711						In the Linux kernel, the following vulnerability has been resolved: NFSD: remove flawed WARN_ON_ONCE from nfsd_mode_check The header for commit e75b23f9e323 ("nfsd: check d_can_lookup in fh_verify of directories") details the assumption that justified adding the WARN_ON_ONCE to nfsd_mode_check(), that assumption is invalid (in the case of NFS reexport). When NFSD exports an NFS filesystem it is very possible fo...
CVE-2026-89712						In the Linux kernel, the following vulnerability has been resolved: NFSD: restart ssc_expire_umount walk after dropping nfsd_ssc_lock nfsd4_ssc_expire_umount() walks nn->nfsd_ssc_mount_list with list_for_each_entry_safe(ni, tmp, ...). For each expired entry it sets nsui_busy = true, drops nfsd_ssc_lock to run mntput() on the source vfsmount, then reacquires the lock to list_del + kfree the entry and continue it...
CVE-2026-89713						In the Linux kernel, the following vulnerability has been resolved: NFSD: check truncate permission under inode lock nfsd_setattr() checks whether a size update needs NFSD_MAY_TRUNC before it takes inode_lock(). The comparison uses the file size sampled by that unlocked read, but the actual ATTR_SIZE update is applied later under inode_lock() by notify_change(). This leaves a TOCTOU window for append-only files...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89714						In the Linux kernel, the following vulnerability has been resolved: NFS: fix delegation_hash_table leak when nfs4_server_common_setup() fails nfs4_server_common_setup() allocates server->delegation_hash_table first, but server->destroy - the only path that frees the table via nfs4_destroy_server() - is not assigned until the very end of the function. If any intermediate step fails (the is_ds_only_client() check,...
CVE-2026-89715						In the Linux kernel, the following vulnerability has been resolved: NFS/localio: fix ref leak on nfs_uuid_add_file failure When nfs_uuid_add_file() races with nfs_uuid_put() tearing down uuid->net, it returns -ENXIO without publishing nfl->nfs_uuid via rcu_assign_pointer(). nfs_open_local_fh() then enters its error branch and only releases the slot's file ref and its paired net ref plus its own entry-time net r...
CVE-2026-89716						In the Linux kernel, the following vulnerability has been resolved: zram: validate deflate params We must validate user-supplied deflate winbits before we pass it to zlib_deflate_workspacesize(), which triggers BUG_ON() if winbits value is outside of valid ranges.
CVE-2026-89717						In the Linux kernel, the following vulnerability has been resolved: zram: set default primary compressor in zram_destroy_comps() Patch series "zram: fix zram issues reported by sashiko". Sashiko drove by and reported [1] a couple of zram issues: a possible BUG_ON() in zlib code due to missing winbits range validation and one possible NULL-ptr dereference in zcomp. Both are low risk yet still worth fixing. Thi...
CVE-2026-89718						In the Linux kernel, the following vulnerability has been resolved: zram: fix out-of-bounds access in writeback_store() Patch series "zram: fix stale scan bounds after reinitialization". Both writeback_store() and read_block_state() derive their table scan bounds from zram->disksize before acquiring dev_lock. If the device is reset and reinitialized with a smaller disksize between that read and lock acquisitio...
CVE-2026-89719						In the Linux kernel, the following vulnerability has been resolved: zram: fix out-of-bounds access in read_block_state() read_block_state() calculates nr_pages before taking dev_lock. If the device is reset and reinitialized with a smaller disksize before lock acquisition, nr_pages still describes the old table. The subsequent loop can then call slot_lock() past the end of the newly allocated table. Read disk...
CVE-2026-89720						In the Linux kernel, the following vulnerability has been resolved: ubifs: fix out-of-bounds read in signature length check ubifs_sb_verify_signature() bounds the on-disk ubifs_sig_node->len field before handing the signature payload to verify_pkcs7_signature(), but the check has the wrong sign: if (le32_to_cpu(signode->len) > snod->len + sizeof(struct ubifs_sig_node)) The signature bytes start sizeof(struct ...
CVE-2026-89721						In the Linux kernel, the following vulnerability has been resolved: phy: rockchip-samsung-dcphy: fix out-of-range max_register The PHY register block is 64KB, so with a register stride of 4 the last accessible register sits at offset 0xffff. max_register names 0x10000, one register past the end of the mapping: dumping the registers through the regmap debugfs interface reads beyond the ioremapped region and oopse...
CVE-2026-89722						In the Linux kernel, the following vulnerability has been resolved: PCI/sysfs: Fix out-of-bounds read in pci_write_legacy_io() pci_write_legacy_io() loads 4 bytes from the kernfs write buffer regardless of how many bytes userspace wrote: if (count != 1 && count != 2 && count != 4) return -EINVAL; return pci_legacy_write(bus, off, *(u32 *)buf, count); kernfs_fop_write_iter() allocates the buffer ...
CVE-2026-89723						In the Linux kernel, the following vulnerability has been resolved: nilfs2: fix slab-out-of-bounds in nilfs_direct_propagate after truncation Shuangpeng Bai reported that KASAN detected a slab-out-of-bounds error in nilfs_direct_propagate() during testing. Analysis revealed that after truncating a file, a node block immediately below the B-tree root was not deleted. Instead, it remained in the B-tree node cach...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89724						In the Linux kernel, the following vulnerability has been resolved: media: vicodec: fix out-of-bounds write in FWHT encoder vidioc_s_fmt_vid_out() sizes the encoder CAPTURE buffer from the compressed descriptor pixfmt_fwht, whose sizeimage_mult is 3: coded_w * coded_h * 3 + sizeof(struct fwht_cframe_hdr). fwht_encode_frame() encodes one plane per component, and an incompressible plane takes the FWHT_FRAME_UNENCO...
CVE-2026-89725						In the Linux kernel, the following vulnerability has been resolved: media: cec: stm32: prevent out-of-bounds write on RX overflow stm32_rx_done() appends each received CEC byte to rx_msg.msg[] using rx_msg.len as the write index, incrementing it on every RXBR (receive-byte-ready) interrupt without checking it against the buffer size: cec->rx_msg.msg[cec->rx_msg.len++] = val & 0xFF; rx_msg.msg[] is a fixed CEC...
CVE-2026-89726						In the Linux kernel, the following vulnerability has been resolved: lib/ucs2_string.c: fix out-of-bounds read in ucs2_strlen() Patch series "lib/ucs2_string.c: fix out-of-bounds read in ucs2_strlen()", v2. This series fixes an off-by-one out-of-bounds read in ucs2_strlen(). The first patch is the real fix, the second patch comes as a bonus and fixes the code indentation. This patch (of 2): ucs2_strlen()...
CVE-2026-89727						In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: GICv2: Don't WARN on out-of-range GICV_DIR INTID vpic_v2_deactivate() passes the INTID a guest wrote to GICV_DIR straight to vpic_get_vcpu_irq(), and treats a failed lookup as a "can't happen" condition with WARN_ON_ONCE(). The guest can make it happen at will, though: for any INTID outside of the implemented SGI, PPI and SPI ranges...
CVE-2026-89728						In the Linux kernel, the following vulnerability has been resolved: i3c: renesas: Fix out-of-bounds access for newdevs mask When software initiates DAA (Dynamic Address Assignment), the controller reports the result via the NRSPQP (Normal Response Queue Port Register). The data length field of the response descriptor, which is accessible through the NRSPQP register, indicates the number of devices remaining after...
CVE-2026-89729						In the Linux kernel, the following vulnerability has been resolved: HID: sensor-hub: Fix out-of-bounds write in sensor_hub_get_feature sensor_hub_get_feature() clamps its return value to the caller's buffer size, but the copy loop still copies field->report_size / 8 bytes for each report value. A malicious HID descriptor can advertise a large feature field size while an IIO caller supplies a small stack buffer, ...
CVE-2026-89730						In the Linux kernel, the following vulnerability has been resolved: fpga: altera-cvp: Avoid out-of-bounds read in trailing byte write The trailing byte path in altera_cvp_send_block() dereferences a u32 pointer even when only 1-3 bytes remain in the input buffer. If the buffer ends at a page or scatterlist boundary, this can read past the valid image data and fault. Copy the remaining bytes into a zero-initiali...
CVE-2026-89731						In the Linux kernel, the following vulnerability has been resolved: cxl/ras: Fix cxl_rch_get_aer_info() out-of-bounds AER register read cxl_rch_get_aer_info() copies the RCH Downstream Port AER capability from the RCRB MMIO block using a readl() loop bounded by sizeof(struct aer_capability_regs). This struct is a software layout and its embedded struct pcie_tlp_log is larger than the on-wire AER capability. As a...
CVE-2026-89732						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_fs: Prevent deadlock during ep0 read loop Currently, ffs_ep0_read() holds ffs->mutex when it prepares to go to sleep waiting for an event. When no setup events are pending, it calls wait_event_interruptible_exclusive_locked_irq() with the mutex still held. The wait macro deliberately drops the waitqueue spinlock before sleeping bu...
CVE-2026-89733						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: uvc: fix dangling pointers in uvc_function_bind() and uvc_function_unbind() In uvc_function_bind() error path, we use usb_ep_free_request which uses uvc->control_req but does not set it to NULL afterwards. Thus, uvc->control_req is a dangling pointer causing a UAF. Also we do not set the uvc->control_buf pointer to NULL after freein...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89734						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: uvc: Fix null pointer dereference in uvcg_video_init() In uvcg_video_init(), if kthread_run_worker() fails, the error logged uses uvcg_err(), however, the pointer it uses: video->uvc is not assigned at this point, triggering a null pointer dereference. Fix this by directly using uvc->func which is assigned already.
CVE-2026-89735						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: midi2: remove default configs groups on teardown f_midi2_alloc_inst() creates default configs child groups for the default endpoint and default block using configs_add_default_group(), setting their internal refcount to 1. However, during function teardown in f_midi2_free_inst() or EP cleanup in f_midi2_ep_opts_release(), config...
CVE-2026-89736						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: u_audio: Fix use-after-free on sound card disconnect g_audio_cleanup() invokes snd_card_free_when_closed() to initiate sound card teardown and immediately frees the underlying struct snd_uac_chip context. However, snd_card_free_when_closed() returns asynchronously while ALSA control elements (kctls) remain open in userspace. When u...
CVE-2026-89737						In the Linux kernel, the following vulnerability has been resolved: usb: typec: thunderbolt: Disable work before freeing tbt on remove tbt_altmode_remove() drops the plug and cable references without draining tbt->work. The work function dereferences those references, and can also requeue itself in its error path. The VDM callbacks can queue the same work item. Disable and drain tbt->work before dropping the re...
CVE-2026-89738						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: at91_udc: drain polled-VBUS timer/work before udc is freed In polled-VBUS mode (board.vbus_pin && board.vbus_polled), probe arms a self-restarting cycle: at91_vbus_timer() schedules vbus_timer_work, and at91_vbus_timer_work() calls at91_vbus_update() and re-arms the timer via mod_timer(). Both recover the same udc through container_...
CVE-2026-89739						In the Linux kernel, the following vulnerability has been resolved: usb: dwc3: gadget: Fix use-after-free in dwc3_gadget_free_endpoints due to race condition In dwc3_gadget_init_endpoint, &dep->nostream_work is bound with dwc3_nostream_work, and dwc3_gadget_endpoint_stream_event can queue this delayed work on system_percpu_wq when a DEPEVT_STREAM_NOSTREAM event is received. If we remove the gadget, dwc3_gadget_...
CVE-2026-89740						In the Linux kernel, the following vulnerability has been resolved: serial: imx: serialize imx_uart_ports[] lifetime imx_uart_probe() publishes its devm-allocated port in imx_uart_ports[] before uart_add_one_port() because console setup uses the table. The entry is not cleared when adding the port fails or after removal, leaving a dangling pointer. A sibling probe can register the shared console through that st...
CVE-2026-89741						In the Linux kernel, the following vulnerability has been resolved: Revert "media: v4l2-dev: fix error handling in __video_register_device()" This reverts commit 2a934fdb01db6458288fc9386d3d8ceba6dd551a. The intentions of that patch were good, but it doesn't work. The idea is that if device_register fails, you have to do a put_device to let the ref counter release resources. However, the V4L2 API says that if...
CVE-2026-89742						In the Linux kernel, the following vulnerability has been resolved: rapidio: mport_cdev: fix use-after-free in dma_req_free() dma_req_free() acquires buf_mutex through req->map, drops the mapping reference with kref_put(), and then dereferences req->map again to unlock the mutex. If kref_put() drops the last reference, mport_release_mapping() frees the mapping, and the subsequent mutex_unlock() dereferences a f...
CVE-2026-89743						In the Linux kernel, the following vulnerability has been resolved: misc: nsm: bound the device-reported response length nsm_sendrecv_msg_locked() stores the virtqueue used-ring length reported by the NSM device into msg->resp.len without bounding it to the response buffer. A malicious or buggy backend can report a length larger than the response buffer; parse_resp_raw() then copies that many bytes out of the fi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89744						In the Linux kernel, the following vulnerability has been resolved: device property: fix infinite loop in fwnode_for_each_child_node() When iterate over children of a fwnode that has a secondary fwnode, fwnode_get_next_child_node() can enter an infinite loop if the secondary fwnode has more than one child. Parent Child (Primary fwnode) FWa: {FWa1, FWa2, FWa3} (Seconda...
CVE-2026-89745						In the Linux kernel, the following vulnerability has been resolved: debugfs: Fix lockdown check for mmap_prepare Commit 651fdda8406d ("relay: update relay to use mmap_prepare") changed the `mmap` file operation to `mmap_prepare` for relayfs, but the lockdown check in debugfs was not updated accordingly. This prevents debugfs from being locked down when the kernel is in integrity mode if a file uses `mmap_prepar...
CVE-2026-89746						In the Linux kernel, the following vulnerability has been resolved: tracing: Fix use-after-free with same-name named triggers When two hist triggers on different events are registered with the same name=, the second one reuses the first as named_data. Both are added to tr->hist_vars by save_hist_vars() during event_hist_trigger_parse(), because save_hist_vars() is called before event_trigger_register() while th...
CVE-2026-89747						In the Linux kernel, the following vulnerability has been resolved: tracing: Fix use-after-free in trace_pipe read on sub-buffer order change Writing to buffer_subbuf_size_kb calls ring_buffer_subbuf_order_set(), which frees every sub-buffer of the ring buffer, including the reader page, and replaces them with newly allocated ones. Readers of trace_pipe hold pointers into those pages. ring_buffer_peek() looks u...
CVE-2026-89748						In the Linux kernel, the following vulnerability has been resolved: tracing: Fix retry exhaustion in simple ring buffer reader swap simple_ring_buffer_swap_reader_page() starts with retry set to 8 and post-decrements it only after a failed link replacement. On the final attempt, a successful replacement leaves retry at zero, while a failed replacement leaves it at -1. The current !retry test reverses both outco...
CVE-2026-89749						In the Linux kernel, the following vulnerability has been resolved: tracing: Fix crash passing ERR_PTR to kthread_stop() event_test_stuff() calls kthread_run() and unconditionally passes the returned task_struct pointer to kthread_stop(). kthread_run() returns an error pointer such as ERR_PTR(-ENOMEM) when kthread creation fails, for example under memory pressure during the boot-time event self-test. kthread_sto...
CVE-2026-89750						In the Linux kernel, the following vulnerability has been resolved: tracing/user_events: Clear copied tracing state before fork duplication dup_task_struct() copies user_event_mm from the parent into the child, without grabbing a reference to it. user_event_mm_dup() should replace it, but it leaves that copied pointer unmodified if user_event_mm_alloc() fails. When the child exits, user_event_mm_remove() decrem...
CVE-2026-89751						In the Linux kernel, the following vulnerability has been resolved: x86/tdx: Fix off-by-one in port I/O handling handle_in() and handle_out() in arch/x86/coco/tdx/tdx.c use: u64 mask = GENMASK(BITS_PER_BYTE * size, 0); GENMASK(h, l) includes bit h. For size=1 (INB), this produces GENMASK(8, 0) = 0x1FF (9 bits) instead of GENMASK(7, 0) = 0xFF (8 bits). The mask is one bit too wide for all I/O sizes. Fix th...
CVE-2026-89752						In the Linux kernel, the following vulnerability has been resolved: mm: memcg: stop reclaim when a limit update is superseded kernfs serializes file operations only per open file, so separate open files can update the same memory.high or memory.max file concurrently. Both handlers store the new limit before synchronous reclaim, but continue to use the writer's local target in the reclaim loop. If another write...
CVE-2026-89753						In the Linux kernel, the following vulnerability has been resolved: mm/vmscan: report RCU-tasks quiescent states in shrink_lruvec() I am seeing some rcu_tasks stalls in the Meta fleet during reclaim. INFO: rcu_tasks detected stalls on tasks: 0000000088620d09: .. nvcs: 6735/6735 holdout: 1 idle_cpu: -1/8 task:GlobalCPUThread state:R running task pid:2552016 tgid:2524552 Call Trace: shrink_lruvec m...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89754						In the Linux kernel, the following vulnerability has been resolved: mm/pagewalk: fix stale walk->action escaping walk_pmd_range() If ->pmd_entry() sets walk->action = ACTION_AGAIN, the pmd_none() check is retried. The PMD entry may be cleared at the point of retry. In this case, if walk->ops->install_pte is not specified, the code continues to the next PMD entry in the range without resetting walk->action to A...
CVE-2026-89755						In the Linux kernel, the following vulnerability has been resolved: mm/migrate_device: clear stale mapping after freeing swapcache __migrate_device_pages() reads the folio mapping before calling folio_free_swap(). When folio_free_swap() succeeds, the folio is removed from the swap cache, but the saved mapping still points to swap_space. Passing the stale mapping to folio_migrate_mapping() makes it use the mapp...
CVE-2026-89756						In the Linux kernel, the following vulnerability has been resolved: mm/migrate: report RCU-tasks quiescent states in migrate_pages_batch() migrate_pages_batch() unmaps each folio before moving it, and every unmap runs the mmu_notifier invalidate callbacks. On KVM hosts try_to_migrate() ends up in kvm_mmu_notifier_invalidate_range_start() -> tdp_mmu_zap_leafs(), which is expensive, so unmapping a large batch kee...
CVE-2026-89757						In the Linux kernel, the following vulnerability has been resolved: mm/mglru: fix and remove redundant unevictable folio handling sort_folio() has a shortcut for moving folios that are no longer evictable but are still sitting on a generation list. However, this shortcut is buggy. It does not follow the PG_lru usage convention, and it has a more serious issue. Unevictable folios are not threaded on lists[LRU_...
CVE-2026-89758						In the Linux kernel, the following vulnerability has been resolved: mm/mempolicy: skip non-present PMDs when queueing folios Patch series "mm: handle device-private PMDs in walk callbacks", v3. Since commit 368076f52ebe ("mm/huge_memory: add device-private THP support to PMD operations") a PMD may hold a device-private swap entry whenever an HMM-based GPU driver migrates an anonymous THP folio to device memory ...
CVE-2026-89759						In the Linux kernel, the following vulnerability has been resolved: mm/kmemleak: avoid soft lockup when scanning task stacks Patch series "mm/kmemleak: avoid soft lockup when scanning task", v3. kmemleak_scan() scans every task stack under one rcu_read_lock() with no reschedule point, which can trip the soft lockup watchdog on hosts with very many threads. That prints the following message, depending on the wo...
CVE-2026-89760						In the Linux kernel, the following vulnerability has been resolved: mm, swap: don't free a hibernation slot that is in the swap cache A slot with a folio in the swap cache is freed when the folio leaves the cache, not when its count drops. swap_put_entries_cluster() follows that rule. swap_free_hibernation_slot() does not, it calls __swap_cluster_free_entries() whether or not a folio sits on the slot. Cluster...
CVE-2026-89761						In the Linux kernel, the following vulnerability has been resolved: apparmor: fix out-of-bounds write when null terminating a label vec aa_vec_unique() null terminates at vec[n - dups] when VEC_FLAG_TERMINATE is passed. If the components are all distinct no duplicates are dropped, dups is 0 and the terminator goes to vec[n], so the caller has to provide room for n + 1 entries. aa_label_strn_parse() sets up its ...
CVE-2026-89762						In the Linux kernel, the following vulnerability has been resolved: apparmor: fix cred UAF caused by begin_current_label_crit_section() AppArmor's begin_current_label_crit_section() is a scary function called from lots of LSM hooks (in particular VFS/socket-related ones) that checks if the label referenced by the current creds is marked FLAG_STALE, and if so, attempts to use aa_replace_current_label() to replace...
CVE-2026-89763						In the Linux kernel, the following vulnerability has been resolved: KEYS: trusted: Fix TPM teardown ordering trusted_tpm_exit() drops the TPM chip reference and frees the digest array before unregistering the trusted key type. key_type_lookup() holds key_types_sem for reading until the key operation finishes, while unregister_key_type() takes it for writing. It therefore provides the synchronization point that m...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89764						In the Linux kernel, the following vulnerability has been resolved: rust: devres: fix race between concurrent revokers There is a potential race condition when two paths try to revoke a Devres concurrently. The driver core's devres_release_all() calls Revocable::revoke() via the release callback, while Devres::drop() calls revoke_nosync() on another CPU. The revoker that does not claim the is_available swap re...
CVE-2026-89765						In the Linux kernel, the following vulnerability has been resolved: timers/itimer: Zero-init old itimerval before copy to userspace On native sparc64, struct __kernel_old_timeval contains a four-byte hole after tv_usec because tv_sec is 64-bit while __kernel_suseconds_t is 32-bit. put_itimerval() fills only the named fields in a stack-allocated __kernel_old_itimerval and copies the entire object to userspace, so...
CVE-2026-89766						In the Linux kernel, the following vulnerability has been resolved: pidfd: hold exec_update_lock around namespace ioctl The PIDFD_GET_*_NAMESPACE ioctls in pidfd_ioctl() perform a filesystem credentials ptrace access check before handing out a namespace file descriptor. The accompanying comment states that the code "mirrors nsfs behavior", but, unlike the corresponding procfs paths, it does so without holding t...
CVE-2026-89767						In the Linux kernel, the following vulnerability has been resolved: ovl: fix double end_creating() on the casefold-mismatch path ovl_create_real() releases the new dentry twice when the casefold consistency check fails. The S_IFDIR branch calls end_creating() and sets err, then falls through to the common out: label which calls end_creating() on the same dentry again: case S_IFDIR: newdentry = ovl_do_mkdir(...
CVE-2026-89768						In the Linux kernel, the following vulnerability has been resolved: fs: fix user path of nested backing files backing_file_open() derives the path to be stored in the new backing file from user_file->f_path. This is incorrect when user_file itself is a backing file, which is the case for nested stacking filesystems, e.g. overlayfs mounts where the lowerdir of one overlayfs is the merged directory of another. S...
CVE-2026-89769						In the Linux kernel, the following vulnerability has been resolved: clocksource/drivers/nxp-pit: Fix IRQ leak on cpuhp_setup_state error path When cpuhp_setup_state fails after pit_clockevent_per_cpu_init has successfully called request_irq, the error handling jumps directly to out_pit_clocksource_unregister without freeing the registered IRQ. This leaks the IRQ line and, since kfree(pit) follows, leaves a dang...
CVE-2026-89770						In the Linux kernel, the following vulnerability has been resolved: iomap: don't free integrity payload that doesn't exist fs_bio_integrity_alloc might not allocate a bio integrity payload if PI verification is disabled on the block device. Check for that case before calling fs_bio_integrity_free in iomap_bio_read_folio_range_sync to avoid a NULL pointer dereferences. Make the branch cover the PI verification ...
CVE-2026-89771						In the Linux kernel, the following vulnerability has been resolved: ring-buffer: Fix subbuf resize race with ring buffer readers trace_buffer subbuf_size is read lockless in ring_buffer_read_page() and ring_buffer_read_start(), while it can simultaneously be resized with ring_buffer_subbuf_order_set(). Instead of trace_buffer::subbuf_size, use bpage::order in ring_buffer_read_start() and ring_buffer_read_page()...
CVE-2026-89772						In the Linux kernel, the following vulnerability has been resolved: btrfs: write-protect folios during data writeback commit 095be159f3eb ("btrfs: unify folio dirty flag clearing") replaced the folio_clear_dirty_for_io() call in extent_write_cache_pages() with a plain folio_test_dirty() check. Besides clearing the dirty flag, folio_clear_dirty_for_io() also calls folio_mkclean(), which write-protects the shared ...
CVE-2026-89773						In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: Skip Update HDCP Config In Transition State Transition state does not have a valid dm_stream_ctx that should skip configuring HDCP routine. The routine is valid to go through only when a valid stream is created.